

PP-Module for VPN Client



Version: 3.0
2025-09-30

National Information Assurance Partnership

Revision History

Version	Date	Comment
2.1	2019-11-14	Initial Release
2.2	2021-01-05	Update release
2.3	2021-08-10	Support for MDF, Bluetooth updates
2.4	2022-03-31	Incorporation of TC feedback
2.5	2024-06-24	Incorporation of TC feedback: • Incorporation of TDs: 0662, 0672, 0690, 0697, 0711, 0725, 0753, 0788 • Corrections to Base-PP references • Definition of auditable events for Additional SFRs • Explicit association of evaluation activities with components and elements
3.0	2025-09-30	CC:2022 conversion, limitation of cryptographic algorithms to CNSA 1.0, incorporation of TDs

Contents

- 1 Introduction
 - 1.1 Overview
 - 1.2 Terms
 - 1.2.1 Common Criteria Terms
 - 1.2.2 Technical Terms
 - 1.3 Compliant Targets of Evaluation
 - 1.3.1 TOE Boundary
 - 1.4 Use Cases
 - 1.5 Package Usage
 - 1.6 Requirements Focus
- 2 Conformance Claims
- 3 Security Problem Definition
 - 3.1 Threats
 - 3.2 Assumptions
 - 3.3 Organizational Security Policies
- 4 Security Objectives
 - 4.1 Security Objectives for the Operational Environment
 - 4.2 Security Objectives Rationale
- 5 Security Requirements
 - 5.1 Protection Profile for Protection Profile for General Purpose Operating System Security Functional Requirements Direction
 - 5.1.1 Modified SFRs
 - 5.1.1.1 Cryptographic Support (FCS)
 - 5.1.2 Additional SFRs
 - 5.1.2.1 Auditable Events for GPOS PP Additional SFRs
 - 5.1.2.2 Cryptographic Support (FCS)
 - 5.1.2.3 Identification and Authentication (FIA)
 - 5.1.2.4 Trusted Path/Channels (FTP)
 - 5.2 Protection Profile for Protection Profile for Mobile Device Fundamentals Security Functional Requirements Direction
 - 5.2.1 Modified SFRs
 - 5.2.1.1 Cryptographic Support (FCS)

- 5.2.1.2 User Data Protection (FDP)
 - 5.2.1.3 Security Management (FMT)
 - 5.2.1.4 Trusted Path/Channels (FTP)
- 5.2.2 Additional SFRs
 - 5.2.2.1 Auditable Events for MDF PP Additional SFRs
 - 5.2.2.2 User Data Protection (FDP)
- 5.3 Protection Profile for Protection Profile for Application Software Security Functional Requirements Direction
 - 5.3.1 Modified SFRs
 - 5.3.1.1 Cryptographic Support (FCS)
 - 5.3.1.2 Trusted Path/Channels
 - 5.3.2 Additional SFRs
 - 5.3.2.1 Auditable Events for App PP Additional SFRs
 - 5.3.2.2 Cryptographic Support (FCS)
- 5.4 Protection Profile for Protection Profile for Mobile Device Management Security Functional Requirements Direction
 - 5.4.1 Modified SFRs
 - 5.4.1.1 Cryptographic Support (FCS)
 - 5.4.1.2 Protection of the TSF (FPT)
 - 5.4.1.3 Trusted Path/Channels (FTP)
 - 5.4.2 Additional SFRs
- 5.5 TOE Security Functional Requirements
 - 5.5.1 Auditable Events for Mandatory SFRs
 - 5.5.2 Cryptographic Support (FCS)
 - 5.5.3 User Data Protection (FDP)
 - 5.5.4 Security Management (FMT)
 - 5.5.5 Protection of the TSF (FPT)
- 5.6 TOE Security Functional Requirements Rationale
- 6 Consistency Rationale
 - 6.1 Protection Profile for Protection Profile for General Purpose Operating System
 - 6.1.1 Consistency of TOE Type
 - 6.1.2 Consistency of Security Problem Definition
 - 6.1.3 Consistency of OE Objectives
 - 6.1.4 Consistency of Requirements
 - 6.2 Protection Profile for Protection Profile for Mobile Device Fundamentals
 - 6.2.1 Consistency of TOE Type
 - 6.2.2 Consistency of Security Problem Definition
 - 6.2.3 Consistency of OE Objectives
 - 6.2.4 Consistency of Requirements
 - 6.3 Protection Profile for Protection Profile for Application Software
 - 6.3.1 Consistency of TOE Type
 - 6.3.2 Consistency of Security Problem Definition
 - 6.3.3 Consistency of OE Objectives
 - 6.3.4 Consistency of Requirements
 - 6.4 Protection Profile for Protection Profile for Mobile Device Management
 - 6.4.1 Consistency of TOE Type
 - 6.4.2 Consistency of Security Problem Definition
 - 6.4.3 Consistency of OE Objectives
 - 6.4.4 Consistency of Requirements
- Appendix A - Optional SFRs
 - A.1 Strictly Optional Requirements
 - A.1.1 Auditable Events for Strictly Optional SFRs
 - A.1.2 Identification and Authentication (FIA)
 - A.1.3 Packet Filtering (FPF)
 - A.2 Objective Requirements
 - A.2.1 Auditable Events for Objective SFRs
 - A.2.2 Security Audit (FAU)
 - A.3 Implementation-dependent Requirements
 - A.3.1 Auditable Events for Implementation-dependent SFRs
 - A.3.2 Security Audit (FAU)

Appendix B -	Selection-based Requirements
B.1	Auditable Events for Selection-based SFRs
B.2	Cryptographic Support (FCS)
B.3	Identification and Authentication (FIA)
Appendix C -	Extended Component Definitions
C.1	Extended Components Table
C.2	Extended Component Definitions
C.2.1	Cryptographic Support (FCS)
C.2.1.1	FCS_CKM_EXT Cryptographic Key Management
C.2.1.2	FCS_IPSEC_EXT IPsec
C.2.1.3	FCS_EAP_EXT EAP-TLS
C.2.2	Identification and Authentication (FIA)
C.2.2.1	FIA_X509_EXT X.509 Certificate Use and Management
C.2.2.2	FIA_BMA_EXT Biometric Activation
C.2.2.3	FIA_PSK_EXT Pre-Shared Key Composition
C.2.3	Packet Filtering (FPF)
C.2.3.1	FPF_MFA_EXT Multifactor Authentication Filtering
C.2.4	Protection of the TSF (FPT)
C.2.4.1	FPT_TST_EXT TSF Self-Test
C.2.5	User Data Protection (FDP)
C.2.5.1	FDP_VPN_EXT Subset Information Flow Control
Appendix D -	Implicitly Satisfied Requirements
Appendix E -	Entropy Documentation and Assessment
Appendix F -	Acronyms
Appendix G -	Bibliography

1 Introduction

1.1 Overview

The scope of this Protection Profile Module (PP-Module) is to describe the security functionality of a virtual private network (VPN) client in terms of [CC] and to define functional and assurance requirements for such products. This PP-Module is intended for use with the following Base-PPs:

- Protection Profile for General Purpose Operating Systems (GPOS PP), Version 5.0
- Protection Profile for Mobile Device Fundamentals (MDF PP), Version 4.0
- Protection Profile for Application Software (App PP), Version 2.0
- Protection Profile for Mobile Device Management (MDM PP), Version 5.0

These Base-PPs are all valid because a VPN client may be a specific type of stand-alone software application or a built-in component of an operating system (OS), whether desktop or mobile. Regardless of which Base-PP is claimed, the VPN client functionality defined by this PP-Module will rely on the Base-PP. Sections 5.1 through 5.4 of this PP-Module describe the relevant functionality for each Base-PP, including specific selections and assignments, or inclusion of optional requirements that must be made as needed to support the VPN client functionality.

1.2 Terms

The following sections list Common Criteria and technology terms used in this document.

1.2.1 Common Criteria Terms

Assurance	Grounds for confidence that a TOE meets the SFRs [CC].
Base Protection Profile (Base-PP)	Protection Profile used as a basis to build a PP-Configuration.
Collaborative Protection Profile (cPP)	A Protection Profile developed by international technical communities and approved by multiple schemes.
Common Criteria (CC)	Common Criteria for Information Technology Security Evaluation (International Standard ISO/IEC 15408).
Common Criteria Testing Laboratory	Within the context of the Common Criteria Evaluation and Validation Scheme (CCEVS), an IT security evaluation facility accredited by the National Voluntary Laboratory Accreditation Program (NVLAP) and approved by the NIAP Validation Body to conduct Common Criteria-based evaluations.
Common Evaluation Methodology (CEM)	Common Evaluation Methodology for Information Technology Security Evaluation.
Direct Rationale	A type of Protection Profile, PP-Module, or Security Target in which the security problem definition (SPD) elements are mapped directly to the SFRs and possibly to the security objectives for the operational environment. There are no security objectives for the TOE.
Distributed TOE	A TOE composed of multiple components operating as a logical whole.
Extended Package (EP)	A deprecated document form for collecting SFRs that implement a particular protocol, technology, or functionality. See Functional Packages.
Functional Package (FP)	A document that collects SFRs for a particular protocol, technology, or functionality.

Operational Environment (OE)	Hardware and software that are outside the TOE boundary that support the TOE functionality and security policy.
Protection Profile (PP)	An implementation-independent set of security requirements for a category of products.
Protection Profile Configuration (PP-Configuration)	A comprehensive set of security requirements for a product type that consists of at least one Base-PP and at least one PP-Module.
Protection Profile Module (PP-Module)	An implementation-independent statement of security needs for a TOE type complementary to one or more Base-PPs.
Security Assurance Requirement (SAR)	A requirement to assure the security of the TOE.
Security Functional Requirement (SFR)	A requirement for security enforcement by the TOE.
Security Target (ST)	A set of implementation-dependent security requirements for a specific product.
Target of Evaluation (TOE)	The product under evaluation.
TOE Security Functionality (TSF)	The security functionality of the product under evaluation.
TOE Summary Specification (TSS)	A description of how a TOE satisfies the SFRs in an ST.

1.2.2 Technical Terms

Administrator	A user that has administrative privilege to configure the TOE in privileged mode.
Authorized	An entity granted access privileges to an object, system, or system entity.
Critical Security Parameter (CSP)	Security related information such as secret and private cryptographic keys, and authentication data such as passwords and PINs, whose disclosure or modification can compromise the security of a cryptographic module.
Entropy Source	This cryptographic function provides a seed for a random number generator by accumulating the outputs from one or more noise sources. The functionality includes a measure of the minimum work required to guess a given output and tests to ensure that the noise sources are operating properly.
IT Environment	Hardware and software that are outside the TOE boundary that support the TOE functionality and security policy.
Private Network	A network that is protected from access by unauthorized users or entities.
Privileged Mode	A TOE operational mode that allows a user to perform functions that require IT environment administrator privileges.
Public Network	A network that is visible to all users and entities and does not protect against unauthorized access (e.g., internet).
Threat Agent	An entity that tries to harm an information system through destruction, disclosure, modification of data, or denial of service.
Unauthorized User	An entity (device or user) that has not been authorized by an authorized administrator to access the TOE or private network.

Unprivileged Mode	A TOE operational mode that only provides VPN client functions for the VPN client user.
VPN Client	The TOE; allows remote users to use client computers to establish an encrypted IPsec tunnel across an unprotected public network to a private network.
VPN Client User	A user operating the TOE in unprivileged mode.
VPN Gateway	A component that performs encryption and decryption of IP packets as they cross the boundary between a private network and a public network.

1.3 Compliant Targets of Evaluation

The TOE defined by this PP-Module is the VPN client, a software application that runs on a physical or virtual host platform, used to establish a secure IPsec connection between that host platform and a remote system. The VPN client is intended to be located outside or inside of a private network, and establishes a secure tunnel to an IPsec peer. For the purposes of this PP-Module, IPsec peers are defined as:

- VPN gateways
- Other VPN clients
- An IPsec-capable network device (supporting IPsec for the purposes of management)

The tunnel provides confidentiality, integrity, and data authentication for information that travels across a less trusted (sometimes public) network. All VPN clients that comply with this document will support IPsec.

This PP-Module extends the GPOS PP when the VPN client is installed on an OS discussed in that PP (e.g., Windows, Mac OS, Linux). This PP-Module extends the MDF PP when the VPN client is installed on a self-contained mobile device that is bundled with an OS (e.g., Android, BlackBerry OS, iOS, Windows Mobile). This PP-Module extends the App PP when the VPN client is provided by a third party and is a standalone application that is not a bundled part of an OS or mobile device. This PP-Module extends the MDM PP when the VPN client is included with MDM server software that is used for centralized deployment and administration of enterprise mobile device policies.

As a PP-Module of any of these PPs, it is expected that the content of this PP-Module and the chosen Base-PP be appropriately combined in the context of each product-specific ST. This PP-Module has been specifically defined such that there should be no difficulty or ambiguity in doing so. When this PP-Module is used, conformant TOEs are obligated to implement the functionality required in the claimed Base-PP with the additional functionality defined in this PP-Module in response to the threat environment discussed in this PP-Module.

1.3.1 TOE Boundary

The TOE defined by this PP-Module is purely a software solution executing on a platform (some sort of OS running on hardware). Depending on the Base-PP claimed as part of the TOE, the platform may also be part of the TOE or it may be an environmental component that the TOE vendor has no control over. Regardless of whether the platform itself is within the scope of the evaluation, the VPN client itself will rely on the platform for its execution domain and proper usage. The vendor is expected to provide sufficient installation and configuration instructions to identify an Operational Environment (OE) with the necessary features and to provide instructions for how to configure it correctly.

The PP-Module contains requirements that must be met by the TOE. Depending on the Base-PP that is claimed, there may be some variation in the applicable requirements. This is because a given Base-PP may include one or more requirements that the VPN client can inherit but are not shared between each possible Base-PP.

This is somewhat different than other PPs, but addresses most implementations of VPN clients where some part of the functionality of the IPsec tunnel is provided by the platform. In terms of the cryptographic primitives (random bit generation, encryption and decryption, key generation, etc.) it is actually desirable that a well-tested implementation in the platform is used rather than trying to implement these functions in each client.

Requirements that can be satisfied by either the TOE or the platform are identified in Section 5 by text such as “The [selection: TSE, TOE platform] shall...” The ST author will make the appropriate selection based on where that element is implemented. It is allowable for some elements in a component to be implemented by the TOE, while other elements in that same component be implemented by the platform (requirements on the usage of X.509 certificates is an example of where this might be the case, where using the information contained in the certificates and the implementation of revocation checking may be done by the

TOE, but storage and protection of the certificates may be done by the platform). Note that in the cases where this PP-Module is used to extend the GPOS PP or MDF PP, the TOE includes both the VPN client and the platform. In this case, it is appropriate to indicate that the TOE satisfies this requirement. However, the ST author should make it clear, for each of these components, which are implemented by the VPN client portion of the TOE versus the platform portion.

A Supporting Document (SD) accompanies this PP-Module and contains guidance for how to evaluate the requirements defined by the PP-Module, expressed as Evaluation Activities (EAs). EAs will differ based on where the function that meets the requirement is implemented. In most cases, requirements implemented by the platform will require that the evaluator examine documents pertaining to the platform (generally the ST), while requirements implemented by the TOE may require examination of the TSS, examination of the Operational Guidance, or execution of evaluator testing. For requirements implemented by the platform, there may also be requirements where the evaluator must examine the interfaces used by the TOE to access these functions on the platform. This ensures that the functionality being invoked to satisfy the requirements of this PP-Module is the same functionality that was evaluated.

Given the degree of coupling between a VPN client and its underlying platform, it is expected that the client will be tested on each platform claimed in the ST. In cases where the platforms are simply different versions of the same OS (provided by the same platform vendor), an equivalency argument may be made in lieu of testing on each version. The argument would have to demonstrate that the client interacts in exactly the same way with the versions of the OS (i.e., the same APIs are used with the same parameters, the network stack is modified with exactly the same kernel modules). The evaluator shall use the operational guidance to configure the TOE and underlying platform.

A TOE that conforms to this PP-Module will implement the Internet Engineering Task Force (IETF) IPsec Security Architecture for the Internet Protocol, RFC 4301, as well as the IPsec Encapsulating Security Payload (ESP) protocol. IPsec ESP is specified in RFC 4303. The IPsec VPN client will support ESP in either tunnel mode, transport mode, or both.

The IPsec VPN client will use the Internet Key Exchange (IKE)v2 protocol. IKEv2 is implemented as specified in RFC 7296 and 4307 to authenticate and establish session keys with the VPN entities. The IKEv2 implementation also requires mandatory support for network address translation (NAT) traversal as specified in section 2.23 of RFC 7296.

To show that the TSF implements the RFCs correctly, the evaluator shall perform the EAs documented in the SD that accompanies this PP-Module. In future versions of this PP-Module, EAs may be modified or new ones may be introduced that cover more aspects of RFC compliance than what is currently described in this publication.

The IPsec VPN client enables encryption of all information that flows between itself and its IPsec peer. The VPN client serves as an endpoint for an IPsec VPN connection and performs a number of cryptographic functions related to establishing and maintaining that connection. If the cryptography used to perform endpoint authentication, generate keys, and encrypt information is sufficiently robust and the implementation has no critical design mistakes, an adversary will be unable to exhaust the encryption key space to obtain the data. Compliance with IPsec standards, use of a properly seeded Random Bit Generator (RBG), and secure authentication factors will ensure that access to the transmitted information cannot be obtained with less work than a full exhaust of the key space. Any plaintext secret and private keys or other cryptographic security parameters will be zeroized when no longer in use to prevent disclosure of security critical data.

1.4 Use Cases

A VPN client allows users on the TOE platform to establish secure IPsec communications, providing confidentiality, integrity, and protection of data, across a less trusted network to secure data in transit. This PP-Module defines three use cases for VPN clients. A conformant TOE will implement one or more of the use cases specified below.

[USE CASE 1] TOE to VPN Gateway

A VPN client allows users on the TOE platform to establish an encrypted IPsec tunnel across a less trusted, often unprotected, public network to a private network (see [Figure 1](#)). In this case, the TOE provides encryption and decryption of network packets as they leave and arrive on the VPN client's underlying platform. IP packets crossing from the private network to the public network will be encrypted if their destination is a remote access VPN client supporting the same VPN policy as the source network.

The TOE is responsible for encrypting the packets that are intended to be received by the target on the private network and then encapsulating these packets in a way that allows the VPN gateway to securely receive them and forward them

to their final destination.

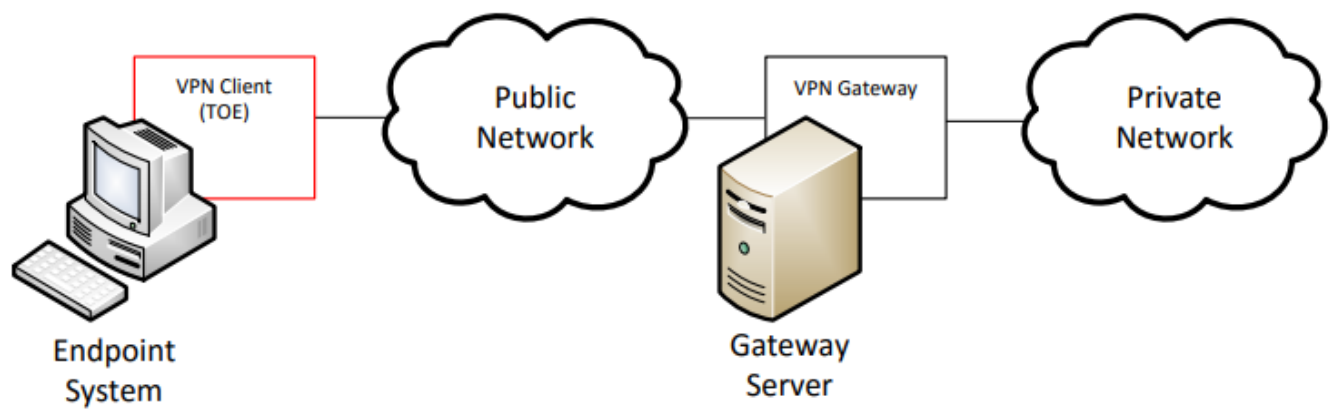


Figure 1: TOE to VPN Gateway

[USE CASE 2] TOE to VPN Client

A VPN client may additionally or alternatively allow a client computer to connect directly to another computer running a VPN client (see Figure 2). In this case, the functionality of the VPN client is to connect directly to another endpoint system to facilitate point-to-point communications with that system.

IPsec transport mode is used for end-to-end communications. In this use case, the content of the packet data (payload) is encrypted but the original IP header is preserved. Inherent to this use case, when two peers are communicating directly, is the disclosure of the source and destination of the packets. Users should take into consideration any security risks associated with this disclosure when architecting their networks in line with this use case.

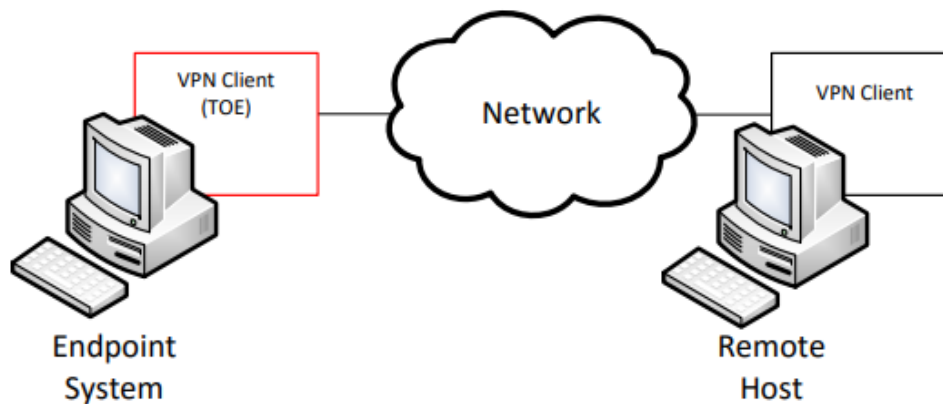


Figure 2: TOE to VPN Client

[USE CASE 3] TOE to IPsec-Capable Network Device

Similar to Use Case 2 above, a VPN client TOE can also be used to establish a secure connection to an IPsec-capable network device using IPsec, similar to how an SSH connection might be used. In this case, where a network device is being managed remotely over an IPsec connection, the network device itself must contain IPsec functionality to act as the peer for the connection (see Figure 3).

While this will behave functionally the same way as the scenario described by Use Case 2, the user of the TOE in Use Case 3 is a network administrator who is assumed to have administrative access to the network device they are

connecting to.

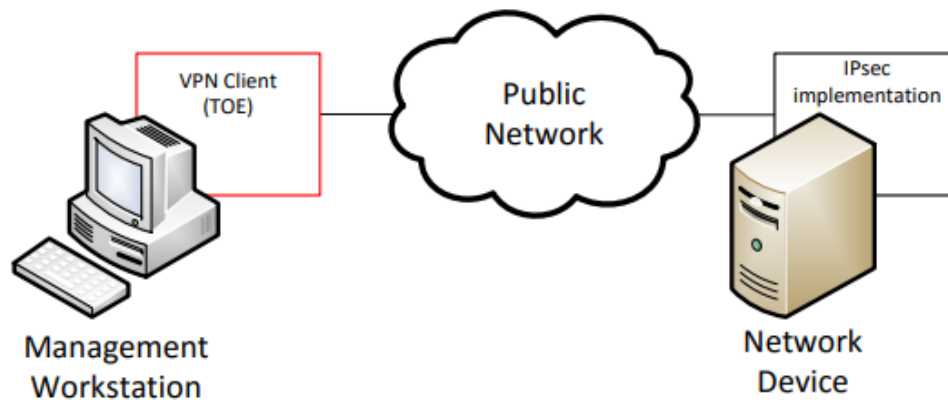


Figure 3: TOE to IPsec-Capable Network Device

1.5 Package Usage

This section contains selections and assignments that are required when the listed Functional Packages are claimed by this PP-Module.

Package Usage guidance defined in the TOE's relevant Base-PP applies to the usage of the packages for this module, unless explicitly stated otherwise in this section.

Functional Package for X.509, Version 1.0

Certificate Verification and Assertion Required in FIA_XCU_EXT.1.1

Because this PP-Module mandates support for mutual authentication for TLS, the ST author shall select the options to verify and assert certificate identities in FIA_XCU_EXT.1.1.

Required Selections for FIA_X509_EXT.2.1

The ST author shall ensure that the assignment and selections in FIA_X509_EXT.2.1 reflect the usage of X.509 certificates for IPsec exchanges. If the TOE supports EAP-TLS and claims [FCS_EAP_EXT.1](#), the ST author shall ensure that the assignment and selections within FIA_X509_EXT.2.1 reflect the usage of X.509 for EAP-TLS. Other selections and assignments may be made as appropriate for other TOE functionality.

Functional Package for Transport Layer Security (TLS), Version 2.1

TLS or DTLS Client Functionality Required in FCS_TLS_EXT.1.1 for EAP-TLS

This usage requirement applies only if the TOE supports EAP-TLS. The ST author shall select the option to support client functionality for TLS or DTLS in FCS_TLS_EXT.1.1. The selection shall correspond with other protocol selections made in [FCS_EAP_EXT.1](#).

Mutual Authentication Required in FCS_TLSC_EXT.1.1 or FCS_DTLSC_EXT.1.1 for EAP-TLS

This usage requirement applies only if the TOE supports EAP-TLS. The ST author shall select the option to support mutual authentication for TLS or DTLS, according with the protocol support selected in FCS_TLS_EXT.1.1.

1.6 Requirements Focus

Regardless of the specific usage of the TOE, the focus of the Security Functional Requirements (SFRs) in this PP-Module is on the following fundamental aspects of a VPN client.

- Authentication of the IPsec peer
- Cryptographic protection of data in transit
- Implementation of services

A VPN client can establish VPN connectivity to either a VPN gateway with traffic bound for a remote endpoint in the private network that is protected by the VPN gateway (Use Case 1), to a VPN client peer residing on a remote endpoint in the same

network as the T.OE (Use Case 2), or to a network device with IPsec capability for the purposes of managing that device (Use Case 3). In the first case, the entire IP packet is encapsulated and a new header is applied so that the gateway can route the packet to its intended destination. This is known as tunnel mode. In the latter two cases, the original IP header is preserved and only the payload is encrypted. This is known as transport mode.

Beyond the implementation differences specified by these use cases, the remaining security functionality is expected to be implemented by all VPN clients, regardless of whether it supports one or more of the use cases. Regardless of the intended use case, VPN endpoints authenticate each other to ensure they are communicating with an authorized external IT entity. Authentication of IPsec peers is performed as part of the Internet Key Exchange (IKE) negotiation. The IKE negotiation uses a pre-existing public key infrastructure for authentication and can optionally use a pre-shared key. When IKE completes, an IPsec tunnel secured with Encapsulating Security Payload (ESP) is established.

It is assumed that the VPN client is implemented properly and contains no critical design mistakes. The VPN client relies on the system or device on which it is installed for its proper execution. The vendor is required to provide configuration guidance (AGD_PRE, AGD_OPE) to correctly install and administer the client machine and the T.OE for every OE supported.

2 Conformance Claims

Conformance Statement

An ~~ST~~ must claim exact conformance to this ~~PP-Module~~.

The evaluation methods used for evaluating the ~~TOE~~ are a combination of the workunits defined in [\[CEM\]](#) as well as the Evaluation Activities for ensuring that individual ~~SFRs~~ and ~~SARs~~ have a sufficient level of supporting evidence in the Security Target and guidance documentation and have been sufficiently tested by the laboratory as part of completing ATE_IND.1. Any functional packages this ~~PP~~ claims similarly contain their own Evaluation Activities that are used in this same manner.

CC Conformance Claims

This ~~PP-Module~~ is conformant to Part 2 (extended) and Part 3 (extended) of Common Criteria ~~CC~~:2022, Revision 1.

PP Claim

This ~~PP-Module~~ does not claim conformance to any Protection Profile.

The following ~~PPs~~ and ~~PP-Modules~~ are allowed to be specified in a ~~PP-Configuration~~ with this ~~PP-Module~~:

- Protection Profile for General Purpose Operating Systems, Version 5.0
- Protection Profile for Mobile Device Fundamentals, Version 4.0
- Protection Profile for Mobile Device Management, Version 5.0
- Protection Profile for Application Software, Version 2.0
- ~~cPP-Module~~ for Wireless LAN Clients, version 1.1
- ~~PP-Module~~ for Bluetooth, version 1.1
- ~~PP-Module~~ for Mobile Device Management Agent, version 2.0
- ~~cPP-Module~~ for Biometric Enrolment and Verification, version 1.1

Package Claim

- This ~~PP-Module~~ is Functional Package for Transport Layer Security Version 2.1 conformant.
- This ~~PP-Module~~ is Functional Package for X.509 Version 1.0 conformant.
- This ~~PP-Module~~ is Assurance Package for Flaw Remediation Version 1.0 conformant.

The functional packages to which the ~~PP~~ conforms may include ~~SFRs~~ that are not mandatory to claim for the sake of conformance. An ~~ST~~ that claims one or more of these functional packages may include any non-mandatory ~~SFRs~~ that are appropriate to claim based on the capabilities of the ~~TSE~~ and on any triggers for their inclusion based inherently on the ~~SFR~~ selections made.

3 Security Problem Definition

The security problem is described in terms of the threats that the TOE is expected to address, assumptions about its OE, and any organizational security policies that the TOE is expected to enforce.

This PP-Module is written to address the situation in which a user accesses a private network (e.g., the user's office network) or terminal endpoint (e.g., a network device) using a less trusted network (such as a public Wi-Fi network or local area network). Protection of network packets is desired as they traverse a public network. To protect the data in transit from disclosure and modification, a VPN is created to establish secure communications. The VPN client provides one end of the secure VPN tunnel and performs encryption and decryption of network packets in accordance with a VPN security policy negotiated between the VPN client (TOE) and its IPsec peer.

The proper installation and configuration of the VPN client is critical to its correct operation such that proper handling of the TOE by an administrator is also addressed.

Note that as a PP-Module, all threats, assumptions, and organizational security policies (OSPs) defined in the Base-PP will also apply to a TOE unless otherwise specified, depending on which of the Base-PPs it extends. The SFRs defined in this PP-Module will mitigate the threats that are defined in the PP-Module but may also mitigate some threats defined in the Base-PPs in more comprehensive detail due to the specific capabilities provided by a VPN client.

3.1 Threats

The following threats defined in this PP-Module extend the threats defined by the Base-PPs.

T.TSF_CONFIGURATION

Configuring VPN tunnels is a complex and time-consuming process, and prone to errors if the interface for doing so is not well-specified or well-behaved. The inability or failure of an ignorant or careless administrator to configure certain aspects of the interface may also lead to the incorrect specification of the desired communications policy or use of cryptography that may be desired or required for a particular site. This may result in unintended weak or plaintext communications while the user thinks that their data are being protected. Other aspects of configuring the TOE or using its security mechanisms (for example, the update process) may also result in a reduction in the trustworthiness of the VPN client.

T.TSF_FAILURE

Security mechanisms of the TOE generally build up from a primitive set of mechanisms (e.g., memory management, privileged modes of process execution) to more complex sets of mechanisms. Failure of the primitive mechanisms could lead to a compromise in more complex mechanisms, resulting in a compromise of the TSF.

T.UNAUTHORIZED_ACCESS

This PP-Module does not include requirements that can protect against an insider threat. Authorized users are not considered hostile or malicious and are trusted to follow appropriate guidance. Only authorized personnel should have access to the system or device that contains the IPsec VPN client. Therefore, the primary threat agents are the unauthorized entities that try to gain access to the protected network (in cases where tunnel mode is used) or to plaintext data that traverses the public network (regardless of whether transport mode or tunnel mode is used).

The endpoint of the network communication can be both geographically and logically distant from the TOE and can pass through a variety of other systems. These intermediate systems may be under the control of the adversary, and offer an opportunity for communications over the network to be compromised.

Plaintext communication over the network may allow critical data (such as passwords, configuration settings, and user data) to be read or manipulated directly by a malicious user or process on intermediate systems, leading to a compromise of the TOE or to the secured environmental systems that the TOE is being used to facilitate communications with. IPsec can be used to provide protection for this communication; however, there are numerous options that can be implemented for the protocol to be compliant to the protocol specification listed in the REC. Some of these options can have negative

impacts on the security of the connection. For instance, using a weak encryption algorithm (even one that is allowed by the ~~RFC~~, such as DES) can allow an adversary to read and even manipulate the data on the encrypted channel, thus circumventing countermeasures in place to prevent such attacks. Further, if the protocol is implemented with little-used or non-standard options, it may be compliant with the protocol specification, but will not be able to interact with other diverse equipment that is typically found in large enterprises.

Even though the communication path is protected, there is a possibility that the IPsec peer could be tricked into thinking that a malicious third-party user or system is the ~~TOE~~. For instance, a middleman could intercept a connection request to the ~~TOE~~ and respond to the request as if it were the ~~TOE~~. In a similar manner, the ~~TOE~~ could also be tricked into thinking that it is establishing communications with a legitimate IPsec peer when in fact it is not. An attacker could also mount a malicious man-in-the-middle-type of attack, in which an intermediate system is compromised, and the traffic is proxied, examined, and modified by this system. This attack can even be mounted via encrypted communication channels if appropriate countermeasures are not applied. These attacks are, in part, enabled by a malicious attacker capturing network traffic (for instance, an authentication session) and “playing back” that traffic in order to fool an endpoint into thinking it was communicating with a legitimate remote entity.

T.USER_DATA_REUSE

Data traversing the ~~TOE~~ could inadvertently be sent to a different user as a consequence of a poorly-designed ~~TOE~~; since these data may be sensitive, this may cause a compromise that is unacceptable. The specific threat that must be addressed concerns user data that is retained by the ~~TOE~~ in the course of processing network traffic that could be inadvertently reused in sending network traffic to a user other than that intended by the sender of the original network traffic.

3.2 Assumptions

These assumptions are made on the Operational Environment (~~OE~~) in order to be able to ensure that the security functionality specified in the ~~PP-Module~~ can be provided by the ~~TOE~~. If the ~~TOE~~ is placed in an ~~OE~~ that does not meet these assumptions, the ~~TOE~~ may no longer be able to provide all of its security functionality.

A.NO_TOE_BYPASS

Information cannot flow onto the network to which the ~~VPN~~ client's host is connected without passing through the ~~TOE~~.

A.PHYSICAL

Physical security, commensurate with the value of the ~~TOE~~ and the data it contains, is assumed to be provided by the environment.

A.TRUSTED_CONFIG

Personnel configuring the ~~TOE~~ and its ~~OE~~ will follow the applicable security configuration guidance.

3.3 Organizational Security Policies

This ~~PP~~ defines no Organizational Security Policies beyond those defined in the claimed ~~Base-PP(s)~~.

4 Security Objectives

4.1 Security Objectives for the Operational Environment

The OE of the TOE implements technical and procedural measures to assist the TOE in correctly providing its security functionality (which is defined by the security objectives for the TOE). The security objectives for the OE consist of a set of statements describing the goals that the OE should achieve. This section defines the security objectives that are to be addressed by the IT domain or by non-technical or procedural means. The assumptions identified in Section 3 are incorporated as security objectives for the environment.

OE.NO_TOE_BYPASS

Information cannot flow onto the network to which the VPN client’s host is connected without passing through the TOE.

OE.PHYSICAL

Physical security, commensurate with the value of the TOE and the data it contains, is assumed to be provided by the environment.

OE.TRUSTED_CONFIG

Personnel configuring the TOE and its OE will follow the applicable security configuration guidance.

4.2 Security Objectives Rationale

This section describes how the assumptions and organizational security policies map to operational environment security objectives.

Table 1: Security Objectives Rationale

Assumption or OSP	Security Objectives	Rationale
A.NO_TOE_BYPASS	OE.NO_TOE_BYPASS	This assumption is satisfied by the environmental objective that ensures network routes do not exist that allow traffic to be transmitted from the TOE system to its intended destination without going through the TOE’s IPsec tunnel.
A.PHYSICAL	OE.PHYSICAL	This assumption is satisfied by the environmental objective that ensures the TOE is not deployed on a system that is vulnerable to loss of physical custody.
A.TRUSTED_CONFIG	OE.TRUSTED_CONFIG	This assumption is satisfied by the environmental objective that ensures that anyone responsible for administering the TOE can be trusted not to misconfigure it, whether intentionally or not.

5 Security Requirements

This chapter describes the security requirements which have to be fulfilled by the product under evaluation. Those requirements comprise functional components from Part 2 and assurance components from Part 3 of [CC]. The following conventions are used for the completion of operations:

- **Refinement** operation (denoted by **bold text** or ~~striketrough text~~): Is used to add details to a requirement or to remove part of the requirement that is made irrelevant through the completion of another operation, and thus further restricts a requirement.
- **Selection** (denoted by *italicized text*): Is used to select one or more options provided by the [CC] in stating a requirement.
- **Assignment** operation (denoted by *italicized text*): Is used to assign a specific value to an unspecified parameter, such as the length of a password. Showing the value in square brackets indicates assignment.
- **Iteration** operation: Is indicated by appending the SFR name with a slash and unique identifier suggesting the purpose of the operation, e.g. "/EXAMPLE1."

5.1 Protection Profile for Protection Profile for General Purpose Operating System Security Functional Requirements Direction

In a PP::Configuration that includes the GPOS PP, the VPN client is expected to rely on some of the security functions implemented by the OS as a whole and evaluated against the Base-PP. In this case, the following sections describe any modifications that the ST author must make to the SFRs defined in the Base-PP in addition to what is mandated by section 5.5.

5.1.1 Modified SFRs

The SFRs listed in this section are defined in the GPOS PP and relevant to the secure operation of the TOE.

5.1.1.1 Cryptographic Support (FCS)

FCS_CKM.1: Cryptographic Key Generation

This SFR is functionally identical to what is defined in the GPOS PP except that ECC key generation with support for P-384 has been made mandatory in support of IPsec due to the mandated support for Diffie-Hellman (DH) group 20 in FCS_IPSEC_EXT.1.8.

The text of the requirement is replaced with:

The TSF shall generate **asymmetric** cryptographic keys in accordance with a specified cryptographic key generation algorithm

- *ECC schemes using ["NIST curves" P-384 and [selection: P-521, no other curves]] that meet the following: FIPS PUB 186-5, "Digital Signature Standard (DSS)," Appendix A.2 and*

[selection:

- CNSA 2.0 Compliant Algorithms: [selection:
 - Leighton-Micali Signature Algorithm using the parameter sets [selection: LMS_SHAKE_M24_H5, LMS_SHAKE_M24_H10, LMS_SHAKE_M24_H15, LMS_SHAKE_M24_H25, LMS_SHAKE_M32_H5, LMS_SHAKE_M32_H10, LMS_SHAKE_M32_H15, LMS_SHAKE_M32_H25, LMS_SHA256_M24_H5, LMS_SHA256_M24_H10, LMS_SHA256_M24_H15, LMS_SHA256_M24_H25, LMS_SHA256_M32_H5, LMS_SHA256_M32_H10, LMS_SHA256_M32_H15, LMS_SHA256_M32_H25] that meet the following [NIST SP 800-208, "Recommendation for Stateful Hash-Based Signature Schemes"]
 - eXtended Merkle Signature Scheme Algorithm using the parameter sets [selection: XMSS-SHA2_10_192, XMSS-SHA2_16_192, XMSS-SHA2_20_192, XMSS-SHA2_10_256, XMSS-

- SHA2_16_256, XMSS-SHA2_20_256, XMSS-SHAKE_10_192, XMSS-SHAKE_16_192, XMSS-SHAKE_20_192, XMSS-SHAKE_10_256, XMSS-SHAKE_16_256, XMSS-SHAKE_20_256] that meets the following: [NIST SP 800-208, "Recommendation for Stateful Hash-Based Signature Schemes"]
 - Module-Lattice-Based Key-Encapsulation Mechanism Standard using the parameter set ML-KEM-1024 that meets the following: [FIPS 203, Module-Lattice-Based Key-Encapsulation Mechanism Standard]
 - Module-Lattice-Based Digital Signature Standard using the parameter set ML-DSA-87 that meets the following [FIPS 204, Module-Lattice-Based Digital Signature Standard]
 - CNSA 1.0 Compliant Algorithms: **[selection:**
 - RSA schemes using cryptographic key sizes of **[assignment: 3072-bit or greater]** that meet the following: FIPS PUB 186-5, "Digital Signature Standard (DSS)", Appendix A.1
 - ECC schemes using "safe-prime" groups **[selection: MODP-3072, MODP-4096, MODP-6144, MODP-8192, ffdhe-3072, ffdhe-4096, ffdhe-6144, ffdhe-8192]** that meet the following: 'NIST Special Publication 800-56A Revision 3, "Recommendation for Pair-Wise Key Establishment Schemes Using Discrete Logarithm Cryptography"', and **[selection: RFC 3526, RFC 7919]**
 - **No other key generation methods**
-].

FCS_CKM.2: Cryptographic Key Establishment

This ~~SFR~~ is functionally identical to what is defined in the GPOS ~~PP~~ except that ~~ECC~~ key generation with support for P-384 has been made mandatory in support of IPsec due to the mandated support for ~~DH~~ group 20 in [FCS_IPSEC_EXT.1.8](#).

The text of the requirement is replaced with:

The ~~TSF~~ shall **implement functionality to perform cryptographic key establishment** in accordance with a specified cryptographic key **establishment** method:

- **Elliptic curve-based key establishment schemes that meet the following: NIST Special Publication 800-56A Revision 3, "Recommendation for Pair-Wise Key Establishment Schemes Using Discrete Logarithm Cryptography," and**
- [selection:**
- CNSA 2.0 Compliant Algorithm:
 - Module-Lattice-Based Key-Encapsulation Mechanism Standard using the parameter set ML-KEM-1024 that meets the following: [FIPS 203, Module-Lattice-Based Key-Encapsulation Mechanism Standard]
 - CNSA 1.0 Compliant Algorithm:
 - Finite field-based key establishment schemes using "safe-prime" groups that meets NIST Special Publication 800-56A Revision 3, "Recommendation for Pair-Wise Key Establishment Schemes Using Discrete Logarithm Cryptography"
 - **No other key establishment methods**
-].

FCS_COP.1/ENCRYPT: Cryptographic Operation - Encryption/Decryption

This ~~SFR~~ is identical to what is defined in the GPOS ~~PP~~ except that support for GCM mode is mandatory in order to address the requirements for [FCS_IPSEC_EXT.1](#).

The text of the requirement is replaced with:

The ~~TSF~~ shall perform [encryption/decryption services for data] in accordance with a specified cryptographic algorithm

- **AES-CBC (as defined in NIST SP 800-38A),**
- **AES-GCM (as defined in NIST SP 800-38D),**

and [selection:

- **AES-XTS (as defined in NIST SP 800-38E)**
- **AES-CTR (as defined in NIST SP 800-38A)**
- **AES Key Wrap (KW) (as defined in NIST SP 800-38F)**
- **AES Key Wrap with Padding (KWP) (as defined in NIST SP 800-38F)**
- **AES-CCMP-256 (as defined in NIST SP 800-38C and IEEE 802.11ac-2013)**
- **AES-GCMP-256 (as defined in NIST SP 800-38D and IEEE 802.11ac-2013)**
- **AES-CCM (as defined in NIST SP 800-38D)**
- *no other modes*

] and cryptographic key sizes 256-bit and [selection: 128-bit, no other bit size].

5.1.2 Additional SFRs

This section defines additional SFRs that must be added to the TOE boundary in order to implement the functionality in any PP-Configuration where the GPOS PP is claimed as the Base-PP.

5.1.2.1 Auditable Events for GPOS PP Additional SFRs

Table 2: Auditable Events for GPOS PP Additional SFRs

Requirement	Auditable Events	Additional Audit Record Contents
FCS_CKM_EXT.2	No events specified	N/A
FIA_X509_EXT.4	No events specified	N/A
FTP_ITC.1	Initiation of the trusted channel.	Identification of the initiator and target.
	Termination of the trusted channel.	No additional information.
	Failure of the trusted channel functions.	Identification of the initiator and target, reason for failure.

5.1.2.2 Cryptographic Support (FCS)

FCS_CKM_EXT.2 Cryptographic Key Storage

FCS_CKM_EXT.2.1

The [selection: *VPN client*, *QS*] shall store persistent secrets and private keys when not in use in *QS*-provided key storage.

Application Note: This requirement ensures that persistent secrets (credentials, secret keys) and private keys are stored securely when not in use. If some secrets or keys are manipulated by the *VPN* client and others are manipulated by the *QS*, then both of the selections can be specified by the *ST* author.

Evaluation Activities ▼

[FCS_CKM_EXT.2.1](#)

TSS

Regardless of whether this requirement is met by the *VPN* client or the *QS*, the evaluator shall check the *TSS* to ensure that it lists each persistent secret (credential, secret key) and private key needed to meet the requirements in the *ST*. For each of these items, the evaluator shall confirm that the *TSS* lists for what purpose it is used, and how it is stored.

The evaluator shall review the *TSS* to determine that it makes a case that, for each item listed as being manipulated, it is not written unencrypted to persistent memory, and that the item is stored by the *QS*.

Guidance

There are no guidance EAs for this requirement.

Tests

There are no test EAs for this component.

5.1.2.3 Identification and Authentication (FIA)

FIA_X509_EXT.4 X.509 Certificate Use and Management

FIA_X509_EXT.4.1

The ~~TSS~~ shall use X.509v3 certificates as defined by RFC 5280 to support authentication for IPsec exchanges, and [selection: *digital signatures for FPT_TUD_EXT.1, integrity checks for FPT_TST_EXT.1, no additional uses*].

FIA_X509_EXT.4.2

When a connection to determine the validity of a certificate cannot be established, the [selection, choose one of: ~~VPN client, QS~~] shall [selection, choose one of: *allow the administrator to choose whether to accept the certificate in these cases, accept the certificate, not accept the certificate*].

Application Note: Oftentimes a connection must be established to perform a verification of the revocation status of a certificate - either to download a certificate revocation list (CRL) or to use the online certificate status protocol (OCSP) to check revocation status. The selection is used to describe the behavior in the event that such a connection cannot be established (for example, due to a network error). The behavior of the ~~TOE~~ in these cases is described by the second selection. If the ~~TOE~~ has determined the certificate is valid according to all other rules in FIA_X509_EXT.1 in [Functional Package for X.509, version 1.0](#), the behavior indicated in the second selection will determine the validity. The ~~TOE~~ must not accept the certificate if it fails any of the other validation rules in FIA_X509_EXT.1 in [Functional Package for X.509, version 1.0](#). If the administrator-configured option is selected by the ~~ST~~ Author, the ~~ST~~ author must also make the appropriate selection in [FMT_SMF.1/VPN](#).

FIA_X509_EXT.4.3

The [selection, choose one of: ~~VPN client, QS~~] shall not establish an ~~SA~~ if a certificate or certificate path is deemed invalid.

Evaluation Activities ▼

[FIA_X509_EXT.4.1](#)

FIA_X509_EXT.4.1 is evaluated as part of FCS_IPSEC_EXT.1 (and conditionally as part of FPT_TUD_EXT.1 or FPT_TST_EXT.1).

[FIA_X509_EXT.4.2](#)

~~TSS~~

The evaluator shall check the ~~TSS~~ to ensure that it describes whether the ~~VPN client~~ or the ~~QS~~ implements the certificate validation functionality, how the ~~VPN client/QS~~ chooses which certificates to use, and any necessary instructions in the administrative guidance for configuring the ~~QS~~ so that desired certificates can be used.

The evaluator shall examine the ~~TSS~~ to confirm that it describes the behavior of the client/~~QS~~ when a connection cannot be established during the validity check of a certificate used in establishing a trusted channel.

Guidance

If the requirement indicates that the administrator is able to specify the default action, then the evaluator shall ensure that the operational guidance contains instructions on how this configuration action is performed.

Tests

The evaluator shall perform the following test regardless of whether the certificate validation functionality is implemented by the *VPN client* or by the *OS*:

- Test *FIA_X509_EXT.4.2:1*: The evaluator shall demonstrate that using a valid certificate that requires certificate validation checking to be performed in at least some part by communicating with a non-TOE *IT* entity. The evaluator shall then manipulate the environment so that the *TOE* is unable to verify the validity of the certificate, and observe that the action selected in *FIA_X509_EXT.4.2* is performed. If the selected action is administrator-configurable, then the evaluator shall follow the operational guidance to determine that all supported administrator-configurable options behave in their documented manner.

FIA_X509_EXT.4.3

FIA_X509_EXT.4.3 is evaluated as part of *FCS_IPSEC_EXT.1.11*.

5.1.2.4 Trusted Path/Channels (FTP)

FTP_ITC.1 Inter-TSF Trusted Channel

FTP_ITC.1.1

The [selection, choose one of: *VPN client*, *OS*] shall use IPsec to provide a trusted communication channel between itself and [selection:

- *a remote VPN gateway*
- *a remote VPN client*
- *a remote IPsec-capable network device*

] that is logically distinct from other communication channels and provides assured identification of its end points and protection of the channel data from **disclosure and detection of modification of the channel data**.

FTP_ITC.1.2

The [selection, choose one of: *VPN client*, *OS*] shall permit [*the TSF*] to initiate communication via the trusted channel.

FTP_ITC.1.3

The [selection, choose one of: *VPN client*, *OS*] shall initiate communication via the trusted channel for [*all traffic traversing that connection*].

Application Note: The intent of the above requirement is to demonstrate that IPsec can be used to establish remote communications in transport mode, tunnel mode, or both.

The requirement implies that not only are communications protected when they are initially established, but also on resumption after an outage. It may be the case that some part of the *TOE* setup involves manually setting up tunnels to protect other communication, and if after an outage the *TOE* attempts to reestablish the communication automatically with (the necessary) manual intervention, there may be a window created where an attacker might be able to gain critical information or compromise a connection.

Evaluation Activities ▼

FTP_ITC.1

TSS

The evaluator shall examine the *TSS* to determine that it describes the details of the *TOE* connecting to a *VPN gateway*, *VPN client*, or *IPsec-capable network device* in terms of the cryptographic protocols specified in the requirement, along with *TOE*-specific options or procedures that might not be reflected in the specification. The evaluator shall also confirm that all protocols listed in the *TSS* are specified and included in the requirements

in the *ST*.

Guidance

The evaluator shall confirm that the operational guidance contains instructions for establishing the connection to a *VPN* gateway, *VPN* client, or IPsec-capable network device, and that it contains recovery instructions should a connection be unintentionally broken.

Tests

The evaluator shall perform the following tests:

- Test *FTP_ITC.1:1*: The evaluator shall ensure that the *TOE* is able to initiate communications with a *VPN* gateway, *VPN* client, or IPsec-capable network device using the protocols specified in the requirement, setting up the connections as described in the operational guidance and ensuring that communication is successful.
- Test *FTP_ITC.1:2*: The evaluator shall ensure, for each communication channel with an IPsec peer, the channel data is not sent in plaintext.
- Test *FTP_ITC.1:3*: The evaluator shall ensure, for each communication channel with an IPsec peer, modification of the channel data is detected by the *TOE*.
- Test *FTP_ITC.1:4*: The evaluator shall physically interrupt the connection from the *TOE* to the IPsec peer. The evaluator shall ensure that subsequent communications are appropriately protected, at a minimum in the case of any attempts to automatically resume the connection or connect to a new access point.

Further EAs are associated with requirements for [FCS_IPSEC_EXT.1](#).

5.2 Protection Profile for Protection Profile for Mobile Device Fundamentals Security Functional Requirements Direction

In a *PP-Configuration* that includes the MDF *PP*, the *VPN* client is expected to rely on some of the security functions implemented by the *OS* as a whole and evaluated against the *Base-PP*. In this case, the following sections describe any modifications that the *ST* author must make to the *SFRs* defined in the *Base-PP* in addition to what is mandated by section 5.5.

5.2.1 Modified SFRs

The *SFRs* listed in this section are defined in the MDF *PP* and relevant to the secure operation of the *TOE*.

5.2.1.1 Cryptographic Support (FCS)

FCS_CKM.1: Cryptographic Key Generation

This *SFR* is functionally identical to what is defined in the MDF *PP* except that elliptic curve cryptography (ECC) key generation with support for P-384 has been made mandatory in support of IPsec due to the mandated support for DH group 20 in [FCS_IPSEC_EXT.1.8](#). Curve25519 schemes remain selectable for their potential use in satisfying FDP_DAR_EXT.2.2 in the MDF *PP*; these schemes are not used in support of IPsec. RSA support remains present as a selection since it may be used by parts of the *TOE* that are not specifically related to *VPN* client functionality.

The text of the requirement is replaced with:

The *TSF* shall generate **asymmetric** cryptographic keys in accordance with a specified cryptographic key generation algorithm

- *ECC schemes using ["NIST curves" P-384 and [selection: P-521, no other curves]] that meet the following: FIPS PUB 186-5, "Digital Signature Standard (DSS)," Appendix A.2*

and [selection:

- *CNSA 2.0 Compliant Algorithms: [selection:*

- Leighton-Micali Signature Algorithm using the parameter sets [**selection:** LMS_SHAKE_M24_H5, LMS_SHAKE_M24_H10, LMS_SHAKE_M24_H15, LMS_SHAKE_M24_H25, LMS_SHAKE_M32_H5, LMS_SHAKE_M32_H10, LMS_SHAKE_M32_H15, LMS_SHAKE_M32_H25, LMS_SHA256_M24_H5, LMS_SHA256_M24_H10, LMS_SHA256_M24_H15, LMS_SHA256_M24_H25, LMS_SHA256_M32_H5, LMS_SHA256_M32_H10, LMS_SHA256_M32_H15, LMS_SHA256_M32_H25] that meet the following [NIST SP 800-208, "Recommendation for Stateful Hash-Based Signature Schemes"]
 - eXtended Merkle Signature Scheme Algorithm using the parameter sets [**selection:** XMSS-SHA2_10_192, XMSS-SHA2_16_192, XMSS-SHA2_20_192, XMSS-SHA2_10_256, XMSS-SHA2_16_256, XMSS-SHA2_20_256, XMSS-SHAKE_10_192, XMSS-SHAKE_16_192, XMSS-SHAKE_20_192, XMSS-SHAKE_10_256, XMSS-SHAKE_16_256, XMSS-SHAKE_20_256] that meets the following: [NIST SP 800-208, "Recommendation for Stateful Hash-Based Signature Schemes"]
 - Module-Lattice-Based Key-Encapsulation Mechanism Standard using the parameter set ML-KEM-1024 that meets the following: [FIPS 203, Module-Lattice-Based Key-Encapsulation Mechanism Standard]
 - Module-Lattice-Based Digital Signature Standard using the parameter set ML-DSA-87 that meets the following [FIPS 204, Module-Lattice-Based Digital Signature Standard]
 - CNSA 1.0 Compliant Algorithms: [**selection:**
 - RSA schemes using cryptographic key sizes of [**assignment:** 3072 bits or greater] that meet the following: FIPS PUB 186-5, "Digital Signature Standard (DSS)", Appendix A.1
 - ECC schemes using "safe-prime" groups [**selection:** MODP-3072, MODP-4096, MODP-6144, MODP-8192, ffdhe-3072, ffdhe-4096, ffdhe-6144, ffdhe-8192] that meet the following: NIST Special Publication 800-56A Revision 3, "Recommendation for Pair-Wise Key Establishment Schemes Using Discrete Logarithm Cryptography", and [**selection:** REC 3526, REC 7919]
 - Non-CNSA Algorithms:
 - ECC schemes using Curve25519 schemes that meet the following: [REC 7748]
 - **No other key generation methods**
-].

FCS_CKM.2/UNLOCKED: Cryptographic Key Establishment (When Unlocked)

This SFR differs from its definition in the MDF PP by moving elliptic curve-based key establishment schemes from selectable to mandatory, due to the mandated support for DH group 20 in [FCS_IPSEC_EXT.1.8](#). This PP-Module does not require the use of RSA for any function but it is present in the selection in case other MDF PP functions require its use.

The text of the requirement is replaced with:

The TSF shall perform **cryptographic key establishment** in accordance with a specified cryptographic key establishment method:

- **[Elliptic curve-based key establishment schemes] that meet the following: [NIST Special Publication 800-56A Revision 3, "Recommendation for Pair-Wise Key Establishment Schemes Using Discrete Logarithm Cryptography"]**
- [selection:**
- CNSA 2.0 Compliant Algorithm:
 - Module-Lattice-Based Key-Encapsulation Mechanism Standard using the parameter set ML-KEM-1024 that meets the following: [FIPS 203, Module-Lattice-Based Key-Encapsulation Mechanism Standard]
 - CNSA 1.0 Compliant Algorithm:
 - Finite field-based key establishment schemes using "safe-prime" groups that meets NIST Special Publication 800-56A Revision 3, "Recommendation for Pair-Wise Key Establishment Schemes Using Discrete Logarithm Cryptography"
 - **No other key establishment methods**
-].

FCS_COP.1/ENCRYPT: Cryptographic Operation

This ~~SFR~~ is identical to what is defined in the MDF ~~PP~~ except that support for GCM mode and support for 256-bit key sizes are both mandatory in order to address the requirements for [FCS_IPSEC_EXT.1](#).

The text of the requirement is replaced with:

The ~~TSE~~ shall perform [encryption/decryption] in accordance with a specified cryptographic algorithm: [

- ~~AES-CBC~~ (as defined in ~~FIPS PUB 197~~, and ~~NIST SP 800-38A~~) mode
- ~~AES-CCMP-256~~ (as defined in ~~NIST SP 800-38C~~ and ~~IEEE 802.11ac-2013~~),
- ~~AES-GCM~~ (as defined in ~~NIST SP 800-38D~~), and
- [selection:
 - ~~AES~~ Key Wrap (KW) (as defined in ~~NIST SP 800-38F~~)
 - ~~AES~~ Key Wrap with Padding (KWP) (as defined in ~~NIST SP 800-38F~~)
 - ~~AES-CCM~~ (as defined in ~~NIST SP 800-38C~~)
 - ~~AES-XTS~~ (as defined in ~~NIST SP 800-38E~~) mode
 - ~~AES-GCMP-256~~ (as defined in ~~NIST SP800-38D~~ and ~~IEEE 802.11ac-2013~~)
 - no other modes

]

] and cryptographic key sizes [256 bits].

5.2.1.2 User Data Protection (FDP)

FDP_IFC_EXT.1: Subset Information Flow Control

This ~~SFR~~ is identical to its definition in the ~~Base-PP~~ except that the selection item that requires the ~~TOE~~ to implement its own ~~VPN~~ client is always selected when the ~~TOE~~'s conformance claim includes this ~~PP-Module~~.

The text of the requirement is replaced with:

The ~~TSE~~ shall [

- provide a ~~VPN~~ client which can protect all ~~IP~~ traffic using IPsec as defined in the ~~PP-Module~~ for ~~VPN~~ Client

] with the exception of ~~IP~~ traffic needed to manage the ~~VPN~~ connection, and [selection: [assignment: traffic needed for correct functioning of the ~~TOE~~], no other traffic] when the ~~VPN~~ is enabled.

5.2.1.3 Security Management (FMT)

FMT_SMF_EXT.1: Specification of Management Functions

This ~~PP-Module~~ requires that Always On ~~VPN~~ protection be enabled across the entire device and does not permit this to be applied at the level of an application or group of application processes.

This ~~SFR~~ is not reproduced in its entirety for size purposes. The only change to this ~~SFR~~ is the following change to management function 45:

45. enable/disable the Always On VPN protection: • across device • [no other method]	M	O	O	O
---	----------	---	---	---

5.2.1.4 Trusted Path/Channels (FTP)

FTP_ITC_EXT.1: Trusted Channel Communication

This SFR is identical to what is defined in the Base-PP except that support for IPsec is mandated. Additionally, since the Base-PP requires ‘at least one of’ the selected protocols which previously included IPsec, ‘no other protocols’ is now available as an option in the selection.

The text of FDP_ITC_EXT.1.1 is replaced with (the other elements are unaffected):

The TSS shall use

- 802.11-2012 in accordance with the [~~PP-Module for Wireless LAN Clients, version 1.1~~],
- 802.1X in accordance with the [~~PP-Module for Wireless LAN Clients, version 1.1~~],
- EAP-TLS in accordance with the [~~PP-Module for Wireless LAN Clients, version 1.1~~],
- Mutually authenticated TLS in accordance with the [~~Functional Package for TLS, version 2.1~~],
- **IPsec in accordance with the [~~PP-Module for VPN Clients, version 3.0~~],**

and [selection:

- *mutually authenticated DTLS as defined in the Functional Package for TLS, version 2.1*
- *HTTPS*
- ***no other***

] protocols to provide a communication channel between itself and another trusted IT product using certificates as defined in [~~Functional Package for X.509, version 1.0~~] that is logically distinct from other communication channels, provides assured identification of its end points, protects channel data from disclosure, and detects modification of the channel data.

5.2.2 Additional SFRs

This section defines additional SFRs that must be added to the TOE boundary in order to implement the functionality in any PP-Configuration where the MDF PP is claimed as the Base-PP.

5.2.2.1 Auditable Events for MDF PP Additional SFRs

Table 3: Auditable Events for MDF PP Additional SFRs

Requirement	Auditable Events	Additional Audit Record Contents
FDP_VPN_EXT.1	No events specified	N/A

5.2.2.2 User Data Protection (FDP)

FDP_VPN_EXT.1 Split Tunnel Prevention

FDP_VPN_EXT.1.1

The TSS shall ensure that all IP traffic (other than IP traffic required to establish the VPN connection) flow through the IPsec VPN client.

Application Note: This requirement is implementation-dependent on the MDF PP being the Base-PP claimed by the TOE. In this case, this requirement must be claimed.

For all other Base-PPs, this requirement is strictly optional.

This requirement is used when the VPN client is able to enforce the requirement through its own components. This generally will have to be done through using hooks provided by the platform such that the TOE is able to ensure that no IP traffic can flow through other network interfaces.

Evaluation Activities ▼

[FDP_VPN_EXT.1.1](#)
TSS

The evaluator shall verify that the *TSS* section of the *ST* describes the routing of *IP* traffic through processes on the *TSE* when a *VPN* client is enabled. The evaluator shall ensure that the description indicates which traffic does not go through the *VPN* and which traffic does and that a configuration exists for each baseband protocol in which only the traffic identified by the *ST* author is necessary for establishing the *VPN* connection (*IKE* traffic and perhaps *HTTPS* or *DNS* traffic) is not encapsulated by the *VPN* protocol (*IPsec*). The *ST* author shall also identify in the *TSS* section any differences in the routing of *IP* traffic when using any supported baseband protocols (e.g., *Wi-Fi*, *LTE*).

Guidance

The evaluator shall verify that the following is addressed by the documentation:

- The description above indicates that if a *VPN* client is enabled, all configurations route all *IP* traffic (other than *IP* traffic required to establish the *VPN* connection) through the *VPN* client.
- The guidance describes how the user or administrator can configure the *TSE* to meet this requirement.

Tests

The evaluator shall perform the following test:

Step 1 - The evaluator shall use the platform to enable a network connection without using *IPsec*. The evaluator shall use a packet sniffing tool between the platform and an internet-connected network. The evaluator shall turn on the sniffing tool and perform actions with the device such as navigating to websites, using provided applications, accessing other internet resources (*Use Case 1*), accessing another *VPN* client (*Use Case 2*), or accessing an *IPsec*-capable network device (*Use Case 3*). The evaluator shall verify that the sniffing tool captures the traffic generated by these actions, turn off the sniffing tool, and save the session data.

Step 2 - The evaluator shall configure an *IPsec VPN* client that supports the routing specified in this requirement, and if necessary, configure the device to perform the routing specified as described in the *AGD* guidance. The evaluator shall turn on the sniffing tool, establish the *VPN* connection, and perform the same actions with the device as performed in the first step. The evaluator shall verify that the sniffing tool captures traffic generated by these actions, turn off the sniffing tool, and save the session data.

Step 3 - The evaluator shall examine the traffic from both step one and step two to verify that all *IP* traffic, aside from and after traffic necessary for establishing the *VPN* (such as *IKE*, *DNS*, and possibly *HTTPS*), is encapsulated by *IPsec*.

Step 4 - The evaluator shall attempt to send packets to the *TOE* outside the *VPN* connection and shall verify that the *TOE* discards them.

5.3 Protection Profile for Protection Profile for Application Software Security Functional Requirements Direction

In a *PP-Configuration* that includes the *App PP*, the *VPN* client is expected to rely on some of the security functions implemented by the *OS* as a whole and evaluated against the *Base-PP*. In this case, the following sections describe any modifications that the *ST* author must make to the *SFRs* defined in the *Base-PP* in addition to what is mandated by section 5.5.

5.3.1 Modified SFRs

The *SFRs* listed in this section are defined in the *App PP* and relevant to the secure operation of the *TOE*.

5.3.1.1 Cryptographic Support (FCS)

FCS_CKM.1/AK: Cryptographic Asymmetric Key Generation

This *SFR* is selection-based in the *App PP* depending on the selection made in *FCS_CKM_EXT.1*. Because key generation services (whether implemented by the *TOE* or invoked from the platform) are required for *IPsec*, this *SFR*

is mandatory for any ~~TOE~~ that claims conformance to this ~~PP-Module~~.

This ~~SFR~~ is functionally identical to what is defined in the App ~~PP~~ except that ~~ECC~~ key generation with P-384 has been made mandatory in support of IPsec due to the mandated support for ~~DH~~ group 20 in [FCS_IPSEC_EXT.1.8](#). RSA remains present as a selection since it may be used by parts of the ~~TOE~~ that are not specifically related to ~~VPN~~ client functionality. The selection for "no other key generation methods" was added in case the algorithms that IPsec requires are the ~~TSF~~'s only use of key generation.

The text of the requirement is replaced with:

The **application** shall [selection:

- *invoke platform-provided functionality*
- *implement functionality*

] to generate **asymmetric** cryptographic keys in accordance with a specified cryptographic key generation algorithm

- **[ECC schemes]** using [**"NIST curves" P-384 and [selection: P-521, no other curves]**] that meet the following: **[FIPS PUB 186-5, "Digital Signature Standard (DSS)," Appendix A.2]**

and [selection:

- **[RSA schemes]** using cryptographic key sizes of [**assignment: 3072-bit or greater**] that meet the following: **[FIPS PUB 186-5, "Digital Signature Standard (DSS)," Appendix A.1]**
- **[EFC Schemes]** using [**"safe-prime" groups**] [selection:

- MODP-3072
- MODP-4096
- MODP-6144
- MODP-8192
- ffdhe-3072
- ffdhe-4096
- ffdhe-6144
- ffdhe-8192

] that meet the following: **[NIST Special Publication 800-56A Revision 3, "Recommendation for Pair-Wise Key Establishment Schemes Using Discrete Logarithm Cryptography" and [selection: REC 3526, REC 7919]]**

- **Leighton-Micali Signature Algorithm** using the parameter sets

- LMS_SHAKE_M24_H5
- LMS_SHAKE_M24_H10
- LMS_SHAKE_M24_H15
- LMS_SHAKE_M24_H25
- LMS_SHAKE_M32_H5
- LMS_SHAKE_M32_H10
- LMS_SHAKE_M32_H15
- LMS_SHAKE_M32_H25
- LMS_SHA256_M24_H5
- LMS_SHA256_M24_H10
- LMS_SHA256_M24_H15
- LMS_SHA256_M24_H25
- LMS_SHA256_M32_H5
- LMS_SHA256_M32_H10
- LMS_SHA256_M32_H15
- LMS_SHA256_M32_H25

] that meet the following: **[NIST SP 800-208, "Recommendation for Stateful Hash-Based Signature Schemes"]**

- **eXtended Merkle Signature Scheme Algorithm** using the parameter sets

- XMSS-SHA2_10_192
- XMSS-SHA2_16_192
- XMSS-SHA2_20_192
- XMSS-SHA2_10_256
- XMSS-SHA2_16_256
- XMSS-SHA2_20_256
- XMSS-SHAKE_10_192
- XMSS-SHAKE_16_192

- XMSS-SHAKE_20_192
- XMSS-SHAKE_10_256
- XMSS-SHAKE_16_256
- XMSS-SHAKE_20_256

] bits that meets the following: [NIST SP 800-208, "Recommendation for Stateful Hash-Based Signature Schemes"]

- **Module-Lattice-Based Key-Encapsulation Mechanism Standard** using the parameter set ML-KEM-1024 that meets the following: [FIPS 203, Module-Lattice-Based Key-Encapsulation Mechanism Standard]
- **Module-Lattice-Based Digital Signature Standard** using the parameter set ML-DSA-87 that meets the following [FIPS 204, Module-Lattice-Based Digital Signature Standard]
- **no other key generation methods**

].

FCS_CKM.2: Cryptographic Key Establishment

This SFR differs from its definition in the App PP by moving elliptic curve-based key establishment schemes from selectable to mandatory due to the mandated support for DH group 20 in FCS_IPSEC_EXT.1.8. The selection for "no other schemes" was added in case the algorithms that IPsec requires are the TSF's only use of key establishment.

The text of the requirement is replaced with:

The **application** shall [selection:

- **invoke platform-provided functionality**
- **implement functionality**

] to perform cryptographic key establishment in accordance with a specified cryptographic key establishment method:

- **[Elliptic curve-based key establishment schemes] that meet the following: [NIST Special Publication 800-56A Revision 3, "Recommendation for Pair-Wise Key Establishment Schemes Using Discrete Logarithm Cryptography"]**

[selection:

- **[RSA-based key establishment schemes] that meet the following: [NIST Special Publication 800-56B, "Recommendation for Pair-Wise Key Establishment Schemes Using Integer Factorization Cryptography"]**
- **[FFC Schemes using "safe-prime" groups] that meet the following: [NIST Special Publication 800-56A Revision 3, "Recommendation for Pair-Wise Key Establishment Schemes Using Discrete Logarithm Cryptography"] and [selection: RFC 3526, RFC 7919]**
- **Module-Lattice-Based Key-Encapsulation Mechanism Standard using the parameter set ML-KEM-1024 that meets the following: [FIPS 203, Module-Lattice-Based Key-Encapsulation Mechanism Standard]**
- **no other key establishment schemes**

].

FCS_CKM_EXT.1: Cryptographic Key Generation Services

This selection differs from its definition in the App PP by removing the selection for "generate no asymmetric cryptographic keys" for this PP:Module because a VPN client TOE will either perform its own key generation or interface with the underlying platform to provide this service, either of which causes FCS_CKM.1/AK to be claimed.

The text of the requirement is replaced with:

The application shall [selection:

- **invoke platform-provided functionality for asymmetric key generation**
- **implement asymmetric key generation**

].

FCS_COP.1/SKC: Cryptographic Operation - Encryption/Decryption

This ~~SFR~~ is selection-based in the ~~Base-PP~~ and remains selection-based here because this ~~PP-Module~~ allows for the possibility that the ~~TSE~~ relies on platform-provided cryptographic algorithm services for its own implementation of IPsec. However, if the ~~TSE~~ does claim this ~~SFR~~ to support IPsec, the ~~ST~~ author must select at minimum AES-GCM for consistency with the relevant IPsec claims ([FCS_IPSEC_EXT.1.4](#) and [FCS_IPSEC_EXT.1.6](#) require AES-GCM). The "no other modes" selection is added for the case where no AES claims need to be made beyond what is mandated for IPsec.

The text of the requirement is replaced with:

The **application** shall [**selection: *perform, invoke the platform to perform***] *[encryption and decryption]* in accordance with a specified cryptographic algorithm

- **AES-CBC (as defined in NIST SP 800-38A) mode**
- **AES-GCM (as defined in NIST SP 800-38D) mode**

and [**selection:**

- *AES-XTS (as defined in NIST SP 800-38E) mode*
- *AES-CCM (as defined in NIST SP 800-38C) mode*
- *AES-CTR (as defined in NIST SP 800-38A) mode*
- **no other modes**

] and cryptographic key size of [256-bits].

5.3.1.2 Trusted Path/Channels

FTP_DIT_EXT.1: Protection of Data in Transit

This ~~SFR~~ is identical to what is defined in the App ~~PP~~ except that the selection for IPsec is mandated, the ~~ST~~ author is forced to select the "encrypt all transmitted sensitive data" option, and the options for invoking platform-provided IPsec functionality have been removed. Since it is possible for a conformant ~~TOE~~ to implement IPsec while relying on the platform for some other protocol (e.g., using platform-provided TLS to obtain IPsec configuration from a gateway), the other platform-provided protocol selections remain. Additionally, since it is possible that a conformant ~~TOE~~ may not implement any encryption protocols other than IPsec, "no other protocols" is provided as a selectable option in the list of supported protocols.

The text of the requirement is replaced with:

The application shall [**selection:**

- *encrypt all transmitted [sensitive data] with **IPsec as defined in the PP-Module for VPN Client and*** [**selection:**
 - *HTTPS as a client in accordance with FCS_HTTPS_EXT.1 and FCS_HTTPS_EXT.2*
 - *HTTPS as a server in accordance with FCS_HTTPS_EXT.1*
 - *HTTPS as a server using mutual authentication in accordance with FCS_HTTPS_EXT.1 and FCS_HTTPS_EXT.2*
 - *TLS as a server as defined in the Functional Package for TLS and also supports functionality for [**selection:** mutual authentication, none]*
 - *TLS as a client as defined in the Functional Package for TLS*
 - *DTLS as a server as defined in the Functional Package for TLS and also supports functionality for [**selection:** mutual authentication, none]*
 - *DTLS as a client as defined in the Functional Package for TLS*
 - *SSH as defined in the Functional Package for Secure Shell*
 - **no other functions**
- *] for [**assignment:** function(s)] using certificates as defined in the Functional Package for X.509*
- *invoke platform-provided functionality to encrypt all transmitted sensitive data with [**selection:** HTTPS, TLS, DTLS, SSH] for [**assignment:** function(s)] using certificates as defined in the Functional Package for X.509*

] between itself and another trusted ~~IT~~ product.

5.3.2 Additional SFRs

This section defines additional SFRs that must be added to the TOE boundary in order to implement the functionality in any PP-Configuration where the App PP is claimed as the Base-PP.

5.3.2.1 Auditable Events for App PP Additional SFRs

Table 4: Auditable Events for App PP Additional SFRs

Requirement	Auditable Events	Additional Audit Record Contents
FCS_CKM.6	Destruction of cryptographic key.	Identification of key.
FCS_CKM_EXT.2	No events specified	N/A

5.3.2.2 Cryptographic Support (FCS)

FCS_CKM.6 Cryptographic Key Destruction

- FCS_CKM.6.1

The [selection: TOE, TOE platform] shall destroy [assignment: list of cryptographic keys (including keying material)] when [selection: no longer needed, [assignment: other circumstances for key or keying material destruction]].
- FCS_CKM.6.2

The TSF shall destroy cryptographic keys and keying material specified by FCS_CKM.6.1 in accordance with a specified cryptographic key destruction method [assignment: cryptographic key destruction method] that meets the following: [assignment: list of standards].

Application Note: Any security related information (such as keys, authentication data, and passwords) must be zeroized when no longer in use to prevent the disclosure or modification of security critical data.

The zeroization indicated above applies to each intermediate storage area for plaintext key or CSP data (i.e., any storage, such as memory buffers, that is included in the path of such data) upon the transfer of the key or CSP to another location.

In practice, the TOE will not implement all of the functionality associated with the requirement, since if it performs zeroization at all it will be by invoking platform interfaces to perform the storage location clear or overwrite function. The ST author should select "TOE" when, for at least one of the keys needed to meet the requirements of this PP-Module, the TOE manipulates (reads, writes) the data identified in the requirement and thus needs to ensure that those data are cleared. In these cases, it is sufficient for the TOE to invoke the correct underlying functions of the host to perform the zeroization—it does not imply that the TOE has to include a kernel-mode memory driver to ensure the data are zeroized. The ST author should select "TOE platform" when native OS functionality is used to perform the key destruction.

In the likely event that some of the data are manipulated by the TOE and other data are manipulated entirely by the platform, the ST author must select both options.

Evaluation Activities ▼

FCS_CKM.6

TSS

The evaluator shall ensure that all plaintext secret and private cryptographic keys and CSPs (whether manipulated by the TOE or exclusively by the platform) are identified in the VPN client ST's TSS, and that they are accounted for by the EAs in this section.

Requirement met by the platform:

The evaluator shall check to ensure the TSS describes each of the secret keys (keys used for symmetric encryption), private keys, and CSPs used to generate keys that are not otherwise covered by the FCS_CKM.6 requirement levied on the TOE.

For each platform listed in the ST, the evaluator shall examine the TSS of the ST of the platform to ensure that each of the secret keys, private keys, and CSPs used to generate the keys listed above are covered.

Requirement met by the TOE:

The evaluator shall check to ensure the TSS describes when each of the plaintext keys are cleared (e.g., system power off, disconnection of an IPsec connection, when no longer needed by the VPN channel per the protocol); and the type of clearing procedure that is performed (cryptographic erase, overwrite with zeros, overwrite three or more times by a different alternating pattern, overwrite with random pattern, or block erase). If different types of memory are used to store the materials to be protected, the evaluator shall check to ensure that the TSS describes the clearing procedure in terms of the memory in which the data are stored (for example, "secret keys stored on flash are cleared by overwriting once with zeros, while secret keys stored on the internal persistent storage device are cleared by overwriting three times with a random pattern that is changed before each write").

Guidance

There are no guidance EAs for this requirement.

Tests

For each key clearing situation described in the TSS, the evaluator shall repeat the following test.

- Test FCS_CKM.6:1: The evaluator shall use appropriate combinations of specialized QE and development tools (debuggers, simulators, etc.) for the TOE and instrumented TOE builds to test that keys are cleared correctly, including all intermediate copies of the key that may have been created internally by the TOE during normal cryptographic processing with that key.

Cryptographic TOE implementations in software shall be loaded and exercised under a debugger to perform such tests. The evaluator shall perform the following test for each key subject to clearing, including intermediate copies of keys that are persisted encrypted by the TOE:

1. Load the instrumented TOE build in a debugger.
2. Record the value of the key in the TOE subject to clearing.
3. Cause the TOE to perform a normal cryptographic processing with the key from #1.
4. Cause the TOE to clear the key.
5. Cause the TOE to stop the execution but not exit.
6. Cause the TOE to dump the entire memory footprint of the TOE into a binary file.
7. Search the content of the binary file created in #6 for instances of the known key value from #1.

The test succeeds if no copies of the key from #1 are found in step #7 above and fails otherwise.

The evaluator shall perform this test on all keys, including those persisted in encrypted form, to ensure intermediate copies are cleared.

FCS_CKM_EXT.2 Cryptographic Key Storage

FCS_CKM_EXT.2.1

The [selection: VPN client, QS] shall store persistent secrets and private keys when not in use in platform-provided key storage.

Application Note: This requirement ensures that persistent secrets and private keys are stored securely when not in use. This differs from FCS_STO_EXT.1 in the Base-PP, which

only applies to secure storage of administrative credentials. If some secrets or keys are manipulated by the TOE and others are manipulated by the platform, then both of the selections can be specified by the ST author.

Evaluation Activities ▼

[FCS_CKM_EXT.2.1](#)

TSS

Regardless of whether this requirement is met by the TOE or the TOE platform, the evaluator shall check the TSS to ensure that it lists each persistent secret (credential, secret key) and private key needed to meet the requirements in the ST. For each of these items, the evaluator shall confirm that the TSS lists for what purpose it is used, and how it is stored. The evaluator shall then perform the following actions:

Persistent secrets and private keys manipulated by the platform:

For each platform listed in the ST, the evaluator shall examine the ST of the platform to ensure that the persistent secrets and private keys listed as being stored by the platform in the VPN client ST are identified as being protected in that platform's ST.

Persistent secrets and private keys manipulated by the TOE:

The evaluator shall review the TSS to determine that it makes a case that, for each item listed as being manipulated by the TOE, it is not written unencrypted to persistent memory, and that the item is stored by the platform.

Guidance

There are no guidance EAs for this requirement.

Tests

There are no test EAs for this requirement.

5.4 Protection Profile for Protection Profile for Mobile Device Management Security Functional Requirements Direction

In a PP-Configuration that includes the MDM PP, the VPN client is expected to rely on some of the security functions implemented by the OS as a whole and evaluated against the Base-PP. In this case, the following sections describe any modifications that the ST author must make to the SFRs defined in the Base-PP in addition to what is mandated by section 5.5.

5.4.1 Modified SFRs

The SFRs listed in this section are defined in the MDM PP and relevant to the secure operation of the TOE.

5.4.1.1 Cryptographic Support (FCS)

FCS_CKM.1: Cryptographic Key Generation

This SFR is modified from its definition in the MDM PP by mandating the key generation algorithms that are required by this PP-Module in support of IPsec due to the mandated support for DH group 20 in [FCS_IPSEC_EXT.1.8](#). Other selections may be chosen by the ST author as needed for parts of the TOE that are not specifically related to VPN client functionality. The selection for "no other key generation methods" was added in case the algorithms that IPsec requires are the TSE's only use of key generation.

The text of the requirement is replaced with:

The TSF shall [selection:

- invoke platform-provided functionality
- implement functionality

] to generate **asymmetric** cryptographic keys in accordance with a specified cryptographic key generation algorithm

- [ECC schemes] using [“NIST curves” P-384 and [selection: P-521, no other curves]] that meet the following: [FIPS PUB 186-5, “Digital Signature Standard (DSS),” Appendix A.2]

and [selection:

- [RSA schemes] using cryptographic key sizes of [assignment: 3072-bit or greater] that meet the following: [FIPS PUB 186-5, “Digital Signature Standard (DSS),” Appendix A.1]
- [ECC Schemes] using [“safe-prime” groups] [selection:
 - MODP-3072
 - MODP-4096
 - MODP-6144
 - MODP-8192
 - ffdhe-3072
 - ffdhe-4096
 - ffdhe-6144
 - ffdhe-8192

] that meet the following: [NIST Special Publication 800-56A Revision 3, “Recommendation for Pair-Wise Key Establishment Schemes Using Discrete Logarithm Cryptography” and [selection: RFC 3526, RFC 7919]]

- **Leighton-Micali Signature Algorithm** using the parameter sets

- LMS_SHAKE_M24_H5
- LMS_SHAKE_M24_H10
- LMS_SHAKE_M24_H15
- LMS_SHAKE_M24_H25
- LMS_SHAKE_M32_H5
- LMS_SHAKE_M32_H10
- LMS_SHAKE_M32_H15
- LMS_SHAKE_M32_H25
- LMS_SHA256_M24_H5
- LMS_SHA256_M24_H10
- LMS_SHA256_M24_H15
- LMS_SHA256_M24_H25
- LMS_SHA256_M32_H5
- LMS_SHA256_M32_H10
- LMS_SHA256_M32_H15
- LMS_SHA256_M32_H25

] that meet the following: [NIST SP 800-208, “Recommendation for Stateful Hash-Based Signature Schemes”]

- **eXtended Merkle Signature Scheme Algorithm** using the parameter sets

- XMSS-SHA2_10_192
- XMSS-SHA2_16_192
- XMSS-SHA2_20_192
- XMSS-SHA2_10_256
- XMSS-SHA2_16_256
- XMSS-SHA2_20_256
- XMSS-SHAKE_10_192
- XMSS-SHAKE_16_192
- XMSS-SHAKE_20_192
- XMSS-SHAKE_10_256
- XMSS-SHAKE_16_256
- XMSS-SHAKE_20_256

] bits that meets the following: [NIST SP 800-208, “Recommendation for Stateful Hash-Based Signature Schemes”]

- **Module-Lattice-Based Key-Encapsulation Mechanism Standard** using the parameter set ML-KEM-1024 that meets the following: [FIPS 203, Module-Lattice-Based Key-Encapsulation Mechanism Standard]

- **Module-Lattice-Based Digital Signature Standard** using the parameter set ML-DSA-87 that meets the following [FIPS 204, Module-Lattice-Based Digital Signature Standard]
- **no other key generation methods**

].

FCS_CKM.2: Cryptographic Key Establishment

This SFR is modified from its definition in the MDM PP by mandating the key establishment algorithms that are required by this PP-Module in support of IPsec due to the mandated support for DH group 20 in FCS_IPSEC_EXT.1.8. Other selections may be chosen by the ST author as needed for parts of the TOE that are not specifically related to VPN client functionality. The selection for "no other schemes" was added in case the algorithms that IPsec requires are the TSF's only use of key establishment.

The text of the requirement is replaced with:

The TSF shall [selection:

- **invoke platform-provided functionality**
- **implement functionality**

] in accordance with a specified cryptographic key **establishment** method:

- **Elliptic curve-based key establishment schemes that meet the following: NIST Special Publication 800-56A Revision 3, "Recommendation for Pair-Wise Key Establishment Schemes Using Discrete Logarithm Cryptography," and**

[selection:

- **CNSA 2.0 Compliant Algorithm:**
 - **Module-Lattice-Based Key-Encapsulation Mechanism Standard using the parameter set ML-KEM-1024 that meets the following: [FIPS 203, Module-Lattice-Based Key-Encapsulation Mechanism Standard]**
- **CNSA 1.0 Compliant Algorithm:**
 - **Finite field-based key establishment schemes using "safe-prime" groups that meets NIST Special Publication 800-56A Revision 3, "Recommendation for Pair-Wise Key Establishment Schemes Using Discrete Logarithm Cryptography"**
- **No other key establishment methods**

].

FCS_COP.1/CONF_ALG: Cryptographic Operation (Confidentiality Algorithms)

This SFR is modified from its definition in the Base-PP by mandating support for both 256-bit implementations of AES-GCM (which this PP-Module requires for the use of IKE and ESP). Other AES modes may be selected by the ST author as needed to address functions not required by this PP-Module. The "no other modes" selection is added for the case where no AES claims need to be made beyond what is mandated for IPsec.

The text of the requirement is replaced with:

The TSF shall [selection: **invoke platform-provided functionality, implement functionality**] to perform [encryption and decryption] in accordance with a specified cryptographic algorithm: [

- **AES-CBC (as defined in FIPS PUB 197, and NIST SP 800-38A) mode**
- **AES-GCM (as defined in NIST SP 800-38D)**

and [selection:

- **AES Key Wrap (KW) (as defined in NIST SP 800-38F)**
- **AES Key Wrap with Padding (KWP) (as defined in NIST SP 800-38F)**
- **AES-CCM (as defined in NIST SP 800-38C)**
- **no other modes**

] and a cryptographic key size of 256-bits.

5.4.1.2 Protection of the TSF (FPT)

FPT_ITT.1/INTER_XFER: Internal TOE TSF Data Transfer (Distributed MDM Server)

When the MDM TOE claims this PP-Module, at least one of its interfaces will implement IPsec communications. However, this PP-Module does not specify that any one particular interface must be implemented using IPsec. If the TOE is distributed and uses IPsec to secure communications between its distributed components, FPT_ITT.1/INTER_XFER is defined as below.

The text of the requirement is replaced with:

The TSF shall *[implement functionality using [IPsec as defined in the PP-Module for VPN Clients]]* to protect **all** data from *[disclosure and modification]* when it is **transferred** between separate parts of the TOE.

This SFR is selection-based in the Base-PP depending on the selections made in the Base-PP requirement FTP_ITC_EXT.1. This is not changed by the PP-Module.

This SFR is modified from its definition in the Base-PP by mandating that the TSF implement IPsec communications and by prohibiting the TOE from relying on platform-provided functionality to implement this.

5.4.1.3 Trusted Path/Channels (FTP)

FTP_ITC.1/INTER_XFER_IT: Inter-TSF Trusted Channel (Authorized IT Entities)

When the MDM TOE claims this PP-Module, at least one of its interfaces will implement IPsec communications. However, this PP-Module does not specify that any one particular interface must be implemented using IPsec. If the TOE uses IPsec to secure communications between itself and external trusted IT entities, [FTP_ITC.1/INTER_XFER_IT](#) is refined as noted by the refinements above.

This SFR is refined from its definition in the Base-PP by mandating that the “implement functionality” selection be chosen at minimum for IPsec and by prohibiting the TOE from relying on platform-provided IPsec functionality. Since the TOE may support multiple trusted channel interfaces, the ST author is given the option to select other protocols (SSH, TLS, DTLS, HTTPS) either as being implemented by the TSF or invoked from the platform. The "not invoke or implement any other protocol functionality" is added for the case where the TOE's implementation of IPsec is the only trusted channel protocol the TSF uses.

The text of [FTP_ITC.1.1/INTER_XFER_IT](#) is replaced with (the other elements are unaffected):

The TSF shall

- **implement functionality using IPsec as defined in the PP-Module for VPN Client, and**
[selection:
 - *invoke platform-provided functionality to use [selection:*
 - *SSH*
 - *mutually authenticated TLS*
 - *mutually authenticated DTLS*
 - *HTTPS*
 - *implement functionality using [selection:*
 - *SSH as defined in the Functional Package for Secure Shell*
 - *mutually authenticated TLS as defined in the Package for Transport Layer Security*
 - *mutually authenticated DTLS as defined in the Package for Transport Layer Security*
 - *HTTPS in accordance with FCS_HTTPS_EXT.1*
 - *not invoke or implement any other protocol functionality*

] to provide a **trusted** communication channel between itself and **authorized IT entities supporting the following capabilities: audit server, [selection: authentication server, [assignment: other capabilities]]** that is logically distinct from other communication channels and provides assured identification of its endpoints and protection of the channel data from modification or disclosure.

FTP_TRP.1/TRUSTPATH_REM_ADMIN: Trusted Path (for Remote Administration)

When the MDM **TOE** claims this **PP-Module**, at least one of its interfaces will implement IPsec communications. However, this **PP-Module** does not specify that any one particular interface must be implemented using IPsec. If the **TOE** uses IPsec to secure communications between itself and trusted remote administrators, **FPT_TRP.1/TRUSTPATH_REM_ADMIN** is refined as below.

This **SFR** is refined from its definition in the **Base-PP** by mandating that the “implement functionality” selection be chosen at minimum for IPsec and by prohibiting the **TOE** from relying on platform-provided IPsec functionality. Since the **TOE** may support multiple remote administrative interfaces, the **ST** author is given the option to select other protocols (SSH, TLS, HTTPS) either as being implemented by the **TSF** or invoked from the platform. The “not invoke or implement any other protocol functionality” is added for the case where the **TOE**’s implementation of IPsec is the only trusted path protocol the **TSF** uses.

The text of **FTP_TRP.1.1/TRUSTPATH_REM_ADMIN** is replaced with (the other elements are unaffected):

The **TSF** shall

- **implement functionality using IPsec as defined in the **PP-Module** for **VPN Client**, and**

[selection:

- *invoke platform-provided functionality to use [selection:*
 - **TLS**
 - **HTTPS**
 - **SSH**
- *implement functionality using [selection:*
 - **TLS as defined in the Package for Transport Layer Security**
 - **HTTPS in accordance with **FCS_HTTPS_EXT.1****
 - **SSH as defined in the Functional Package for Secure Shell**
- *not invoke or implement any other protocol functionality*

] to provide a **trusted** communication path between itself as a [selection: **server, peer**] and another trusted **IT product** that is logically distinct from other communication paths and provides assured identification of its endpoints and protection of the communicated data from [modification or disclosure].

5.4.2 Additional SFRs

This **PP-Module** does not define any additional **SFRs** for any **PP-Configuration** where the MDM **PP** is claimed as the **Base-PP**.

5.5 TOE Security Functional Requirements

The following section describes the **SFRs** that must be satisfied by any **TOE** that claims conformance to this **PP-Module**. These **SFRs** must be claimed regardless of which **PP-Configuration** is used to define the **TOE**.

5.5.1 Auditable Events for Mandatory SFRs

Table 5 must be included as part of **FAU_GEN.1/VPN** for GPOS, MDF, and MDM **Base-PPs**. When App **PP** is the **Base-PP**, it should be included only if implementation-dependent requirement **FAU_GEN.1/VPN** is included in the **ST**.

Table 5: Auditable Events for Mandatory SFRs

Requirement	Auditable Events	Additional Audit Record Contents
FCS_CKM.1/VPN	No events specified	N/A
FCS_IPSEC_EXT.1	Decisions to DISCARD or BYPASS network packets processed by the TOE .	• Presumed identity of source subject. • The entry in the SPD that applied to the decision.
	Failure to establish an IPsec SA .	• Source IP address, if applicable.

		• Identity of destination subject. • Reason for failure.
	Establishment/Termination of an IPsec SA.	• Identity of destination subject. • Transport layer protocol, if applicable. • Source subject service identifier, if applicable. • Non-TOE endpoint of connection (IP address) for both successes and failures.
FDP_RIP.2	No events specified	N/A
FMT_SMF.1/VPN	Success or failure of management function.	No additional information.
FPT_TST_EXT.1/VPN	No events specified	N/A

5.5.2 Cryptographic Support (FCS)

FCS_CKM.1/VPN VPN Cryptographic Key Generation (IKE)

FCS_CKM.1.1/VPN

The TSS shall **[selection, choose one of: invoke platform-provided functionality, implement functionality]** to generate asymmetric cryptographic keys used for IKE peer authentication in accordance with: **[selection:**

- ~~FIPS PUB 186-5, “Digital Signature Standard (DSS),” Appendix A.1 for RSA schemes~~
- ~~FIPS PUB 186-5, “Digital Signature Standard (DSS),” Appendix A.2 for ECDSA schemes and implementing “NIST curve” P-384 and [selection: P-521, no other curves]~~

~~] and specified cryptographic key sizes [equivalent to, or greater than, a symmetric key strength of 128 bits] that meet the following: [assignment: list of standards].~~

Application Note: The keys that are required to be generated by the TOE through this requirement are intended to be used for the authentication of the VPN entities during the IKEv2 key exchange. While it is required that the public key be associated with an identity in an X509v3 certificate, this association is not required to be performed by the TOE, and instead is expected to be performed by a Certificate Authority in the OE.

As indicated in FCS_IPSEC_EXT.1, the TOE is required to implement support for RSA or ECDSA (or both) for authentication.

See NIST Special Publication 800-57, “Recommendation for Key Management” for information about equivalent key strengths.

Evaluation Activities ▼

FCS_CKM.1.1/VPN

TSS

The evaluator shall examine the TSS to verify that it describes how the key generation functionality is invoked.

Guidance

There are no guidance EAs for this requirement.

Tests

If this functionality is implemented by the T_{SF}, refer to the following EAs, depending on the T_{OE}'s claimed Base-PP:

- GPOS PP: FCS_CKM.1
- MDF PP: FCS_CKM.1
- App PP: FCS_CKM.1/AK
- MDM PP: FCS_CKM.1

FCS_IPSEC_EXT.1 IPsec

FCS_IPSEC_EXT.1.1

The T_{SF} shall implement the IPsec architecture as specified in RFC 4301.

Application Note: In the following elements of the FCS_IPSEC_EXT.1 component, it is allowable for some or all of the individual elements to be implemented by the platform on which the V_{PN} client operates. However, this is only the case when the platform is within the T_{OE} boundary, as is the case where this PP-Module is being claimed on top of a general-purpose OS or a mobile device.

When the T_{OE} is a standalone software application, the IPsec functionality must be implemented by the T_{SF}, though it is permissible for the T_{SF} to invoke cryptographic algorithm services from the T_{OE} platform to support the T_{OE}'s implementation of IPsec. The T_{OE} may also rely on the T_{OE} platform for X.509 certificate validation services, though it is the responsibility of the T_{SF} to take the proper action based on the validation response that is returned.

It is also permissible for the T_{SF} to rely on low-level capabilities of the platform to perform enforcement and routing functions as a result of the policies the T_{SF} maintains. For example, while the T_{SF} must provide the capability to implement the Security Policy Database (SPD) abstraction, it is permissible for the T_{SF} to depend on the platform-provided network stack to perform the low-level packet filtering and routing actions once the T_{SF} has set up those rules as defined by the SPD.

While enforcement of the IPsec requirements must be implemented by the T_{SF}, it is permissible for the T_{SF} to receive configuration of the IPsec behavior from an environmental source, most notably a V_{PN} gateway.

RFC 4301 calls for an IPsec implementation to protect IP traffic through the use of an SPD. The SPD is used to define how IP packets are to be handled: PROTECT the packet (e.g., encrypt the packet), BYPASS the IPsec services (e.g., no encryption), or DISCARD the packet (e.g., drop the packet). The SPD can be implemented in various ways, including router access control lists, firewall rulesets, a "traditional" SPD, etc. Regardless of the implementation details, there is a notion of a "rule" that a packet is "matched" against and a resulting action that takes place.

While there must be a means to order the rules, a general approach to ordering is not mandated, as long as the T_{OE} can distinguish the IP packets and apply the rules accordingly. There may be multiple SPDs (one for each network interface), but this is not required.

A V_{PN} gateway fully implements the IPsec capability and provides an administrative interface to establish and populate an SPD. A V_{PN} client is not required to provide an administrative interface to create or maintain an SPD.

As an alternative, a client may provide an interface that can be used by another application or network entity, such as a V_{PN} gateway, as a means to establish and populate the SPD. In either of these cases (the client provides an administrative interface, or an API), while the client is expected to maintain the SPD abstraction, it is permitted for the low-level

enforcement and routing activities to be implemented by platform capabilities (e.g., a network driver) as configured by the client.

FCS_IPSEC_EXT.1.2

The **TSE** shall implement [**selection:** *tunnel mode, transport mode*].

Application Note: If the **TOE** is used to connect to a **VPN** gateway for the purposes of establishing a secure connection to a private network, the **ST** author is expected to select tunnel mode. If the **TOE** uses IPsec to establish an end-to-end connection to another IPsec **VPN** client, the **ST** author is expected to select transport mode. If the **TOE** uses IPsec to establish a connection to a specific endpoint device for the purpose of secure remote administration, the **ST** author is expected to select transport mode.

FCS_IPSEC_EXT.1.3

The **TSE** shall have a nominal, final entry in the **SPD** that matches anything that is otherwise unmatched, and discards it.

FCS_IPSEC_EXT.1.4

The **TSE** shall implement the IPsec protocol **ESP** as defined by **REC 4303** using the cryptographic algorithms [**AES-GCM-256 as specified in REC 4106**].

Application Note: If this functionality is configurable, the **TSE** may be configured by a **VPN** gateway or by an administrator of the **TOE** itself.

FCS_IPSEC_EXT.1.5

The **TSE** shall implement the protocol: [**IKEv2 as defined in REC 7296 (with mandatory support for NAT traversal as specified in section 2.23), REC 8247, and REC 4868 for hash functions**].

FCS_IPSEC_EXT.1.6

The **TSE** shall ensure the encrypted payload in the [**IKEv2**] protocol uses the cryptographic algorithms [**AES-GCM-256 as specified in REC 5282**] and no other algorithm.

Application Note: If this functionality is configurable, the **TSE** may be configured by a **VPN** gateway or by an administrator of the **TOE** itself.

FCS_IPSEC_EXT.1.7

The **TSE** shall ensure that [**IKEv2 SA**] lifetimes can be configured by [**selection:** *an administrator, a VPN gateway*] based on [**selection:** *number of packets/number of bytes, length of time*]]. If length of time is used, it must include at least one option that is 24 hours or less for **IKE** SAs and eight hours or less for Child SAs.

Application Note: There is a selection that allows the **ST** author to specify which entity is responsible for “configuring” the life of the security association (**SA**). An implementation that allows an administrator to configure the client or a **VPN** gateway that pushes the **SA** lifetime down to the client are both acceptable.

As far as **SA** lifetimes are concerned, the **TOE** can limit the lifetime based on the number of bytes transmitted, or the number of packets transmitted. Either packet-based or volume-based **SA** lifetimes are acceptable; the **ST** author makes the appropriate selection to indicate which type of lifetime limits are supported.

For **IKEv2**, there are no hard-coded limits, therefore it is required that an administrator be able to configure the values. In general, instructions for setting the parameters of the implementation, including lifetime of the SAs, should be included in the operational guidance generated for **AGD_OPE**. It is appropriate to refine the requirement in terms of number of MB or KB instead of number of packets, as long as the **TOE** is capable of setting a limit on the amount of traffic that is protected by the same key (the total volume of all IPsec traffic protected by that key).

FCS_IPSEC_EXT.1.8

The **TSE** shall ensure that **IKE** implements **DH** Groups

- 20 (384-bit Random ECP) according to [RFC 5114](#) and

[selection:

- 15 (3072-bit MODP) according to [RFC 3526](#)
- 16 (4096-bit MODP) according to [RFC 3526](#)
- 17 (6144-bit MODP) according to [RFC 3526](#)
- 18 (8192-bit MODP) according to [RFC 3526](#)
- 21 (521-bit Random ECP) according to [RFC 5114](#)

].

Application Note: The selection is used to specify additional DH groups supported. This applies to IKEv2 exchanges. It should be noted that if any additional DH groups are specified, they must comply with the requirements (in terms of the ephemeral keys that are established) listed in FCS_CKM.1.

Since the implementation may allow different DH groups to be negotiated for use in forming the SAs, the assignments in [FCS_IPSEC_EXT.1.9](#) and [FCS_IPSEC_EXT.1.10](#) may contain multiple values. For each DH group supported, the ST author consults Table 2 in 800-57 to determine the “bits of security” associated with the DH group. Each unique value is then used to fill in the assignment (for 1.9 they are doubled; for they are inserted directly into the assignment). For example, suppose the implementation supports DH group 15 (3072-bit MODP) and group 20 (ECDH using NIST curve P-384). From Table 2, the bits of security value for group 15 is 128, and for group 20 it is 192. For [FCS_IPSEC_EXT.1.9](#), then, the assignment would read “[256, 384]” and for [FCS_IPSEC_EXT.1.10](#) it would read “[128, 192]”

FCS_IPSEC_EXT.1.9

The TSF shall generate the secret value x used in the IKE DH key exchange (“ x ” in $g^x \text{ mod } p$) using the random bit generator specified in FCS_RBG.1 (or [FCS_RBG_EXT.1](#) in the case of [\[App PP\]](#)), and having a length of at least **[assignment: (one or more) numbers of bits that is at least twice the “bits of security” value associated with the negotiated DH group as listed in Table 2 of NIST SP 800-57, Recommendation for Key Management – Part 1: General]** bits.

FCS_IPSEC_EXT.1.10

The TSF shall generate nonces used in IKE exchanges in a manner such that the probability that a specific nonce value will be repeated during the life a specific IPsec SA is less than 1 in $2^{\text{[assignment: (one or more) “bits of security” values associated with the negotiated DH group as listed in Table 2 of NIST SP 800-57, Recommendation for Key Management – Part 1: General]}}$.

FCS_IPSEC_EXT.1.11

The TSF shall ensure that [IKEv2] performs peer authentication using **[selection: RSA, ECDSA]** that use X.509v3 certificates that conform to [RFC 4945](#) and **[selection: Pre-shared Keys that conform to [RFC 8784](#), Pre-shared Keys transmitted via EAP-TTLS, EAP-TLS, no other method]**.

Application Note: At least one public-key-based peer authentication method is required in order to conform to this PP-Module; one or more of the public key schemes is chosen by the ST author to reflect what is implemented. The ST author also ensures that appropriate FCS requirements reflecting the algorithms used (and key generation capabilities, if provided) are listed to support those methods. Note that the TSS will elaborate on the way in which these algorithms are to be used. X.509 certificates will be validated against FIA_X509_EXT.1 from [Functional Package for X.509, version 1.0](#), which is referenced in each supported Base-PP.

If a selection with “EAP-TLS” or “EAP-TTLS” is chosen, the selection-based requirement [FCS_EAP_EXT.1](#) must be claimed. When an EAP method is used, verification occurs via an external authentication server.

If any selection including “pre-shared keys” is chosen, the selection-based requirement

[FIA_PSK_EXT.1](#) must be claimed.

Multifactor support can be achieved via traffic filtering in accordance with [PPF_MFA_EXT.1](#).

It is acceptable for different use cases to leverage different selections. If this is the case, it must be identified.

This ~~SFR~~ is modified from its definition in the ~~Base-PP~~ by adding new selections for authentication methods.

FCS_IPSEC_EXT.1.12

The ~~TSE~~ shall not establish an ~~SA~~ if the [**selection:** *IP address, Fully Qualified Domain Name (FQDN), user FQDN, Distinguished Name (DN)*] and [**selection:** *no other reference identifier type, [assignment: other supported reference identifier types]*] contained in a certificate does not match the expected values for the entity attempting to establish a connection.

Application Note: The ~~TQE~~ must support at least one of the following identifier types: IP address, FQDN, user FQDN, or DN. In the future, the ~~TQE~~ will be required to support all of these identifier types. The ~~TQE~~ is expected to support as many IP address formats (IPv4 and IPv6) as IP versions supported by the ~~TQE~~ in general. The ~~ST~~ author may assign additional supported identifier types in the second selection.

FCS_IPSEC_EXT.1.13

The ~~TSE~~ shall not establish an ~~SA~~ if the presented identifier does not match the configured reference identifier of the peer.

Application Note: At this time, only the comparison between the presented identifier in the peer's certificate and the peer's reference identifier is mandated by the testing below. However, in the future, this requirement will address two aspects of the peer certificate validation: 1) comparison of the peer's ID payload to the peer's certificate, which are both presented identifiers, as required by ~~REC~~ 4945 and 2) verification that the peer identified by the ID payload and the certificate is the peer expected by the ~~TQE~~ (per the reference identifier). At that time, the ~~TQE~~ will be required to demonstrate both aspects (i.e. that the ~~TQE~~ enforces that the peer's ID payload matches the peer's certificate, which both match configured peer reference identifiers).

Excluding the DN identifier type (which is necessarily the Subject DN in the peer certificate), the ~~TQE~~ may support the identifier in either the Common Name or Subject Alternative Name (SAN) or both. If both are supported, the preferred logic is to compare the reference identifier to a presented SAN, and only if the peer's certificate does not contain a SAN, to fall back to a comparison against the Common Name. In the future, the ~~TQE~~ will be required to compare the reference identifier to the presented identifier in the SAN only, ignoring the Common Name.

The configuration of the peer reference identifier is addressed by [FMT_SMF.1.1/VPN](#).

FCS_IPSEC_EXT.1.14

The [**selection:** *TSE, VPN gateway*] shall be able to ensure by default that the strength of the symmetric algorithm (in terms of the number of bits in the key) negotiated to protect the [*IKEv2 IKE_SA*] connection is greater than or equal to the strength of the symmetric algorithm (in terms of the number of bits in the key) negotiated to protect the [*IKEv2 CHILD_SA*] connection.

Application Note: If this functionality is configurable, the ~~TSE~~ may be configured by a ~~VPN~~ gateway or by an administrator of the ~~TQE~~ itself

While it is acceptable for this capability to be configurable, the default configuration in the evaluated configuration (either "out of the box" or by configuration guidance in the AGD

documentation) must enable this functionality.

Evaluation Activities ▼

[FCS_IPSEC_EXT.1](#)

TSS

In addition to the **TSS** EAs for the individual [FCS_IPSEC_EXT.1](#) elements below, the evaluator shall perform the following:

If the **TOE** boundary includes a general-purpose **OS** or mobile device, the evaluator shall examine the **TSS** to ensure that it describes whether the **VPN** client capability is architecturally integrated with the platform itself or it is a separate executable that is bundled with the platform.

Guidance

In addition to the guidance EAs for the individual [FCS_IPSEC_EXT.1](#) elements below, the evaluator shall perform the following:

If the configuration of the IPsec behavior is from an environmental source, most notably a **VPN** gateway (e.g. through receipt of required connection parameters from a **VPN** gateway), the evaluator shall ensure that the operational guidance contains any appropriate information for ensuring that this configuration can be properly applied.

Note, in this case, that the implementation of the IPsec protocol must be enforced entirely within the **TOE** boundary; i.e. it is not permissible for a software application **TOE** to be a graphical front-end for IPsec functionality implemented totally or in part by the underlying **OS** platform. The behavior referenced here is for the possibility that the configuration of the IPsec connection is initiated from outside the **TOE**, which is permissible so long as the **TSE** is solely responsible for enforcing the configured behavior. However, it is allowable for the **TSE** to rely on low-level, platform-provided networking functions to implement the **SPD** from the client (e.g., enforcement of packet routing decisions).

Tests

As a prerequisite for performing the Test EAs for the individual [FCS_IPSEC_EXT.1](#) elements below, the evaluator shall do the following:

The evaluator shall minimally create a test environment equivalent to the test environment illustrated below. It is expected that the traffic generator is used to construct network packets and will provide the evaluator with the ability to manipulate fields in the ICMP, IPv4, IPv6, UDP, and TCP packet headers. The evaluator shall provide justification for any differences in the test environment.

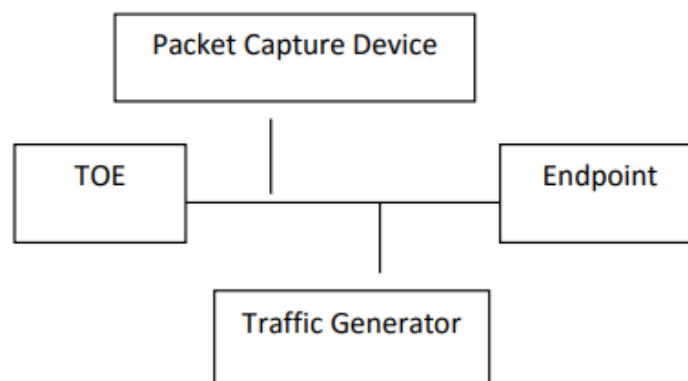


Figure 4: Test Environment

Note that the evaluator shall perform all tests using the VPN client and a representative sample of platforms listed in the ST (for TOEs that claim to support multiple platforms).

FCS_IPSEC_EXT.1.1

TSS

The evaluator shall examine the TSS and determine that it describes how the IPsec capabilities are implemented.

If the TOE is a standalone software application, the evaluator shall ensure that the TSS asserts that all IPsec functionality is implemented by the TSE. The evaluator shall also ensure that the TSS identifies what platform functionality the TSE relies on to support its IPsec implementation, if any (e.g., does it invoke cryptographic primitive functions from the platform's cryptographic library, enforcement of packet routing decisions by low-level network drivers).

If the TOE is part of a general-purpose desktop or mobile OS, the evaluator shall ensure that the TSS describes at a high level the architectural relationship between the VPN client portion of the TOE and the rest of the TOE (e.g., is the VPN client an integrated part of the OS or is it a standalone executable that is bundled into the OS package). If the SPD is implemented by the underlying platform in this case, then the TSS describes how the client interacts with the platform to establish and populate the SPD, including the identification of the platform's interfaces that are used by the client.

In all cases, the evaluator shall also ensure that the TSS describes how the client interacts with the network stack of the platforms on which it can run (e.g., does the client insert itself within the stack via kernel mods, does the client simply invoke APIs to gain access to network services).

The evaluator shall ensure that the TSS describes how the SPD is implemented and the rules for processing both inbound and outbound packets in terms of the IPsec policy. The TSS describes the rules that are available and the resulting actions available after matching a rule. The TSS describes how the available rules and actions form the SPD using terms defined in REC 4301, such as BYPASS (e.g., no encryption), DISCARD (e.g., drop the packet), and PROTECT (e.g., encrypt the packet).

As noted in section 4.4.1 of REC 4301, the processing of entries in the SPD is non-trivial, and the evaluator shall determine that the description in the TSS is sufficient to determine which rules will be applied given the rule structure implemented by the TOE. For example, if the TOE allows specification of ranges, conditional rules, etc., the evaluator shall determine that the description of rule processing (for both inbound and outbound packets) is sufficient to determine the action that will be applied, especially in the case where two different rules may apply. This description shall cover both the initial packets (that is, no SA is established on the interface or for that particular packet) as well as packets that are part of an established SA.

Guidance

The evaluator shall examine the operational guidance to verify it describes how the SPD is created and configured. If there is an administrative interface to the client, then the guidance describes how the administrator specifies rules for processing a packet. The description includes all three cases - a rule that ensures packets are encrypted/decrypted, dropped, and allowing a packet to flow in plaintext. The evaluator shall determine that the description in the operational guidance is consistent with the description in the TSS, and that the level of detail in the operational guidance is sufficient to allow the administrator to set up the SPD in an unambiguous fashion. This includes a discussion of how ordering of rules impacts the processing of an IP packet.

If the client is configured by an external application, such as the VPN gateway, then the operational guidance should indicate this and provide a description of how the client is configured by the external application. The description should contain information as to how the SPD is established and set up in an unambiguous fashion. The description should also include what is configurable via the external application, how ordering of entries may be expressed, as well as the impacts that ordering of entries may have on the packet processing.

In either case, the evaluator shall ensure the description provided in the TSS is consistent with the capabilities

and description provided in the operational guidance.

Tests

Depending on the implementation, the evaluator may be required to use a VPN gateway or some form of application to configure the client. For Test 2, the evaluator is required to choose an application that allows for the configuration of the full set of capabilities of the VPN client (in conjunction with the platform). For example, if the client provides a robust interface that allows for specification of wildcards, subnets, etc., it is unacceptable for the evaluator to choose a VPN gateway that only allows for specifying a single fully qualified IP addresses in the rule.

The evaluator shall perform the following tests:

- Test FCS_IPSEC_EXT.1.1:1: The evaluator shall configure an SPD on the client that is capable of the following: dropping a packet, encrypting a packet, and allowing a packet to flow in plaintext. The selectors used in the construction of the rule shall be different such that the evaluator can generate a packet and send packets to the client with the appropriate fields (fields that are used by the rule - e.g., the IP addresses, TCP/UDP ports) in the packet header. The evaluator shall perform both positive and negative test cases for each type of rule. The evaluator shall observe via the audit trail and packet captures that the TOE exhibited the expected behavior: appropriate packets were dropped, allowed through without modification, was encrypted by the IPsec implementation.
- Test FCS_IPSEC_EXT.1.1:2: The evaluator shall devise several tests that cover a variety of scenarios for packet processing. These scenarios must exercise the range of possibilities for SPD entries and processing modes as outlined in the TSS and operational guidance. Potential areas to cover include rules with overlapping ranges and conflicting entries, inbound and outbound packets, and packets that establish SAs as well as packets that belong to established SAs. The evaluator shall verify, via the audit trail and packet captures, for each scenario that the expected behavior is exhibited, and is consistent with both the TSS and the operational guidance.

FCS_IPSEC_EXT.1.2

TSS

The evaluator shall check the TSS to ensure it states that the VPN can be established to operate in tunnel mode, transport mode, or both (as selected).

Guidance

The evaluator shall confirm that the operational guidance contains instructions on how to configure the connection in each mode selected.

If both transport and tunnel modes are implemented, the evaluator shall review the operational guidance to determine how the use of a given mode is specified.

Tests

The evaluator shall perform the following tests based on the selections chosen:

- Test FCS_IPSEC_EXT.1.2:1: [conditional]: If tunnel mode is selected, the evaluator shall use the operational guidance to configure the TOE and a VPN gateway to operate in tunnel mode. The evaluator shall configure the TOE and the VPN gateway to use any of the allowable cryptographic algorithms, authentication methods, etc. to ensure an allowable SA can be negotiated. The evaluator shall then initiate a connection from the client to connect to the VPN gateway peer. The evaluator shall observe (for example, in the audit trail and the captured packets) that a successful connection was established using the tunnel mode.
- Test FCS_IPSEC_EXT.1.2:2: [conditional]: If transport mode is selected, the evaluator shall use the operational guidance to configure the TOE to operate in transport mode and also configures an IPsec peer to accept IPsec connections using transport mode. The evaluator shall configure the TOE and the endpoint device to use any of the allowed cryptographic algorithms, authentication methods, etc. to ensure an allowable SA can be negotiated. The evaluator shall then initiate a connection from the TOE to connect to the remote endpoint. The evaluator shall observe (for example, in the audit trail and the captured packets) that a successful connection was established using the transport mode.
- Test FCS_IPSEC_EXT.1.2:3: [conditional]: If both tunnel and transport modes are selected, the evaluator shall perform both Test 1 and Test 2 above, demonstrating that the TOE can be configured to

support both modes.

- Test FCS_IPSEC_EXT.1.2:4: [conditional]: If both tunnel and transport modes are selected, the evaluator shall modify the testing for [FCS_IPSEC_EXT.1](#) to include the supported mode for SPD. PROTECT entries to show that they only apply to traffic that is transmitted or received using the indicated mode.

[FCS_IPSEC_EXT.1.3](#)

TSS

The evaluator shall examine the TSS to verify that the TSS provides a description of how a packet is processed against the SPD and that if no “rules” are found to match, that a final rule exists, either implicitly or explicitly, that causes the network packet to be discarded.

Guidance

The evaluator shall check that the operational guidance provides instructions on how to construct or acquire the SPD and uses the guidance to configure the TOE for the following test.

Tests

The evaluator shall perform the following test:

- Test FCS_IPSEC_EXT.1.3:1: The evaluator shall configure the SPD such that it has entries that contain operations that DISCARD, PROTECT, and (if applicable) BYPASS network packets. The evaluator may use the SPD that was created for verification of [FCS_IPSEC_EXT.1.1](#). The evaluator shall construct a network packet that matches a BYPASS entry and send that packet. The evaluator should observe that the network packet is passed to the proper destination interface with no modification. The evaluator shall then modify a field in the packet header; such that it no longer matches the evaluator-created entries (there may be a “TOE-created” final entry that discards packets that do not match any previous entries). The evaluator sends the packet, and observes that the packet was not permitted to flow to any of the TOE’s interfaces.

[FCS_IPSEC_EXT.1.4](#)

TSS

The evaluator shall examine the TSS to verify that the algorithm AES-GCM-256 is implemented. In addition, the evaluator shall ensure that the SHA-based HMAC algorithm conforms to the algorithms specified in the relevant iteration of FCS_COP.1 from the Base-PP that applies to keyed-hash message authentication.

Guidance

The evaluator shall check the operational guidance to ensure it provides instructions on how the TOE is configured to use the algorithms selected in this component and whether this is performed through direct configuration, defined during initial installation, or defined by acquiring configuration settings from an environmental component.

Tests

- Test FCS_IPSEC_EXT.1.4:1: The evaluator shall configure the TOE as indicated in the operational guidance, configuring the TOE to use the AES-GCM-256 algorithm, and attempt to establish a connection using ESP.

[FCS_IPSEC_EXT.1.5](#)

TSS

The evaluator shall examine the TSS to verify that IKEv2 is implemented.

Guidance

The evaluator shall check the operational guidance to ensure it instructs the administrator how to configure the TOE to support only IKEv2 (if necessary), and uses the guidance to configure the TOE to perform NAT traversal for the tests below.

Tests

- Test FCS_IPSEC_EXT.1.5:1: The evaluator shall configure the TOE so that it will perform NAT traversal processing as described in the TSS and RFC 7296, section 2.23. The evaluator shall initiate an IPsec

connection and determine that the NAT is successfully traversed.

- Test FCS_IPSEC_EXT.1.5.2: The evaluator shall configure a remote peer to support IKEv1 only. If the TOE's supported versions of IKE is configurable, the evaluator shall follow the instructions specified in the operational guidance to ensure that only IKEv2 is supported. The evaluator shall then attempt to establish a connection between the TOE and that peer and verify the TSS rejects the connection attempt based on its lack of support for IKEv1.

FCS_IPSEC_EXT.1.6

TSS

The evaluator shall ensure the TSS identifies the algorithms used for encrypting the IKEv2 payload and that the algorithm AES-GCM-256 is specified.

Guidance

The evaluator shall check the operational guidance to ensure it provides instructions on how the TOE is configured to use the algorithms selected in this component and whether this is performed through the TOE's default configuration (i.e., no configuration is necessary), direct configuration, defined during initial installation, or defined by acquiring configuration settings from an environmental component.

Tests

The evaluator shall use the operational guidance to configure the TOE (or to configure the OE to have the TOE receive configuration) to perform the following test for the selected ciphersuite:

- Test FCS_IPSEC_EXT.1.6.1: The evaluator shall configure the TOE to use the ciphersuite under test to encrypt the IKEv2 payload and establish a connection with a peer device, which is configured to only accept the payload encrypted using the indicated ciphersuite. The evaluator shall confirm the algorithm was that used in the negotiation. The evaluator shall confirm that the connection is successful by confirming that data can be passed through the connection once it is established. For example, the evaluator may connect to a webpage on the remote network and verify that it can be reached.

FCS_IPSEC_EXT.1.7

TSS

There are no TSS EAs for this requirement.

Guidance

The evaluator shall check the operational guidance to ensure it provides instructions on how the TOE configures the values for SA lifetimes. In addition, the evaluator shall check that the guidance has the option for either the administrator or VPN gateway to configure IKE SAs if time-based limits are supported. Currently, there are no values mandated for the number of packets or number of bytes; the evaluator shall simply check the operational guidance to ensure that this can be configured if selected in the requirement.

Tests

When testing this functionality, the evaluator shall ensure that both sides are configured appropriately. From the REC: "In IKEv2, each end of the SA is responsible for enforcing its own lifetime policy on the SA and rekeying the SA when necessary. If the two ends have different lifetime policies, the end with the shorter lifetime will end up always being the one to request the rekeying. If the two ends have the same lifetime policies, it is possible that both will initiate a rekeying at the same time (which will result in redundant SAs). To reduce the probability of this happening, the timing of rekeying requests *SHOULD* be jittered."

Each of the following tests shall be performed:

- Test FCS_IPSEC_EXT.1.7.1: [conditional]: The evaluator shall configure a maximum lifetime in terms of the # of packets (or bytes) allowed following the operational guidance. The evaluator shall establish an SA and determine that once the allowed # of packets (or bytes) through this SA is exceeded, the connection is closed.
- Test FCS_IPSEC_EXT.1.7.2: [conditional]: The evaluator shall construct a test where an IKEv2 IKE_SA is established and attempted to be maintained for more than 24 hours before it is renegotiated. The evaluator shall observe that this SA is closed or renegotiated in 24 hours or less. If such an action requires that the TOE be configured in a specific way, the evaluator shall implement tests demonstrating that the configuration capability of the TOE works as documented in the operational guidance.

- Test FCS_IPSEC_EXT.1.7:3: [conditional]: The evaluator shall perform a test similar to Test 2 for Child SAs, except that the lifetime will be 8 hours or less instead of 24 hours or less.

[FCS_IPSEC_EXT.1.8](#)

TSS

The evaluator shall check to ensure that the *DPH* groups specified in the requirement are listed as being supported in the *TSS*. If there is more than one *DPH* group supported, the evaluator shall check to ensure the *TSS* describes how a particular *DPH* group is specified/negotiated with a peer.

Guidance

There are no guidance EAs for this requirement.

Tests

The evaluator shall perform the following test:

- Test FCS_IPSEC_EXT.1.8:1: For each supported *DPH* group, the evaluator shall test to ensure that IKEv2 can be successfully completed using that particular *DPH* group.

[FCS_IPSEC_EXT.1.9](#)

TSS

The evaluator shall check to ensure that, for each *DPH* group supported, the *TSS* describes the process for generating "x" (as defined in [FCS_IPSEC_EXT.1.9](#)) and each nonce. The evaluator shall verify that the *TSS* indicates that the random number generated that meets the requirements in this *EP* is used, and that the length of "x" and the nonces meet the stipulations in the requirement.

Guidance

There are no guidance EAs for this requirement.

Tests

There are no test EAs for this requirement.

[FCS_IPSEC_EXT.1.10](#)

EAs for this element are tested through EAs for [FCS_IPSEC_EXT.1.9](#).

[FCS_IPSEC_EXT.1.11](#)

TSS

The evaluator shall ensure that the *TSS* describes whether peer authentication is performed using RSA, ECDSA, or both.

If any selection with pre-shared keys is chosen in the selection, the evaluator shall check to ensure that the *TSS* describes how those selections work in conjunction with authentication of IPsec connections.

The evaluator shall ensure that the *TSS* describes how the *TOE* compares the peer's presented identifier to the reference identifier. This description shall include whether the certificate presented identifier is compared to the ID payload presented identifier, which fields of the certificate are used as the presented identifier (*DN*, Common Name, or SAN), and if multiple fields are supported, the logical order comparison. If the *ST* author assigned an additional identifier type, the *TSS* description shall also include a description of that type and the method by which that type is compared to the peer's presented certificate.

Guidance

If any selection with "Pre-shared Keys" is selected, the evaluator shall check that the operational guidance describes any configuration necessary to enable any selected authentication mechanisms.

If any method other than no other method is selected, the evaluator shall check that the operational guidance describes any configuration necessary to enable any selected authentication mechanisms.

The evaluator shall ensure that the operational guidance describes how to set up the *TOE* to use the cryptographic algorithms RSA, ECDSA, or either, depending on which is claimed in the *ST*.

In order to construct the environment and configure the *TOE* for the following tests, the evaluator shall ensure that the operational guidance also describes how to configure the *TOE* to connect to a trusted CA, and ensure a valid certificate for that CA is loaded into the *TOE* as a trusted CA.

The evaluator shall also ensure that the operational guidance includes the configuration of the reference identifiers for the peer.

Tests

For efficiency's sake, the testing that is performed here has been combined with the testing for FIA_X509_EXT.2 in [Functional Package for X.509, version 1.0](#) and FIA_X509_EXT.4 (for IPsec connections and depending on the *Base-PP*), FCS_IPSEC_EXT.1.12, and FCS_IPSEC_EXT.1.13. The following tests shall be repeated for each peer authentication protocol selected in the FCS_IPSEC_EXT.1.11 selection above:

- Test FCS_IPSEC_EXT.1.11:1: The evaluator shall have the *TOE* generate a public-private key pair and submit a CSR (Certificate Signing Request) to a CA (trusted by both the *TOE* and the peer *VPN* used to establish a connection) for its signature. The values for the *DN* (Common Name, Organization, Organizational Unit, and Country) will also be passed in the request. Alternatively, the evaluator may import to the *TOE* a previously generated private key and corresponding certificate.
- Test FCS_IPSEC_EXT.1.11:2: The evaluator shall configure the *TOE* to use a private key and associated certificate signed by a trusted CA and shall establish an IPsec connection with the peer.
- Test FCS_IPSEC_EXT.1.11:3: The evaluator shall test that the *TOE* can properly handle revoked certificates – conditional on whether *CRL* or *OCSP* is selected; if both are selected, then a test is performed for each method. For this current version of the *PP-Module*, the evaluator has to only test one up in the trust chain (future drafts may require to ensure the validation is done up the entire chain). The evaluator shall ensure that a valid certificate is used and that the *SA* is established. The evaluator shall then attempt the test with a certificate that will be revoked (for each method chosen in the selection) to ensure when the certificate is no longer valid that the *TOE* will not establish an *SA*.
- Test FCS_IPSEC_EXT.1.11:4: [conditional]: For each selection made, the evaluator shall verify factors are required, as indicated in the operational guidance, to establish an IPsec connection with the server.

For each supported identifier type (excluding *DN*s), the evaluator shall repeat the following tests:

- Test FCS_IPSEC_EXT.1.11:5: For each field of the certificate supported for comparison, the evaluator shall configure the peer's reference identifier on the *TOE* (per the administrative guidance) to match the field in the peer's presented certificate and shall verify that the IKEv2 authentication succeeds.
- Test FCS_IPSEC_EXT.1.11:6: For each field of the certificate support for comparison, the evaluator shall configure the peer's reference identifier on the *TOE* (per the administrative guidance) to not match the field in the peer's presented certificate and shall verify that the IKEv2 authentication fails.
- Test FCS_IPSEC_EXT.1.11:7: [conditional]: If, according to the *TSS*, the *TOE* supports both Common Name and SAN certificate fields and uses the preferred logic outlined in the Application Note, the tests above with the Common Name field shall be performed using peer certificates with no SAN extension. Additionally, the evaluator shall configure the peer's reference identifier on the *TOE* to not match the SAN in the peer's presented certificate, but to match the Common Name in the peer's presented certificate and verify that the IKEv2 authentication fails.
- Test FCS_IPSEC_EXT.1.11:8: [conditional]: If the *TOE* supports *DN* identifier types, the evaluator shall configure the peer's reference identifier on the *TOE* (per the administrative guidance) to match the subject *DN* in the peer's presented certificate and shall verify that the IKEv2 authentication succeeds. To demonstrate a bit-wise comparison of the *DN*, the evaluator shall change a single bit in the *DN* (preferably, in an Object Identifier (OID) in the *DN*) and verify that the IKEv2 authentication fails. To demonstrate a comparison of *DN* values, the evaluator shall change any one of the four *DN* values and verify that the IKEv2 authentication fails.
- Test FCS_IPSEC_EXT.1.11:9: [conditional]: If the *TOE* supports both IPv4 and IPv6 and supports *IP* address identifier types, the evaluator must repeat tests 1 and 2 with both IPv4 address identifiers and IPv6 identifiers. Additionally, the evaluator shall verify that the *TOE* verifies that the *IP* header matches the identifiers by setting the presented identifiers and the reference identifier with the same *IP* address that differs from the actual *IP* address of the peer in the *IP* headers and verifying that the IKEv2 authentication fails.
- Test FCS_IPSEC_EXT.1.11:10: [conditional]: If, according to the *TSS*, the *TOE* performs comparisons between the peer's ID payload and the peer's certificate, the evaluator shall repeat the following test for each combination of supported identifier types and supported certificate fields (as above). The evaluator

shall configure the peer to present a different ID payload than the field in the peer's presented certificate and verify that the ~~TOE~~ fails to authenticate the IKEv2 peer.

[FCS_IPSEC_EXT.1.12](#)

EAs for this element are tested through EAs for [FCS_IPSEC_EXT.1.11](#).

[FCS_IPSEC_EXT.1.13](#)

EAs for this element are tested through EAs for [FCS_IPSEC_EXT.1.11](#).

[FCS_IPSEC_EXT.1.14](#)

~~TSS~~

The evaluator shall check that the ~~TSS~~ describes the potential strengths (in terms of the number of bits in the symmetric key) of the algorithms that are allowed for the ~~IKE~~ and ~~ESP~~ exchanges. The ~~TSS~~ shall also describe the checks that are done when negotiating IKEv2 CHILD_SA suites to ensure that the strength (in terms of the number of bits of key in the symmetric algorithm) of the negotiated algorithm is less than or equal to that of the ~~IKE SA~~ that is protecting the negotiation.

Guidance

There are no guidance EAs for this requirement.

Tests

The evaluator shall follow the guidance to configure the ~~TOE~~ to perform the following tests:

- Test [FCS_IPSEC_EXT.1.14:1](#): The evaluator shall successfully negotiate an IPsec connection using each of the supported algorithms and hash functions identified in the requirements.
- Test [FCS_IPSEC_EXT.1.14:2](#): [conditional]: The evaluator shall attempt to establish a IKEv2 Child SA that selects an encryption algorithm with more strength than that being used for the IKEv2 ~~IKE SA~~ (i.e., symmetric algorithm with a key size larger than that being used for the ~~IKE SA~~). Such attempts should fail.
- Test [FCS_IPSEC_EXT.1.14:3](#): The evaluator shall attempt to establish an IKEv2 ~~IKE SA~~ using an algorithm that is not one of the supported algorithms and hash functions identified in the requirements. Such an attempt should fail.
- Test [FCS_IPSEC_EXT.1.14:4](#): The evaluator shall attempt to establish an IKEv2 Child SA for ~~ESP~~ (assumes the proper parameters where used to establish the ~~IKE SA~~) that selects an encryption algorithm that is not identified in [FCS_IPSEC_EXT.1.4](#). Such an attempt should fail.

5.5.3 User Data Protection (FDP)

FDP_RIP.2 Full Residual Information Protection

FDP_RIP.2.1

The [selection, choose one of: ~~TOE~~, ~~TOE platform~~] shall ensure that any previous information content of a resource is made unavailable upon the [selection: allocation of the resource to, deallocation of the resource from] all objects.

Application Note: This requirement ensures, for example, that protocol data units (PDUs) are not padded with residual information such as cryptographic key material. The ~~ST~~ author uses the selection to specify when previous information is made unavailable.

Evaluation Activities ▼

[FDP_RIP.2.1](#)

~~TSS~~

Requirement met by the platform

The evaluator shall examine the ~~TSS~~ to verify that it describes (for each supported platform) the extent to

which the client processes network packets and addresses the [FDP_RIP.2](#) requirement.

Requirement met by the T_{OE}

“Resources” in the context of this requirement are network packets being sent through (as opposed to “to”, as is the case when a security administrator connects to the T_{OE}) the T_{OE}. The concern is that once a network packet is sent, the buffer or memory area used by the packet still contains data from that packet, and that if that buffer is reused, those data might remain and make their way into a new packet. The evaluator shall check to ensure that the T_{SS} describes packet processing to the extent that they can determine that no data will be reused when processing network packets. The evaluator shall ensure that this description at a minimum describes how the previous data are zeroized/overwritten and at what point in the buffer processing this occurs.

Guidance

There are no guidance EAs for this requirement.

Tests

There are no test EAs for this requirement.

5.5.4 Security Management (FMT)

The T_{OE} is not required to maintain a separate management role. It is, however, required to provide functionality to configure certain aspects of T_{OE} operation that should not be available to the general user population. It is possible for the T_{OE}, T_{OE} Platform, or VPN gateway to provide this functionality. The client itself has to be configurable - whether it is from the EUD or from a VPN gateway.

FMT_SMF.1/VPN Specification of Management Functions (VPN)

FMT_SMF.1.1/VPN

The T_{SSF} shall be capable of performing the following management functions: [**selection:**

- Specify VPN gateways to use for connections
- Specify IPsec VPN clients to use for connections
- Specify IPsec-capable network devices to use for connections
- Specify client credentials to be used for connections
- Configure the reference identifier of the peer
- [**assignment:** any additional management functions]

]

Application Note: Several of the management functions defined above correspond to the use cases of the T_{OE} as follows:

- “Specify VPN gateways to use for connections” – Use Case 1
- “Specify IPsec VPN clients to use for connections” – Use Case 2 (specifically refers to different end points to use for client-to-client connections)
- “Specify IPsec-capable network devices to use for connections” – Use Case 3

Selections appropriate for the use cases supported by the T_{OE} should be claimed. “Client credentials” will include the client certificate used for IPsec authentication, and may also include a PSK.

For T_{OE}s that support only IP address and FQDN identifier types, configuration of the reference identifier may be the same as configuration of the peer’s name for the purposes of connection.

If there are additional management functions performed by the T_{OE} (including those specified in [FCS_IPSEC_EXT.1](#)), they should be added in the assignment.

[FMT_SMF.1.1/VPN](#)

TSS

The evaluator shall check to ensure the TSS describes the client credentials and how they are used by the TOE.

Guidance

The evaluator shall check to make sure that every management function mandated in the ST for this requirement is described in the operational guidance and that the description contains the information required to perform the management duties associated with each management function.

Tests

The evaluator shall test the TOE's ability to provide the management functions by configuring the TOE according to the operational guidance and testing of each management activity listed in the ST.

The evaluator shall ensure that all management functions claimed in the ST can be performed by completing activities described in the AGD. Note that this may be performed in the course of completing other testing.

5.5.5 Protection of the TSF (FPT)

FPT_TST_EXT.1/VPN TSF Self-Test

FPT_TST_EXT.1.1/VPN

The [selection, choose one of: TOE, TOE platform] shall run a suite of self tests during initial start-up (on power on) to demonstrate the correct operation of the TSF.

FPT_TST_EXT.1.2/VPN

The [selection, choose one of: TOE, TOE platform] shall provide the capability to verify the integrity of stored TSF executable code when it is loaded for execution through the use of the [assignment: cryptographic services provided either by the portion of the TOE described by the Base.PP or by the OE].

Application Note: While the TOE is typically a software package running in the IT Environment, it is still capable of performing the self-test activities required above. It should be understood, however, that there is a significant dependency on the host environment in assessing the assurance provided by the tests mentioned above (meaning that if the host environment is compromised, the self-tests will not be meaningful).

Cryptographic verification of the integrity is required, but the method by which this can be accomplished is specified in the ST in the assignment. The ST author will fill in the assignment with references to the cryptographic functions used to perform the integrity checks; this will include hashing and may potentially include digital signatures signed using X.509 certificates. If the TSF provides the cryptographic services used to verify updates, all relevant FCS_COP requirements will be identified in the assignment by the ST author.

Evaluation Activities ▼

[FPT_TST_EXT.1/VPN](#)

Except for where it is explicitly noted, the evaluator is expected to check the following information regardless of whether the functionality is implemented by the TOE or by the TOE platform.

TSS

The evaluator shall examine the TSS to ensure that it details the self-tests that are run by the TSF on startup; this description should include an outline of what the tests are actually doing (e.g., rather than saying "memory is tested," a description similar to "memory is tested by writing a value to each memory location and reading it back to ensure it is identical to what was written" shall be used). The evaluator shall ensure that the TSS makes an argument that the tests are sufficient to demonstrate that the TSF is operating correctly. If some of the tests

are performed by the *TOE* platform, the evaluator shall check the *TSS* to ensure that those tests are identified and that the *ST* for each platform contains a description of those tests. Note that the tests that are required by this component are those that support security functionality in this *PP-Module*, which may not correspond to the set of all self-tests contained in the platform *STs*.

The evaluator shall examine the *TSS* to ensure that it describes how the integrity of stored *TSF* executable code is cryptographically verified when it is loaded for execution. The evaluator shall ensure that the *TSS* makes an argument that the tests are sufficient to demonstrate that the integrity of stored *TSF* executable code has not been compromised. The evaluator shall check to ensure that the cryptographic requirements listed are consistent with the description of the integrity verification process.

Guidance

If not present in the *TSS*, the evaluator shall ensure that the operational guidance describes the actions that take place for successful (e.g., hash verified) and unsuccessful (e.g., hash not verified) cases. For checks implemented entirely by the platform, the evaluator shall ensure that the operational guidance for the *TOE* references or includes the platform-specific guidance for each platform listed in the *ST*.

Tests

The evaluator shall perform the following tests:

- Test *FPT_TST_EXT.1/VPN:1*: The evaluator shall perform the integrity check on a known good *TSF* executable and verifies that the check is successful.
- Test *FPT_TST_EXT.1/VPN:2*: The evaluator shall modify the *TSF* executable, performs the integrity check on the modified *TSF* executable, and verifies that the check fails.

5.6 TOE Security Functional Requirements Rationale

The following rationale provides justification for each *SFR* for the *TOE*, showing that the *SFRs* are suitable to address the specified threats:

Table 6: *SFR* Rationale

Threat	Addressed by	Rationale
T.TSF_CONFIGURATION	FAU_GEN.1/VPN (implementation-dependent)	This <i>SFR</i> mitigates the threat by optionally requiring the <i>TOE</i> to generate audit data for its behavior.
	FAU_SEL.1/VPN (objective)	This <i>SFR</i> mitigates the threat by optionally requiring the <i>TOE</i> to allow for the configuration of what behavior is audited.
	FIA_X509_EXT.4 (additional to GPOS PP)	This <i>SFR</i> mitigates the threat by providing the ability to verify the integrity of the <i>TSF</i> using X.509 certificates.
	FMT_SMF.1/VPN	This <i>SFR</i> mitigates the threat by requiring the <i>TOE</i> to implement certain administratively-configurable functions.
	FPT_TST_EXT.1/VPN	This <i>SFR</i> mitigates the threat by requiring the <i>TOE</i> to execute self-tests that demonstrate that its integrity is maintained.
T.TSF_FAILURE	FAU_GEN.1/VPN (implementation-dependent)	This <i>SFR</i> mitigates the threat by optionally requiring the <i>TOE</i> to generate audit data for its behavior.
	FAU_SEL.1/VPN (objective)	This <i>SFR</i> mitigates the threat by optionally requiring the <i>TOE</i> to allow for the configuration of what behavior is audited.

	FPT_TST_EXT.1/VPN	This SFR mitigates the threat by requiring the TOE to execute self-tests that demonstrate that its integrity is maintained.
T.UNAUTHORIZED_ACCESS	FCS_EAP_EXT.1 (selection-based)	This SFR mitigates the threat by optionally implementing EAP-TLS or EAP-TTLS as a mechanism for authentication.
	FCS_IPSEC_EXT.1	This SFR mitigates the threat by requiring the TOE's implementation of IPsec to include requirements for how the remote VPN gateway or peer is authenticated.
	FIA_BMA_EXT.1 (optional)	This SFR mitigates the threat by optionally defining the TOE's support for a platform-based biometric mechanism to use as an authentication mechanism.
	FIA_PSK_EXT.1 (selection-based)	This SFR mitigates the threat by optionally requiring support for pre-shared keys as an alternate authentication method for IPsec.
	FIA_PSK_EXT.2 (selection-based)	This SFR mitigates the threat by optionally specifying whether the TOE generates its own pre-shared keys used for authentication or accept them from an external source.
	FIA_PSK_EXT.3 (selection-based)	This SFR mitigates the threat by optionally defining the composition and use of password-based pre-shared keys used for authentication.
	FIA_PSK_EXT.4 (selection-based)	This SFR mitigates the threat by optionally defining HOTP as an authentication mechanism.
	FIA_PSK_EXT.5 (selection-based)	This SFR mitigates the threat by optionally defining TOTP as an authentication mechanism.
	FPF_MFA_EXT.1 (optional)	This SFR mitigates the threat by optionally enforcing a multifactor authentication requirement on an IPsec connection.
	FTP_ITC.1 (additional to GPOS PP)	This SFR mitigates the threat by defining the use of IPsec for protecting data in transit.
T.USER_DATA_REUSE	FCS_CKM_EXT.2 (additional to App PP)	This SFR mitigates the threat by requiring the TOE or its platform to store sensitive data in the OS' key storage.
	FCS_CKM_EXT.2 (additional to GPOS PP)	This SFR mitigates the threat by requiring the TOE to store sensitive data in the OS' key storage.
	FCS_CKM.6 (additional to App PP)	This SFR mitigates the threat by requiring the TOE or its platform to zeroize key data when no longer needed.
	FDP_RIP.2	This SFR mitigates the threat by requiring the TOE or its platform to ensure that residual data is purged from the system.
	FDP_VPN_EXT.1 (additional to MDF PP)	This SFR mitigates the threat by optionally requiring the TOE to prohibit split-tunneling so that network traffic cannot be transmitted outside of an established IPsec tunnel.
	FPF_MFA_EXT.1 (optional)	This SFR mitigates the threat by optionally requiring the TOE to prohibit transmission of packet data aside from those packets needed to perform multifactor authentication.

6 Consistency Rationale

6.1 Protection Profile for Protection Profile for General Purpose Operating System

6.1.1 Consistency of TOE Type

If this PP-Module is used to extend the GPOS PP, the TOE type for the overall TOE is still a general-purpose OS. The TOE boundary is simply extended to include VPN client functionality that is built into the OS so that additional security functionality is claimed within the scope of the TOE.

6.1.2 Consistency of Security Problem Definition

The threats and assumptions defined by this PP-Module (see sections 3.1 and 3.2) supplement those defined in the GPOS PP as follows:

Table 7: Consistency of Security Problem Definition (GPOS PP base)

PP-Module Threat, Assumption, QSP	Consistency Rationale
T.TSF_CONFIGURATION	The threat of a misconfigured VPN client is consistent with the T.NETWORK_ATTACK and T.NETWORK_EAVESDROP threats on the GPOS PP because misconfiguration could allow VPN traffic to be subjected unexpectedly to unauthorized modification or disclosure.
T.TSF_FAILURE	A failure of TSF functionality could compromise the local system, which is consistent with the T.LOCAL_ATTACK threat in the GPOS PP.
T.UNAUTHORIZED_ACCESS	The threat of an attacker gaining access to a network interface or data that is transmitted over it is consistent with the T.NETWORK_ATTACK and T.NETWORK_EAVESDROP threats in the GPOS PP.
T.USER_DATA_REUSE	Inadvertent disclosure of user data to an unauthorized recipient is consistent with the T.NETWORK_EAVESDROP threat in the GPOS PP.
A.NO_TOE_BYPASS	The A.NO_TOE_BYPASS assumption assumes that the OE is configured in such a manner that the only network route to the protected network is through the TOE. This does not conflict with the GPOS PP because the GPOS PP makes no assumptions about the network architecture in which the TOE is deployed.
A.PHYSICAL	The assumption that physical security is provided by the environment is not explicitly stated in the GPOS PP but is consistent with the A.PLATFORM assumption defined in the GPOS PP, which expects the computing platform to be trusted.
A.TRUSTED_CONFIG	The assumption that personnel responsible for the TOE's configuration are trusted to follow the guidance is consistent with the A.PROPER_ADMIN defined in the GPOS PP.

6.1.3 Consistency of OE Objectives

Table 8: Consistency of OE Objectives (GPOS PP base)

PP-Module OE Objective	Consistency Rationale
------------------------	-----------------------

OE.NO_TOE_BYPASS	This objective addresses behavior that is out of scope of the GPOS PP and does not define an environment that a GPOS TOE is incapable of existing in.
OE.PHYSICAL	This is part of satisfying OE.PLATFORM as defined in the GPOS PP because physical security is required for hardware to be considered ‘trusted.’
OE.TRUSTED_CONFIG	The expectation of trusted configuration is consistent with OE.PROPER_USER and OE.PROPER_ADMIN in the GPOS PP.

6.1.4 Consistency of Requirements

This PP-Module identifies several SERs from the GPOS PP that are needed to support VPN client functionality. This is considered to be consistent because the functionality provided by the GPOS PP is being used for its intended purpose. The PP-Module also identifies a number of modified SERs from the GPOS PP as well as new SERs that are used entirely to provide functionality for VPN client. The rationale for why this does not conflict with the claims defined by the GPOS PP are as follows:

Table 9: Consistency of Requirements (GPOS PP base)

PP-Module Requirement	Consistency Rationale
Modified SERs	
FCS_CKM.1	The ST author is instructed to make specific selections at minimum to address VPN client requirements; the SER behavior itself is unmodified.
FCS_CKM.2	The ST author is instructed to make specific selections at minimum to address VPN client requirements; the SER behavior itself is unmodified.
FCS_COP.1/ENCRYPT	The SER is refined to mandate AES modes that must be supported to address VPN client requirements; the use of these modes for VPN connectivity does not impact the ability of the TSF to satisfy any of its other security requirements.
Additional SERs	
FCS_CKM_EXT.2	Storage of key data related to VPN functionality can be accomplished using the same mechanism defined by FCS_STO_EXT.1 in the GPOS PP.
FIA_X509_EXT.4	This SER defines additional uses for X.509 certificate functionality that do not conflict with those defined in the GPOS PP.
FTP_ITC.1	This SER defines a trusted channel for IPsec, which is added functionality that does not prevent the existing GPOS functions from being performed.
Mandatory SERs	
FCS_CKM.1/VPN	Generation of IKE peer authentication keys is added functionality that does not prevent the existing GPOS functions from being performed.
FCS_IPSEC_EXT.1	This SER defines the VPN client’s IPsec implementation, which is added functionality that does not interfere with the GPOS functions.
FDP_RIP.2	The requirement to protect against reuse of residual data is a property of the VPN client behavior and does not impact the GPOS functionality.
FMT_SMF.1/VPN	The ability to configure the VPN client behavior does not affect whether the GPOS as a whole can perform its security functions.
FPT_TST_EXT.1/VPN	Self-testing of the VPN client functionality does not impact the ability of the GPOS to perform its security functions.

Optional SERs

FIA_BMA_EXT.1	This SER relates to biometric authentication, which does not conflict with the GPOS PP because it may be a function offered by the part of the TOE described by the GPOS PP.
FPF_MFA_EXT.1	This SER relates specifically to the handling of traffic that is used for the establishment of IPsec connections.

Objective SERs

FAU_SEL.1/VPN	The ability to suppress the generation of certain audit data related to VPN activity does not interfere with the ability of the GPOS to satisfy its security functionality.
-------------------------------	---

Implementation-dependent SERs

FAU_GEN.1/VPN	Audit data generated by the VPN client does not interfere with GPOS functionality. The possibility of the underlying OS platform generating audit records is consistent with the GPOS PP, which already contains FAU_GEN.1.
-------------------------------	---

Selection-based SERs

FCS_EAP_EXT.1	This SER defines an additional cryptographic protocol that is beyond the scope of those defined in the GPOS PP but does not prevent any GPOS PP functionality from being implemented.
FIA_PSK_EXT.1	This SER defines the use of pre-shared keys, which is behavior that only relates to the establishment of IPsec connections.
FIA_PSK_EXT.2	This SER relates to use of pre-shared keys, which is behavior that only applies to the establishment of IPsec connections.
FIA_PSK_EXT.3	This SER relates to use of pre-shared keys, which is behavior that only applies to the establishment of IPsec connections.
FIA_PSK_EXT.4	This SER relates to use of pre-shared keys, which is behavior that only applies to the establishment of IPsec connections.
FIA_PSK_EXT.5	This SER relates to use of pre-shared keys, which is behavior that only applies to the establishment of IPsec connections.

6.2 Protection Profile for Protection Profile for Mobile Device Fundamentals

6.2.1 Consistency of TOE Type

If this PP-Module is used to extend the MDF PP, the TOE type for the overall TOE is still a mobile device. The TOE boundary is simply extended to include VPN client functionality that is built into the device's software so that additional security functionality is claimed within the scope of the TOE.

6.2.2 Consistency of Security Problem Definition

The threats and assumptions defined by this PP-Module (see sections 3.1 and 3.2) supplement those defined in the MDF PP as follows:

Table 10: Consistency of Security Problem Definition (MDF PP base)

PP-Module Threat, Assumption, QSP	Consistency Rationale
T.TSF_CONFIGURATION	The threat of a misconfigured VPN client is consistent with the T.NETWORK and T.EAVESDROP threats in the MDF PP because failure to mitigate against misconfiguration makes these threats more significant.

T.TSF_FAILURE	A failure of T.TSF functionality could compromise the local system, which is consistent with the T.FLAWAPP threat in the MDF PP .
T.UNAUTHORIZED_ACCESS	The threat of an attacker gaining access to a network interface or data that is transmitted over it is consistent with the T.NETWORK and T.EAVESDROP threats in the MDF PP .
T.USER_DATA_REUSE	Inadvertent disclosure of user data to an unauthorized recipient is consistent with the T.EAVESDROP threat in the MDF PP .
A.NO_TOE_BYPASS	The A.NO_TOE_BYPASS assumption assumes that the OE is configured in such a manner that the only network route to the protected network is through the T.OE . This does not conflict with the MDF PP because the MDF PP makes no assumptions about the network architecture in which the T.OE is deployed.
A.PHYSICAL	The MDF PP includes the A.NOTIFY and A.PRECAUTION assumptions to mitigate the risk of physical theft of the T.OE . This is consistent with the A.PHYSICAL assumption in this PP-Module because the MDF PP includes reasonable assumptions about the physical security of the T.OE .
A.TRUSTED_CONFIG	This assumption is consistent with the MDF PP because the MDF PP includes the A.CONFIG assumption which assumes that all security functions are appropriately configured.

6.2.3 Consistency of OE Objectives

Table 11: Consistency of [OE](#) Objectives (MDF [PP](#) base)

PP-Module OE Objective	Consistency Rationale
OE.NO_TOE_BYPASS	This objective addresses behavior that is out of scope of the MDF PP and does not define an environment that an MDF T.OE is incapable of existing in.
OE.PHYSICAL	The operational environment of a mobile device cannot guarantee physical security, but the OE.PRECAUTION objective in the MDF PP ensures that an appropriate level of physical security is provided.
OE.TRUSTED_CONFIG	The expectation of trusted configuration is consistent with OE.CONFIG in the MDF PP .

6.2.4 Consistency of Requirements

This [PP-Module](#) identifies several [SFRs](#) from the MDF [PP](#) that are needed to support [VPN](#) client functionality. This is considered to be consistent because the functionality provided by the MDF [PP](#) is being used for its intended purpose. The [PP-Module](#) also identifies a number of modified [SFRs](#) from the MDF [PP](#) as well as new [SFRs](#) that are used entirely to provide functionality for [VPN](#) client. The rationale for why this does not conflict with the claims defined by the MDF [PP](#) are as follows:

Table 12: Consistency of Requirements (MDF [PP](#) base)

PP-Module Requirement	Consistency Rationale
Modified SFRs	
FCS_CKM.1	The ST author is instructed to make specific selections at minimum to address VPN client requirements; the SFR behavior itself is unmodified.
FCS_CKM.2/UNLOCKED	The ST author is instructed to make specific selections at minimum to address VPN client requirements; the SFR behavior itself is unmodified.
FCS_COP.1/ENCRYPT	The ST author is instructed to make specific selections at minimum to address VPN client requirements; the SFR behavior itself is unmodified.

FDP_IFC_EXT.1	The ST author is instructed to make specific selections at minimum to address VPN client requirements; the SER behavior itself is unmodified.
FMT_SMF_EXT.1	This PP-Module modifies the management function regarding Always-on VPN protection.
FTP_ITC_EXT.1	This PP-Module adds IPsec as a new protocol that is used to implement trusted channels.

Additional ~~SERs~~

FDP_VPN_EXT.1	The ability of the VPN client to prevent split tunneling of IPsec traffic requires it to have hooks into lower-level mobile device behavior, but there are no requirements in the MDF PP that would prevent this functionality from being supported.
---------------	--

Mandatory ~~SERs~~

FCS_CKM.1/VPN	This SER defines the method of key generation for IKE peer authentication, which is a function that does not interfere with the functionality defined in the MDF PP .
FCS_IPSEC_EXT.1	This SER defines the VPN client's IPsec implementation, which is added functionality that does not interfere with the MDF functions.
FDP_RIP.2	The requirement to protect against reuse of residual data is a property of the VPN client behavior and does not impact the MDF functionality.
FMT_SMF.1/VPN	The ability to configure the VPN client behavior does not affect whether the MDF as a whole can perform its security functions.
FPT_TST_EXT.1/VPN	Self-testing of the VPN client functionality does not impact the ability of the MDF to perform its security functions.

Optional ~~SERs~~

FIA_BMA_EXT.1	This SER relates to biometric authentication, which does not conflict with the MDF PP because it may be a function offered by the part of the TOE described by the MDF PP .
FPF_MFA_EXT.1	This SER relates specifically to the handling of traffic that is used for the establishment of IPsec connections.

Objective ~~SERs~~

FAU_SEL.1/VPN	The ability to suppress the generation of certain VPN client audit data does not interfere with MDM functionality. The MDF PP already contains FAU_SEL.1 as an objective SER which means that this functionality does not conflict with the expected behavior of a mobile device.
---------------	--

Implementation-dependent ~~SERs~~

FAU_GEN.1/VPN	Audit data generated by the VPN client does not interfere with MDF functionality. The possibility of the underlying MDF platform generating audit data is consistent with the MDF PP , which already contains FAU_GEN.1.
---------------	--

Selection-based ~~SERs~~

FCS_EAP_EXT.1	This SER defines an additional cryptographic protocol that is beyond the scope of those defined in the MDF PP but does not prevent any MDF PP functionality from being implemented.
FIA_PSK_EXT.1	This SER defines the use of pre-shared keys, which is behavior that only relates to the establishment of IPsec connections.
FIA_PSK_EXT.2	This SER relates to use of pre-shared keys, which is behavior that only applies to the establishment of IPsec connections.

FIA_PSK_EXT.3	This SEF relates to use of pre-shared keys, which is behavior that only applies to the establishment of IPsec connections.
FIA_PSK_EXT.4	This SEF relates to use of pre-shared keys, which is behavior that only applies to the establishment of IPsec connections.
FIA_PSK_EXT.5	This SEF relates to use of pre-shared keys, which is behavior that only applies to the establishment of IPsec connections.

6.3 Protection Profile for Protection Profile for Application Software

6.3.1 Consistency of TOE Type

If this ~~PP-Module~~ is used to extend the App PP, the ~~TOE~~ type for the overall ~~TOE~~ is still a software application. The ~~TOE~~ boundary is made more specific by defining the ~~TOE~~ as a specific type of application.

6.3.2 Consistency of Security Problem Definition

The threats and assumptions defined by this ~~PP-Module~~ (see sections 3.1 and 3.2) supplement those defined in the App PP as follows:

Table 13: Consistency of Security Problem Definition (App PP base)

PP-Module Threat, Assumption, QSP	Consistency Rationale
T.TSF_CONFIGURATION	The threat of a misconfigured VPN client is consistent with the T.LOCAL_ATTACK threat in the App PP.
T.TSF_FAILURE	A failure of TSF functionality could compromise the local system, which is consistent with the T.LOCAL_ATTACK threat in the App PP.
T.UNAUTHORIZED_ACCESS	The threat of an attacker gaining access to a network interface or data that is transmitted over it is consistent with the T.NETWORK_ATTACK and T.NETWORK_EAVESDROP threats in the App PP.
T.USER_DATA_REUSE	Inadvertent disclosure of user data to an unauthorized recipient is consistent with the T.NETWORK_EAVESDROP threat in the App PP.
A.NO_TOE_BYPASS	The A.NO_TOE_BYPASS assumption assumes that the OE is configured in such a manner that the only network route to the protected network is through the TOE . This does not conflict with the App PP because the App PP makes no assumptions about the network architecture in which the TOE is deployed.
A.PHYSICAL	The assumption that physical security is provided by the environment is not explicitly stated in the App PP but is consistent with the A.PLATFORM assumption defined in the App PP, which expects the computing platform to be trusted.
A.TRUSTED_CONFIG	The assumption that personnel responsible for the TOE 's configuration are trusted to follow the guidance is consistent with the A.PROPER_ADMIN defined in the App PP.

6.3.3 Consistency of OE Objectives

Table 14: Consistency of ~~OE~~ Objectives (App PP base)

PP-Module OE Objective	Consistency Rationale
OE.NO_TOE_BYPASS	This objective addresses behavior that is out of scope of the App PP and does not define an environment that is globally applicable to all software applications.

OE.PHYSICAL	This is part of satisfying OE.PLATFORM as defined in the App PP because physical security is required for the underlying platform to be considered ‘trustworthy’.
OE.TRUSTED_CONFIG	The expectation of trusted configuration is consistent with OE.PROPER_USER and OE.PROPER_ADMIN in the App PP.

6.3.4 Consistency of Requirements

This PP-Module identifies several SFRs from the App PP that are needed to support VPN client functionality. This is considered to be consistent because the functionality provided by the App PP is being used for its intended purpose. The PP-Module also identifies a number of modified SFRs from the App PP as well as new SFRs that are used entirely to provide functionality for VPN client. The rationale for why this does not conflict with the claims defined by the App PP are as follows:

Table 15: Consistency of Requirements (App PP base)

PP-Module Requirement	Consistency Rationale
Modified SFRs	
FCS_CKM.1/AK	The ST author is instructed to make specific selections at minimum to address VPN client requirements; the SFR behavior itself is unmodified. Additionally, this behavior is selection-based in the App PP but is made mandatory since it is required for VPN client functionality.
FCS_CKM.2	The ST author is instructed to make specific selections at minimum to address VPN client requirements and is modified to include DH group 14 as an additional supported method for key establishment.
FCS_CKM_EXT.1	The ST author is instructed to make specific selections at minimum to address VPN client requirements; specifically, since key generation services are required in some capacity in order to support VPN functionality, the ST author loses the choice of stating that the application does not have any key generation functionality. Additionally, this behavior is selection-based in the App PP but is made mandatory since it is required for VPN client functionality.
FCS_COP.1/SKC	The ST author is instructed to make specific selections at minimum to address VPN client requirements; the SFR behavior itself is unmodified.
FTP_DIT_EXT.1	This PP-Module requires the existing selection of IPsec to be chosen to satisfy the dependency on this PP-Module
Additional SFRs	
FCS_CKM.6	This PP-Module adds a requirement for key destruction, which is new functionality when compared to the App PP but does not interfere with its existing security functions.
FCS_CKM_EXT.2	This PP-Module adds a requirement for key storage, which is new functionality when compared to the App PP but does not interfere with its existing security functions.
Mandatory SFRs	
FCS_CKM.1/VPN	This SFR defines the method of key generation for IKE peer authentication, which is a function that does not interfere with the functionality defined in the App PP.
FCS_IPSEC_EXT.1	This SFR defines the VPN client’s IPsec implementation, which is added functionality that does not interfere with the application functions.
FDP_RIP.2	The requirement to protect against reuse of residual data is a property of the VPN client behavior and does not impact the general application functionality.
FMT_SMF.1/VPN	The ability to configure the VPN client behavior does not affect whether the application as a whole can perform its security functions.

FPT_TST_EXT.1/VPN	Self-testing of the VPN client functionality does not impact the ability of the application to perform its security functions.
Optional SERs	
FIA_BMA_EXT.1	This SER relates to biometric authentication, which does not conflict with the App PP because it may be a function offered by the OE in which a TOE defined by the App PP is deployed.
FPF_MFA_EXT.1	This SER relates specifically to the handling of traffic that is used for the establishment of IPsec connections.
Objective SERs	
FAU_SEL.1/VPN	The ability to suppress the generation of certain audit data related to VPN activity does not interfere with the ability of the application to satisfy its security functionality.
Implementation-dependent SERs	
FAU_GEN.1/VPN	Audit data generated by the VPN client does not interfere with application functionality. For cases where auditing is performed by the TOE platform, a software application is installed on a general-purpose OS or mobile device, both of which can reasonably be expected to provide audit functionality.
Selection-based SERs	
FCS_EAP_EXT.1	This SER defines an additional cryptographic protocol that is beyond the scope of those defined in the App PP but does not prevent any App PP functionality from being implemented.
FIA_PSK_EXT.1	This SER defines the use of pre-shared keys, which is behavior that only relates to the establishment of IPsec connections.
FIA_PSK_EXT.2	This SER relates to use of pre-shared keys, which is behavior that only applies to the establishment of IPsec connections.
FIA_PSK_EXT.3	This SER relates to use of pre-shared keys, which is behavior that only applies to the establishment of IPsec connections.
FIA_PSK_EXT.4	This SER relates to use of pre-shared keys, which is behavior that only applies to the establishment of IPsec connections.
FIA_PSK_EXT.5	This SER relates to use of pre-shared keys, which is behavior that only applies to the establishment of IPsec connections.

6.4 Protection Profile for Protection Profile for Mobile Device Management

6.4.1 Consistency of TOE Type

If this **PP-Module** is used to extend the MDM **PP**, the **TOE** type for the overall **TOE** is still a mobile device management solution. The **TOE** boundary is simply extended to include **VPN** client functionality that is included with the MDM software so that additional security functionality is claimed within the scope of the **TOE**.

6.4.2 Consistency of Security Problem Definition

The threats and assumptions defined by this **PP-Module** (see sections 3.1 and 3.2) supplement those defined in the MDM **PP** as follows:

Table 16: Consistency of Security Problem Definition (MDM **PP base)**

PP-Module Threat, Assumption, OSP	Consistency Rationale
---	------------------------------

T.TSF_CONFIGURATION	The threat of a misconfigured VPN client is consistent with the T.NETWORK_ATTACK and T.NETWORK_EAVESDROP threats in the MDM PP because failure to mitigate against misconfiguration makes these threats more significant.
T.TSF_FAILURE	A failure of TSF functionality could compromise the implementation of the IPsec channel, which would lead to an exploitation of the T.NETWORK_ATTACK threat.
T.UNAUTHORIZED_ACCESS	The threat of an attacker gaining access to a network interface or data that is transmitted over it is consistent with the T.NETWORK_ATTACK and T.NETWORK_EAVESDROP threats in the MDM PP.
T.USER_DATA_REUSE	Inadvertent disclosure of user data to an unauthorized recipient is consistent with the T.NETWORK_EAVESDROP threat in the MDM PP.
A.NO_TOE_BYPASS	The A.NO_TOE_BYPASS assumption assumes that the OE is configured in such a manner that the only network route to the protected network is through the TOE. This does not conflict with the MDM PP because the MDM PP makes no assumptions about the network architecture in which the TOE is deployed.
A.PHYSICAL	The assumption that physical security is provided by the environment is not explicitly stated in the MDM PP but is consistent with the A.MDM_SERVER_PLATFORM assumption defined in the MDM PP, which expects the computing platform to be trusted.
A.TRUSTED_CONFIG	The assumption that personnel responsible for the TOE's configuration are trusted to follow the guidance is consistent with the A.PROPER_ADMIN defined in the MDM PP.

6.4.3 Consistency of OE Objectives

Table 17: Consistency of OE Objectives (MDM PP base)

PP-Module OE Objective	Consistency Rationale
OE.NO_TOE_BYPASS	This objective addresses behavior that is out of scope of the MDM PP and does not define an environment that an MDM TOE is incapable of existing in.
OE.PHYSICAL	This is part of satisfying OE.IT_ENTERPRISE as defined in the MDM PP because provisioning of physical security is a reasonable expectation for an IT enterprise.
OE.TRUSTED_CONFIG	The expectation of trusted configuration is consistent with OE.PROPER_USER and OE.PROPER_ADMIN in the MDM PP.

6.4.4 Consistency of Requirements

This PP-Module identifies several SFRs from the MDM PP that are needed to support VPN client functionality. This is considered to be consistent because the functionality provided by the MDM PP is being used for its intended purpose. The PP-Module also identifies a number of modified SFRs from the MDM PP that are used entirely to provide functionality for VPN client. The rationale for why this does not conflict with the claims defined by the MDM PP are as follows:

Table 18: Consistency of Requirements (MDM PP base)

PP-Module Requirement	Consistency Rationale
Modified SFRs	
FCS_CKM.1	The ST author is instructed to make specific selections at minimum to address VPN client requirements; the SFR behavior itself is unmodified.

FCS_CKM.2	The ST author is instructed to make specific selections at minimum to address VPN client requirements; the SER behavior itself is unmodified.
FCS_COP.1/CONF_ALG	The ST author is instructed to make specific selections at minimum to address VPN client requirements; the SER behavior itself is unmodified.
FPT_ITT.1/INTER_XFER	When this SER relates to the PP:Module 's functionality, the ST author is instructed to make specific selections to implement this behavior using the VPN client. This is done by forcing the ST author to make specific selections that are already present in the MDM PP definition of the SER ; no new behavior is introduced by this.
FTP_ITC.1/INTER_XFER_IT	When this SER relates to the PP:Module 's functionality, the ST author is instructed to make specific selections to implement this behavior using the VPN client at minimum. This is done by forcing the ST author to make a specific selection that is already present in the MDM PP definition of the SER and by removing a selection option; no new behavior is introduced by this.
FTP_TRP.1/TRUSTPATH_REM_ADMIN	When this SER relates to the PP:Module 's functionality, the ST author is instructed to make specific selections to implement this behavior using the VPN client at minimum. This is done by forcing the ST author to make a specific selection that is already present in the MDM PP definition of the SER and by removing a selection option; no new behavior is introduced by this.

Additional ~~SERs~~

This ~~PP:Module~~ does not add any requirements when the MDM ~~PP~~ is the base.

Mandatory ~~SERs~~

FCS_CKM.1/VPN	This SER defines the method of key generation for IKE peer authentication, which is a function that does not interfere with the functionality defined in the MDM PP .
FCS_IPSEC_EXT.1	This SER defines the VPN client's IPsec implementation, which is added functionality that does not interfere with the MDM functions.
FDP_RIP.2	The requirement to protect against reuse of residual data is a property of the VPN client behavior and does not impact the MDM functionality.
FMT_SMF.1/VPN	The ability to configure the VPN client behavior does not affect whether the MDM as a whole can perform its security functions.
FPT_TST_EXT.1/VPN	Self-testing of the VPN client functionality does not impact the ability of the MDM to perform its security functions.

Optional ~~SERs~~

FIA_BMA_EXT.1	This SER relates to biometric authentication, which does not conflict with the MDM PP because it may be a function offered by the part of the TOE described by the MDM PP .
FPF_MFA_EXT.1	This SER relates specifically to the handling of traffic that is used for the establishment of IPsec connections.

Objective ~~SERs~~

FAU_SEL.1/VPN	The ability to suppress the generation of certain VPN client audit data does not interfere with MDM functionality. The MDM PP already contains FAU_SEL.1 as an optional SER , which means that this functionality does not conflict with the expected behavior of an MDM.
---------------	--

Implementation-dependent SERs

FAU_GEN.1/VPN

Audit data generated by the VPN client do not interfere with MDM functionality. The possibility of the MDM as a whole generating audit records is consistent with the MDM PP, which already contains FAU_GEN.1.

Selection-based SERs

FCS_EAP_EXT.1

This SER defines an additional cryptographic protocol that is beyond the scope of those defined in the MDM PP but does not prevent any MDM PP functionality from being implemented.

FIA_PSK_EXT.1

This SER defines the use of pre-shared keys, which is behavior that only relates to the establishment of IPsec connections.

FIA_PSK_EXT.2

This SER relates to use of pre-shared keys, which is behavior that only applies to the establishment of IPsec connections.

FIA_PSK_EXT.3

This SER relates to use of pre-shared keys, which is behavior that only applies to the establishment of IPsec connections.

FIA_PSK_EXT.4

This SER relates to use of pre-shared keys, which is behavior that only applies to the establishment of IPsec connections.

FIA_PSK_EXT.5

This SER relates to use of pre-shared keys, which is behavior that only applies to the establishment of IPsec connections.

Appendix A - Optional SFRs

A.1 Strictly Optional Requirements

A.1.1 Auditable Events for Strictly Optional SFRs

Entries from [Table 19](#) must be included for GPOS, MDF, and MDM Base-PPs if the strictly optional SFRs are included in the ST. When the App PP is the Base-PP, if any strictly optional SFRs are included in the ST, corresponding auditable event entries must be included only if the implementation-dependent requirement [FAU_GEN.1/VPN](#) is included in the ST.

Table 19: Auditable Events for Strictly Optional SFRs

Requirement	Auditable Events	Additional Audit Record Contents
FIA_BMA_EXT.1	No events specified	N/A
FPF_MFA_EXT.1	No events specified	N/A

A.1.2 Identification and Authentication (FIA)

The TOE may support leveraging the biometric API provided by the platform.

FIA_BMA_EXT.1 Biometric Activation

FIA_BMA_EXT.1.1

The TSF shall leverage the platform biometric features to confirm the user before initiating a trusted channel.

Application Note: In this context the platform refers to the OS or device and may be part of the TOE if those Base-PPs are leveraged.

Evaluation Activities ▼

[FIA_BMA_EXT.1.1](#)

TSS

The evaluator shall confirm that the TSS describes the calls to the platform and verifies they align with platform documentation.

Guidance

The evaluator shall ensure that any configuration details needed to enable the biometric prompt are included in the guidance documentation.

Tests

- *Test FIA_BMA_EXT.1.1:1: The evaluator shall initiate a connection and verify that a biometric prompt is presented and accepted before the connection can proceed. The evaluator shall also verify the connection does not proceed if the biometric is not presented or accepted.*

A.1.3 Packet Filtering (FPF)

FPF_MFA_EXT.1 Multifactor Authentication Filtering

FPF_MFA_EXT.1.1

The TSE shall not forward packets to the internal network until the IKE/IPsec tunnel has been established, except those necessary to ensure that the client is authenticated according to FIA_PSK_EXT.1.

Application Note: If FPF_MFA_EXT.1 is included, FIA_PSK_EXT.1 must be included.

Evaluation Activities ▼

FPF_MFA_EXT.1.1

TSS

The evaluator shall examine the TSS to verify that it describes how authentication packets are identified and how all other traffic is blocked until secondary authentication is successful.

Guidance

The evaluator shall examine the operational guidance to verify that it provides any necessary instructions to the administrator on how to enable and configure filtering.

Tests

- Test FPF_MFA_EXT.1.1:1: The evaluator shall attempt to connect and verify other traffic is rejected per the filtering rules. The evaluator shall then provide the supported PSKs and confirm it is accepted and traffic is no longer blocked.

A.2 Objective Requirements

A.2.1 Auditable Events for Objective SFRs

Entries from Table 20 must be included for GPOS, MDF, and MDM Base-PPs if the objective SFRs are included in the ST. When the App PP is the Base-PP, if any objective SFRs are included in the ST, corresponding auditable event entries must be included only if the implementation-dependent requirement FAU_GEN.1/VPN is included in the ST.

Table 20: Auditable Events for Objective SFRs

Requirement	Auditable Events	Additional Audit Record Contents
<u>FAU_SEL.1/VPN</u>	All modifications to the audit configuration that occur while the audit collection functions are operating.	No additional information.

A.2.2 Security Audit (FAU)

FAU_SEL.1/VPN Selective Audit

FAU_SEL.1.1/VPN

The [selection, choose one of: TSE, TOE platform] shall be able to select the set of events to be audited from the set of all auditable events based on the following attributes: [event type, [success of auditable security events, failure of auditable security events], [assignment: list of additional attributes that audit selectivity is based upon]].

Application Note: The intent of this requirement is to identify all criteria that can be selected to trigger an audit event. This can be configured through an interface on the client for a user or administrator to invoke, or it could be an interface that the VPN gateway uses to instruct the client on which events are to be audited. For the ST author, the assignment is used to list

any additional criteria or “none”. The auditable event types are listed in the Auditable Events table

The intent of the first selection is to allow for the case where the underlying platform is responsible for some audit log generation functionality.

Evaluation Activities ▼

FAU_SEL.1.1/VPN
TSS
There are no TSS EAs for this SFR.

Guidance
The evaluator shall review the administrative guidance to ensure that the guidance itemizes all event types, as well as describes all attributes that are to be selectable in accordance with the requirement, to include those attributes listed in the assignment. The administrative guidance shall also contain instructions on how to set the pre-selection or how the VPN gateway will configure the client, as well as explain the syntax (if present) for multi-value pre-selection. The administrative guidance shall also identify the audit data that are always recorded, regardless of the selection criteria currently being enforced.

Tests
The evaluator shall perform the following tests:

- Test FAU_SEL.1.1/VPN:1: For each attribute listed in the requirement, the evaluator shall devise a test to show that selecting the attribute causes only audit events with that attribute (or those that are always recorded, as identified in the administrative guidance) to be recorded.
- Test FAU_SEL.1.1/VPN:2: [conditional] If the TSF supports specification of more complex audit pre-selection criteria (e.g., multiple attributes, logical expressions using attributes), then the evaluator shall devise tests showing that this capability is correctly implemented. The evaluator shall also, in the test plan, provide a short narrative justifying the set of tests as representative and sufficient to exercise the capability.

A.3 Implementation-dependent Requirements

A.3.1 Auditable Events for Implementation-dependent SFRs

Entries from Table 21 must be included for GPOS, MDF, and MDM Base-PPs if the implementation-dependent SFRs are included in the ST. When the App PP is the Base-PP, if any implementation-dependent SFRs are included in the ST, corresponding auditable event entries must be included only if the implementation-dependent requirement FAU_GEN.1/VPN is included in the ST.

Table 21: Auditable Events for Implementation-dependent SFRs

Requirement	Auditable Events	Additional Audit Record Contents
FAU_GEN.1/VPN	No events specified	N/A

A.3.2 Security Audit (FAU)

FAU_GEN.1/VPN Audit Data Generation

FAU_GEN.1.1/VPN

The TSF and [selection, choose one of: TOE platform, no other component] shall be able to generate audit data of the following auditable events:

1. Start-up and shutdown of the audit functions;
2. All auditable events for the *[not specified]* level of audit;
3. All administrative actions;
4. *[Specifically defined auditable events listed in the Auditable Events tables]*.

Application Note: This requirement is implementation-dependent on the MDF PP, GPOS PP, or MDM PP being the Base-PP claimed by the TOE. In this case, this requirement must be claimed.

For the App PP Base-PP, this requirement is strictly optional.

In the case of "a," the audit functions referred to are those provided by the TOE. For example, in the case that the TOE was a stand-alone executable, auditing the startup and the shutdown of the TOE itself would be sufficient to meet the requirements of this clause.

Many auditable aspects of the SFRs included in this document deal with administrative actions. Item c above requires all administrative actions to be auditable, so no additional specification of the audibility of these actions is present in the Auditable Events table. While the TOE itself does not need to provide the ability to perform I&A for an administrator, this requirement implies that the TOE possess the capability to audit the events described by the Base-PP as "administrative actions" (primarily dealing with configuration of the functionality provided by the TOE).

The auditable events defined in the Auditable Events table are for the SFRs that are explicitly defined in this PP-Module (Table 5, Table 19, Table 20, Table 21, and Table 22). For any SFRs that are included as part of the TOE based on the claimed Base-PP (as defined in the Auditable Events tables in the Additional SFRs section for the corresponding Base-PP claim), it is expected that any applicable auditable events defined for those SFRs in the Base-PP are also claimed as part of the TSF. These auditable events only apply if the client actually performs these functions. If the platform performs any of these actions, then the platform is responsible for performing the auditing, not the TSF.

FAU_GEN.1.2/VPN

The TSF and **[selection, choose one of: TOE platform, no other component]** shall record within the audit data at least the following information:

1. Date and time of the event, type of event, subject identity, and the outcome (success or failure) of the event; and
2. For each audit event type, based on the auditable event definitions of the functional components included in the PP-Module/ST, *[information specified in column three of the Auditable Events tables]*.

Evaluation Activities ▼

FAU_GEN.1/VPN

TSS

The evaluator shall examine the TSS to determine that it describes the auditable events and the component that is responsible for each type of auditable event.

Guidance

The evaluator shall check the operational guidance and ensure that it lists all of the auditable events and provides a format for audit data. All audit data format types must be covered, along with a brief description of each field. The evaluator shall check to make sure that every audit event type mandated by the PP-Module for VPN Clients is described and that the description of the fields contains the information required in FAU_GEN.1.2/VPN, and the additional information specified in the Auditable Events table of the PP-Module for VPN Clients.

In particular, the evaluator shall ensure that the operational guidance is clear in relation to the contents for failed cryptographic events. In the Auditable Events table of the ~~PP-Module~~ for ~~VPN~~ Clients, information detailing the cryptographic mode of operation and a name or identifier for the object being encrypted is required. The evaluator shall ensure that name or identifier is sufficient to allow an administrator reviewing the audit log to determine the context of the cryptographic operation (for example, performed during a key negotiation exchange, performed when encrypting data for transit) as well as the non-TOE endpoint of the connection for cryptographic failures relating to communications with other ~~IT~~ systems.

The evaluator shall also make a determination of the administrative actions that are relevant in the context of the ~~PP-Module~~ for ~~VPN~~ Clients. The ~~TOE~~ may contain functionality that is not evaluated in the context of the ~~PP-Module~~ for ~~VPN~~ Clients because the functionality is not specified in an ~~SFR~~. This functionality may have administrative aspects that are described in the operational guidance. Since such administrative actions will not be performed in an evaluated configuration of the ~~TOE~~, the evaluator shall examine the operational guidance and make a determination of which administrative commands, including subcommands, scripts, and configuration files, are related to the configuration (including enabling or disabling) of the mechanisms implemented in the ~~TOE~~ that are necessary to enforce the requirements specified in the ~~PP-Module~~ for ~~VPN~~ Clients, which thus form the set of “all administrative actions”. The evaluator may perform this activity as part of the activities associated with ensuring the AGD_OPE guidance satisfies the requirements.

For each required auditable event, the evaluator shall examine the operational guidance to determine that it is clear to the reader where each event is generated (e.g., the ~~TSE~~ may generate its own audit logs in one location while the platform-provided auditable events are generated elsewhere).

Tests

The evaluator shall test the ~~TOE~~'s ability to correctly generate audit data by having the ~~TOE~~ generate audit data in accordance with the EAs associated with the functional requirements in the ~~PP-Module~~ for ~~VPN~~ Clients. Additionally, the evaluator shall test that each administrative action applicable in the context of the ~~PP-Module~~ for ~~VPN~~ Clients is auditable. When verifying the test results, the evaluator shall ensure the audit data generated during testing match the format specified in the guidance and that the fields in each audit record have the proper entries.

Note that the testing here can be accomplished in conjunction with the testing of the security mechanisms directly. For example, testing performed to ensure that the administrative guidance provided is correct verifies that AGD_OPE.1 is satisfied and should address the invocation of the administrative actions that are needed to verify the audit data is generated as expected.

Appendix B - Selection-based Requirements

B.1 Auditable Events for Selection-based SFRs

Entries from Table 22 must be included for GPOS, MDF, and MDM Base-PPs if the selection-based SFRs are included in the ST. When the App PP is the Base-PP, if any selection-based SFRs are included in the ST, corresponding auditable event entries must be included only if the implementation-dependent requirement FAU_GEN.1/VPN is included in the ST.

Table 22: Auditable Events for Selection-Based SFRs

Requirement	Auditable Events	Additional Audit Record Contents
FCS_EAP_EXT.1	No events specified	N/A
FIA_PSK_EXT.1	No events specified	N/A
FIA_PSK_EXT.2	No events specified	N/A
FIA_PSK_EXT.3	No events specified	N/A
FIA_PSK_EXT.4	No events specified	N/A
FIA_PSK_EXT.5	No events specified	N/A

B.2 Cryptographic Support (FCS)

FCS_EAP_EXT.1 EAP-TLS

The inclusion of this selection-based component depends upon selection in FCS_IPSEC_EXT.1.11.

- FCS_EAP_EXT.1.1

The TSF shall support [selection: EAP-TLS as specified in RFC 5216 and updated by RFC 8996, EAP-TTLS as specified in RFC 5281 and updated by RFC 8996] over a protected channel per the Base-PP with an authentication server.
- FCS_EAP_EXT.1.2

The TSF shall implement [selection: EAP-TLS, EAP-TTLS] with the TSF as the EAP client, an external authentication server as the EAP server and the VPN peer as the supplicant.
- FCS_EAP_EXT.1.3

The TSF shall use the MSK from the [selection: EAP-TLS, EAP-TTLS] response as the IKEv2 shared secret in the authentication payload.

Evaluation Activities ▼

FCS_EAP_EXT.1

TSS
The evaluator shall verify that the TSS describes the use of EAP options for each of the selected peer authentication mechanisms, that TLS with mutual authentication is used, that the random values are from an appropriate source, and that the EAP MSK is derived from the TLS master key and is used as the IKEv2 shared

key.

Guidance

The evaluator shall verify that the guidance documents describe any configurable features of the EAP or TLS functionality, including instructions for configuration of the authenticators and registration processes for clients.

Tests

Testing for TLS functionality is in accordance with the TLS package. For each supported EAP method claimed in FCS_EAP_TLS_EXT.1.1 and for each authentication method claimed in FCS_EAP_TLS_EXT.1.3, the evaluator shall perform the following tests:

- Test FCS_EAP_EXT.1:1: The evaluator shall follow AGD guidance to configure the TSF to use the EAP method claimed. The evaluator shall follow AGD guidance to configure the TSF to use the authentication method claimed, and for EAP-TTLS, register a client with the appropriate key material required for the authentication method. The evaluator shall establish a VPN session using a test client with a valid certificate, and for EAP-TTLS, configured to provide a correct value for the configured authenticator. The evaluator shall observe the VPN session is successful.
- Test FCS_EAP_EXT.1:2: (conditional for EAP-TTLS support): The evaluator shall cause the test client with a valid certificate to send an invalid authenticator for the claimed authentication method. For HOTP, replay the HOTP value sent previously. For TOTP or PSK, modify a byte of the properly constructed value and observe that the TSF aborts the session.
- Test FCS_EAP_EXT.1:3: The evaluator shall establish a new, valid certificate for a test client using an identifier not corresponding to a registered user. For EAP-TTLS, the evaluator shall cause the test client using this certificate to send a correct authenticator value for the registered user. The evaluator shall initiate a VPN session from the test client to the TSF and observe that the TSF aborts the session.
- Test FCS_EAP_EXT.1:4: The evaluator shall follow AGD guidance to configure the TSF to use a supported EAP method and register the user with the key material required for a supported authentication method. The evaluator shall configure a test client to respond to an IKEv2 exchange with EAP-request, providing valid phase 1 handshake and valid TLS handshake, but computing the phase 2 shared key using standard (non-EAP) methods. The evaluator shall initiate a VPN session between the test client and the TSF, and observe that the TSF aborts the session.

B.3 Identification and Authentication (FIA)

The TOE may support pre-shared keys for use in the IPsec protocol, and may use pre-shared keys in other protocols as well. PSK in the context of this document refer to generated values, memorized values subject to conditioning, one-time passwords, and combinations of the above as described in [FIA_PSK_EXT.1.2](#).

FIA_PSK_EXT.1 Pre-Shared Key Composition

The inclusion of this selection-based component depends upon selection in [FCS_IPSEC_EXT.1.11](#).

This component must be included in the ST if any of the following SFRs are included:

- [FPF_MFA_EXT.1](#)

FIA_PSK_EXT.1.1

The TSF shall be able to use pre-shared keys for [selection: IKEv2, multifactor authentication filtering].

FIA_PSK_EXT.1.2

The TSF shall be able to accept the following as pre-shared keys: [selection: generated bit-based, password-based, HMAC-based one-time password, time-based one-time password,

combination of a generated bit-based and HMAC-based one-time password, combination of a generated bit-based and time-based one-time password, combination of a password-based and HMAC-based one-time password, combination of a password-based and time-based one-time password] keys.

Application Note: If “pre-shared keys that conform to [RFC 8784](#)” is selected in [FCS_IPSEC_EXT.1.11](#), a generated, bit-based PSK must be used.

If any selection including "generated bit-based" is chosen, then [FIA_PSK_EXT.2](#) must be included.

If any selection including password-based keys is chosen, then [FIA_PSK_EXT.3](#) must be included.

If any selection including HMAC-based one-time password keys is chosen, then [FIA_PSK_EXT.4](#) must be included.

If any selection including time-based one-time password is chosen, then [FIA_PSK_EXT.5](#) must be included.

This requirement is selection-based on [FCS_IPSEC_EXT.1.11](#) or inclusion of [PPF_MFA_EXT.1](#).

Evaluation Activities

[FIA_PSK_EXT.1](#)

TSS

The evaluator shall examine the TSS to ensure that it identifies all protocols that allow pre-shared keys. For each protocol identified by the requirement, the evaluator shall confirm that the TSS states which pre-shared key selections are supported.

Guidance

The evaluator shall examine the operational guidance to determine that it provides guidance to administrators on how to configure all selected pre-shared key options if any configuration is required.

The evaluator shall examine the operational guidance to determine that it provides guidance to administrators on how to configure the mandatory_or_not flag per RFC 8784.

Tests

The evaluator shall also perform the following tests for each protocol (or instantiation of a protocol, if performed by a different implementation on the TOE).

- Test [FIA_PSK_EXT.1:1](#): For each mechanism selected in [FIA_PSK_EXT.1.2](#), the evaluator shall attempt to establish a connection and confirm that the connection requires the selected factors in the PSK to establish the connection in alignment with table 1 from RFC 8784.

[FIA_PSK_EXT.2](#) Generated Pre-Shared Keys

The inclusion of this selection-based component depends upon selection in [FIA_PSK_EXT.1.2](#).

[FIA_PSK_EXT.2.1](#)

The TSF shall be able to [**selection:** accept externally generated pre-shared keys, generate 256 bit-based pre-shared keys via the random number generator used by the TSF].

Application Note: Generated PSKs are expected to be shared between components via an out-of-band mechanism.

This requirement is selection-based on [FIA_PSK_EXT.1](#).

Evaluation Activities ▼

[FIA_PSK_EXT.2.1](#)

TSS

If "generate" is selected, the evaluator shall confirm that this process uses the RBG specified in [FCS_RBG.1](#) (or [FCS_RBG_EXT.1](#) in the case of [\[App PP\]](#) and the output matches the size selected in [FIA_PSK_EXT.2.1](#).

Guidance

The evaluator shall confirm the operational guidance contains instructions for entering generated pre-shared keys for each protocol identified in the [FIA_PSK_EXT.1.1](#).

Tests

- Test [FIA_PSK_EXT.2.1:1](#): [conditional] If "generate" was selected, the evaluator shall generate a pre-shared key and confirm the output matches the size selected in [FIA_PSK_EXT.2.1](#).

FIA_PSK_EXT.3 Password-Based Pre-Shared Keys

The inclusion of this selection-based component depends upon selection in [FIA_PSK_EXT.1.2](#).

FIA_PSK_EXT.3.1

The TSF shall support a PSK of up to [**assignment**: positive integer of 64 or more] characters.

FIA_PSK_EXT.3.2

The TSF shall allow PSKs to be composed of any combination of upper case characters, lower case characters, numbers, and the following special characters: "!", "@", "#", "\$", "%", "^", "&", "*", "(", and ")", and [**selection**: [**assignment**: other supported special characters], no other characters].

FIA_PSK_EXT.3.3

The TSF shall perform Password-based Key Derivation Functions in accordance with a specified cryptographic algorithm [*HMAC-SHA-384*], with [**assignment**: positive integer of 4096 or more] iterations, and output cryptographic key sizes [256 bits] that meet the following: [*NIST SP 800-132*].

FIA_PSK_EXT.3.4

The TSF shall not accept PSKs less than [**selection**: a value settable by the administrator, [**assignment**: minimum PSK length accepted by the TOE, must be ≥ 6]] and greater than the maximum PSK length defined in [FIA_PSK_EXT.3.1](#).

FIA_PSK_EXT.3.5

The TSF shall generate all salts using an RBG that meets [**selection**: [FCS_RBG.1](#), [FCS_RBG_EXT.1](#)] and with entropy of [**assignment**: value equal to or greater than 256] bits.

Application Note: For the first selection, the ST author selects [FCS_RBG.1](#) if the TOE implements its own DRBG. The ST author selects [FCS_RBG_EXT.1](#) if [\[App PP\]](#) is the Base-PP for the TOE and the TSF relies on a DRBG in its operational environment.

FIA_PSK_EXT.3.6

The TSSF shall require the PSK to be entered before every initiated connection.

FIA_PSK_EXT.3.7

The TSSF shall [**selection:** *provide a password strength meter, check the password against a denylist, perform no action to assist the user in choosing a strong password*].

Application Note: For [FIA_PSK_EXT.3.1](#), the ST author assigns the maximum size of the PSK it supports; it must support at least 64 characters or a length defined by the platform.

For [FIA_PSK_EXT.3.2](#), the ST author assigns any other supported characters; if there are no other supported characters, they should select "no other characters."

For [FIA_PSK_EXT.3.3](#), the ST author selects the parameters based on the PBKDF used by the TSSF.

For [FIA_PSK_EXT.3.4](#), if the minimum length is settable, then the ST author chooses "a value settable by the administrator." If the minimum length is not settable, the ST author fills in the assignment with the minimum length the PSK must be. This requirement is to ensure bounds work properly.

For [FIA_PSK_EXT.3.7](#), the ST author may select one, both, or neither of the functions in alignment with NIST SP 800-63b.

This requirement is selection-based on [FIA_PSK_EXT.1](#).

Evaluation Activities ▼

[FIA_PSK_EXT.3](#)

TSS

The evaluator shall examine the TSS to ensure it describes the process by which the bit-based pre-shared keys are used.

Support for length: The evaluator shall check to ensure that the TSS describes the allowable ranges for PSK lengths, and that at least 64 characters or a length defined by the platform may be specified by the user.

Support for character set: The evaluator shall check to ensure that the TSS describes the allowable character set and that it contains the characters listed in the SFR.

Support for PBKDF: The evaluator shall examine the TSS to ensure that the use of PBKDF2 is described and that the key sizes match that described by the ST author.

The evaluator shall check that the TSS describes the method by which the PSK is first encoded and then fed to the hash algorithm. The settings for the algorithm (padding, blocking, etc.) shall be described, and the evaluator shall verify that these are supported by the selections in this component as well as the selections concerning the hash function itself.

For the NIST SP 800-132-based conditioning of the PSK, the required evaluation activities will be performed when doing the evaluation activities for the appropriate requirements (FCS_COP.1/KeyedHash).

The evaluator shall confirm that the minimum length is described.

The ST author shall provide a description in the TSS regarding the salt generation. The evaluator shall confirm that the salt is generated using an RBG described in the DRBG that is generated by the TSSF or that is invoked from the operational environment.

[conditional] If "password strength meter" or "check the password against a denylist" is selected, the evaluator shall examine the TSS to ensure any password checking functionality provided by the TSSF is described and

contains details on how the function operates.

Guidance

The evaluator shall confirm the operational guidance contains instructions for entering bit-based pre-shared keys for each protocol identified in the requirement, is generating a bit-based pre-shared key, or both. The evaluator shall confirm that any management functions related to pre-shared keys that are performed by the TOE are specified in the operational guidance.

The guidance must specify the allowable characters for pre-shared keys, and that list must include, at minimum, the same items contained in [FIA_PSK_EXT.3.2](#).

The evaluator shall confirm the operational guidance contains any necessary instructions for enabling and configuring password checking functionality.

Tests

Support for Password/Passphrase characteristics: In addition to the analysis above, the evaluator shall also perform the following tests on a TOE configured according to the operational guidance:

- Test FIA_PSK_EXT.3:1: The evaluator shall compose a pre-shared key of at least 64 characters that contains a combination of the allowed characters in accordance with the [FIA_PSK_EXT.1.3](#) and verify that a successful protocol negotiation can be performed with the key.
- Test FIA_PSK_EXT.3:2: [conditional]: If the TOE supports pre-shared keys of multiple lengths, the evaluator shall repeat Test 1 using the minimum length and invalid lengths that are below the minimum length, above the maximum length, null length, empty length, or zero length. The minimum test should be successful, and the invalid lengths must be rejected by the TOE.
- Test FIA_PSK_EXT.3:3: [conditional]: If the TOE initiates connections, initiate and establish a remote connection, disconnect from the connection, and verify that the PSK is required when initiating the connection a second time.
- Test FIA_PSK_EXT.3:4: [conditional]: If the TOE supports a password meter, the evaluator shall enter a password and verify the password checker responds per the description in the TSS.
- Test FIA_PSK_EXT.3:5: [conditional]: If the TOE supports a password denylist, the evaluator shall enter a denylisted password and verify that the password is rejected or flagged as such.

FIA_PSK_EXT.4 HMAC-Based One-Time Password Pre-shared Keys Support

The inclusion of this selection-based component depends upon selection in [FIA_PSK_EXT.1.2](#).

FIA_PSK_EXT.4.1

The TSS shall accept and send an HOTP while initiating a VPN connection.

Application Note: This requirement is selection-based on [FIA_PSK_EXT.1](#)

Evaluation Activities ▼

[FIA_PSK_EXT.4.1](#)

TSS

The evaluator shall verify the TSS describes how the HOTP is input into the client and how that value is sent to the server.

Guidance

The evaluator shall verify the operational guidance contains any configuration necessary to enable HOTP.

Tests

- Test FIA_PSK_EXT.4.1:1: The evaluator shall configure the TQE to use a supported HOTP factor, then attempt to establish a connection using that factor. The evaluator shall verify the client prompts the user for the HOTP before initiating the connection. The evaluator shall verify the server validates the HOTP or receives confirmation from an authentication server before establishing the channel.

FIA_PSK_EXT.5 Time-Based One-Time Password Pre-shared Keys Support

The inclusion of this selection-based component depends upon selection in [FIA_PSK_EXT.1.2](#).

FIA_PSK_EXT.5.1

The TSE shall accept and send a TOTP while initiating a VPN connection.

Application Note: This requirement is selection-based on [FIA_PSK_EXT.1](#).

Evaluation Activities ▼

[FIA_PSK_EXT.5.1](#)

TSS

The evaluator shall verify the TSS describes how the TOTP is input into the client and how that value is sent to the server.

Guidance

The evaluator shall verify the operational guidance contains any configuration necessary to enable TOTP.

Tests

- Test FIA_PSK_EXT.5.1:1: The evaluator shall configure the TQE to use a supported TOTP factor, then attempt to establish a connection using that factor. The evaluator shall verify the client prompts the user for the TOTP before initiating the connection. The evaluator shall verify the server validates the TOTP or receives confirmation from an authentication server before establishing the channel.

Appendix C - Extended Component Definitions

This appendix contains the definitions for all extended requirements specified in the PP-Module.

C.1 Extended Components Table

All extended components specified in the PP-Module are listed in this table:

Table 23: Extended Component Definitions

Functional Class	Functional Components
Cryptographic Support (FCS)	FCS_CKM_EXT Cryptographic Key Management FCS_EAP_EXT EAP-TLS FCS_IPSEC_EXT IPsec
Identification and Authentication (FIA)	FIA_BMA_EXT Biometric Activation FIA_PSK_EXT Pre-Shared Key Composition FIA_X509_EXT X.509 Certificate Use and Management
Packet Filtering (FPF)	FPF_MFA_EXT Multifactor Authentication Filtering
Protection of the TSF (FPT)	FPT_TST_EXT TSF Self-Test
User Data Protection (FDP)	FDP_VPN_EXT Subset Information Flow Control

C.2 Extended Component Definitions

C.2.1 Cryptographic Support (FCS)

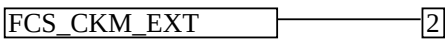
This PP-Module defines the following extended components as part of the FCS class originally defined by CC Part 2:

C.2.1.1 FCS_CKM_EXT Cryptographic Key Management

Family Behavior

Components in this family describe requirements for key management functionality such as key storage and destruction.

Component Leveling



[FCS_CKM_EXT.2](#), Cryptographic Key Storage, requires the TSF to securely store key data when not in use.

Management: FCS_CKM_EXT.2

No specific management functions are identified.

Audit: FCS_CKM_EXT.2

There are no auditable events foreseen.

FCS_CKM_EXT.2 Cryptographic Key Storage

Hierarchical to: No other components.

Dependencies to: No dependencies.

FCS_CKM_EXT.2.1

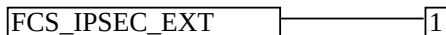
The [selection: *VPN client*, *OS*] shall store persistent secrets and private keys when not in use in *OS*-provided key storage.

C.2.1.2 FCS_IPSEC_EXT IPsec

Family Behavior

Components in this family describe requirements for IPsec implementation.

Component Leveling



[FCS_IPSEC_EXT.1](#), IPsec, requires the *TSE* to securely implement the IPsec protocol.

Management: FCS_IPSEC_EXT.1

The following actions could be considered for the management functions in FMT:

- Specify *VPN* gateways to use for connections
- Specify IPsec *VPN* clients to use for connections
- Specify IPsec-capable network devices to use for connections
- Specify client credentials to be used for connections

Audit: FCS_IPSEC_EXT.1

The following actions should be auditable if FAU_GEN Security Audit Data Generation is included in the *PP/ST*:

- Decisions to DISCARD or BYPASS network packets processed by the *TOE*
- Failure to establish an IPsec *SA*
- Establishment/Termination of an IPsec *SA*

FCS_IPSEC_EXT.1 IPsec

Hierarchical to: No other components.

Dependencies to: FCS_CKM.1 Cryptographic Key Generation

FCS_CKM.2 Cryptographic Key Distribution

FCS_COP.1 Cryptographic Operation

FCS_IPSEC_EXT.1.1

The *TSE* shall implement the IPsec architecture as specified in *RFC* 4301.

FCS_IPSEC_EXT.1.2

The *TSE* shall implement [selection: *tunnel mode*, *transport mode*].

FCS_IPSEC_EXT.1.3

The *TSE* shall have a nominal, final entry in the *SPD* that matches anything that is otherwise unmatched, and discards it.

FCS_IPSEC_EXT.1.4

The TSF shall implement the IPsec protocol ESP as defined by RFC 4303 using the cryptographic algorithms [assignment: supported cryptographic algorithms].

FCS_IPSEC_EXT.1.5

The TSF shall implement the protocol: [assignment: key exchange protocol].

FCS_IPSEC_EXT.1.6

The TSF shall ensure the encrypted payload in the [assignment: key exchange protocol] protocol uses the cryptographic algorithms [assignment: supported cryptographic algorithms] and no other algorithm.

FCS_IPSEC_EXT.1.7

The TSF shall ensure that [assignment: key exchange protocol] lifetimes can be configured by [assignment: authorized subjects] based on [assignment: values or metrics for maximum validity of negotiated keys]. If length of time is used, it must include at least one option that is 24 hours or less for Phase 1 SAs and eight hours or less for Phase 2 SAs.

FCS_IPSEC_EXT.1.8

The TSF shall ensure that IKE implements DH Groups

- 20 (384-bit Random ECP) according to RFC 5114 and

[selection:

- 15 (3072-bit MODP) according to RFC 3526
- 16 (4096-bit MODP) according to RFC 3526
- 17 (6144-bit MODP) according to RFC 3526
- 18 (8192-bit MODP) according to RFC 3526
- 21 (521-bit Random ECP) according to RFC 5114

].

FCS_IPSEC_EXT.1.9

The TSF shall generate the secret value x used in the IKE DH key exchange (" x " in $g^x \bmod p$) using the random bit generator specified in FCS_RBG.1, and having a length of at least [assignment: number of bits] bits.

FCS_IPSEC_EXT.1.10

The TSF shall generate nonces used in IKE exchanges in a manner such that the probability that a specific nonce value will be repeated during the life a specific IPsec SA is less than 1 in $2^{\text{[assignment: (one or more) "bits of security" values associated with the negotiated DH group as listed in Table 2 of NIST SP 800-57, Recommendation for Key Management – Part 1: General}]}$.

FCS_IPSEC_EXT.1.11

The TSF shall ensure that [assignment: key exchange protocol] performs peer authentication using [assignment: supported authentication mechanisms].

FCS_IPSEC_EXT.1.12

The TSF shall not establish an SA if the [selection: IP address, Fully Qualified Domain Name (FQDN), user FQDN, Distinguished Name (DN)] and [selection: no other reference identifier type, [assignment: other supported reference identifier types]] contained in a certificate does not match the expected values for the entity attempting to establish a connection.

FCS_IPSEC_EXT.1.13

The TSF shall not establish an SA if the presented identifier does not match the configured reference identifier of the peer.

FCS_IPSEC_EXT.1.14

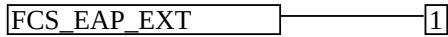
The [selection: *TSE, VPN gateway*] shall be able to ensure by default that the strength of the symmetric algorithm (in terms of the number of bits in the key) negotiated to protect the [selection: *IKEv1 Phase 1, IKEv2 IKE_SA*] connection is greater than or equal to the strength of the symmetric algorithm (in terms of the number of bits in the key) negotiated to protect the [selection: *IKEv1 Phase 2, IKEv2 CHILD_SA*] connection.

C.2.1.3 FCS_EAP_EXT EAP-TLS

Family Behavior

Components in this family describe the requirements for EAP-TLS.

Component Leveling



[FCS_EAP_EXT.1](#), EAP-TLS, defines the use of EAP-TLS.

Management: FCS_EAP_EXT.1

No specific management functions are identified.

Audit: FCS_EAP_EXT.1

No specific audit functions are identified.

FCS_EAP_EXT.1 EAP-TLS

Hierarchical to: No other components.

Dependencies to: FCS_IPSEC_EXT.1 IPsec

FCS_EAP_EXT.1.1

The TSE shall support [selection: *EAP-TLS as specified in RFC 5216 and updated by RFC 8996, EAP-TTLS as specified in RFC 5281 and updated by RFC 8996*] over a protected channel per the Base-PP with an authentication server.

FCS_EAP_EXT.1.2

The TSE shall implement [selection: *EAP-TLS, EAP-TTLS*] with the TSE as the EAP client, an external authentication server as the EAP server and the VPN peer as the supplicant.

FCS_EAP_EXT.1.3

The TSE shall use the MSK from the [selection: *EAP-TLS, EAP-TTLS*] response as the IKEv2 shared secret in the authentication payload.

C.2.2 Identification and Authentication (FIA)

This PP-Module defines the following extended components as part of the FIA class originally defined by CC Part 2:

C.2.2.1 FIA_X509_EXT X.509 Certificate Use and Management

Family Behavior

Components in this family describe the requirements that pertain to IP traffic and information flow through the VPN client.

Component Leveling

[FIA_X509_EXT.4](#), X.509 Certificate Use and Management, requires the ~~TQE~~ to perform X.509 certificate authentication and describes the behavior that is followed if the status of the certificate is unknown or invalid.

Management: FIA_X509_EXT.4

No specific management functions are identified.

Audit: FIA_X509_EXT.4

There are no auditable events foreseen.

FIA_X509_EXT.4 X.509 Certificate Use and Management

Hierarchical to: No other components.

Dependencies to: FIA_X509_EXT.1 X.509 Certificate Validation

FPT_TST_EXT.1 ~~TSE~~ Self-Test

FPT_TUD_EXT.1 Trusted Update

FIA_X509_EXT.4.1

The ~~TSE~~ shall use X.509v3 certificates as defined by [RFC 5280](#) to support authentication for IPsec exchanges, and [selection: digital signatures for FPT_TUD_EXT.1, integrity checks for FPT_TST_EXT.1, no additional uses].

FIA_X509_EXT.4.2

When a connection to determine the validity of a certificate cannot be established, the [selection, choose one of: ~~VPN~~ client, QS] shall [selection, choose one of: allow the administrator to choose whether to accept the certificate in these cases, accept the certificate, not accept the certificate].

FIA_X509_EXT.4.3

The [selection, choose one of: ~~VPN~~ client, QS] shall not establish an ~~SA~~ if a certificate or certificate path is deemed invalid.

C.2.2.2 FIA_BMA_EXT Biometric Activation

Family Behavior

Components in this family describe the requirements for biometrics when using the ~~VPN~~ client.

Component Leveling

[FIA_BMA_EXT.1](#), Biometric Activation, defines the use of biometrics when using the ~~VPN~~ client.

Management: FIA_BMA_EXT.1

No specific management functions are identified.

Audit: FIA_BMA_EXT.1

No specific audit functions are identified.

FIA_BMA_EXT.1 Biometric Activation

Hierarchical to: No other components.

Dependencies to: No dependencies.

FIA_BMA_EXT.1.1

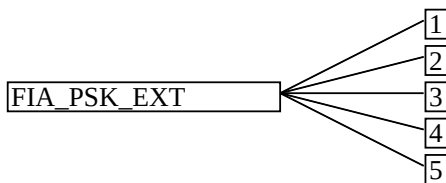
The T_{TSF} shall leverage the platform biometric features to confirm the user before initiating a trusted channel.

C.2.2.3 FIA_PSK_EXT Pre-Shared Key Composition

Family Behavior

Components in this family describe the requirements for pre-shared keys when implementing IPsec.

Component Leveling



[FIA_PSK_EXT.1](#), Pre-Shared Key Composition, defines the use and composition of pre-shared keys used for IPsec.

[FIA_PSK_EXT.2](#), Generated Pre-Shared Keys, defines the use and composition of generated pre-shared keys used for IPsec.

[FIA_PSK_EXT.3](#), Password-Based Pre-Shared Keys, defines the use and composition of password-based pre-shared keys used for IPsec.

[FIA_PSK_EXT.4](#), HMAC-Based One-Time Password Pre-shared Keys Support, defines the use and composition of HOTP pre-shared keys used for IPsec.

[FIA_PSK_EXT.5](#), Time-Based One-Time Password Pre-shared Keys Support, defines the use and composition of TOTP pre-shared keys used for IPsec.

Management: FIA_PSK_EXT.1

No specific management functions are identified.

Audit: FIA_PSK_EXT.1

No specific audit functions are identified.

FIA_PSK_EXT.1 Pre-Shared Key Composition

Hierarchical to: No other components.

Dependencies to: FCS_IPSEC_EXT.1 IPsec

FIA_PSK_EXT.1.1

The T_{TSF} shall be able to use pre-shared keys for [**selection:** *IKEv2, multifactor authentication filtering*].

FIA_PSK_EXT.1.2

The T_{TSF} shall be able to accept the following as pre-shared keys: [**selection:** *generated bit-based, password-based, HMAC-based one-time password, time-based one-time password, combination of a generated bit-based and HMAC-based one-time password, combination of a generated bit-based and time-based one-time password, combination of a password-based and HMAC-based one-time password, combination of a password-based and time-based one-time password*] keys.

Management: FIA_PSK_EXT.2

No specific management functions are identified.

Audit: FIA_PSK_EXT.2

The following actions should be auditable if FAU_GEN Security Audit Data Generation is included in the PP/ST:

- Failure of the randomization process

FIA_PSK_EXT.2 Generated Pre-Shared Keys

Hierarchical to: No other components.

Dependencies to: FIA_PSK_EXT.1 Pre-Shared Key Composition

FIA_PSK_EXT.2.1

The TSF shall be able to [**selection:** *accept externally generated pre-shared keys, generate 256 bit-based pre-shared keys via the random number generator used by the TSF.*].

Management: FIA_PSK_EXT.3

No specific management functions are identified.

Audit: FIA_PSK_EXT.3

The following actions should be auditable if FAU_GEN Security Audit Data Generation is included in the PP/ST:

- Failure of the randomization process

FIA_PSK_EXT.3 Password-Based Pre-Shared Keys

Hierarchical to: No other components.

Dependencies to: FCS_RBG.1 Random Bit Generation (RBG), FIA_PSK_EXT.1 Pre-Shared Key Composition

FIA_PSK_EXT.3.1

The TSF shall support a PSK of up to [**assignment:** *positive integer of 64 or more*] characters.

FIA_PSK_EXT.3.2

The TSF shall allow PSKs to be composed of any combination of upper case characters, lower case characters, numbers, and the following special characters: "!", "@", "#", "\$", "%", "^", "&", "*", "(", and ")", and [**selection:** [**assignment:** *other supported special characters*], no other characters].

FIA_PSK_EXT.3.3

The TSF shall perform Password-based Key Derivation Functions in accordance with a specified cryptographic algorithm [**assignment:** *cryptographic algorithm used for key derivation*], with [**assignment:** *positive integer of 4096 or more*] iterations, and output cryptographic key sizes [**assignment:** *output key size*] that meet the following: [**assignment:** *list of standards*].

FIA_PSK_EXT.3.4

The TSF shall not accept PSKs less than [**selection:** *a value settable by the administrator, [assignment: minimum PSK length accepted by the TOE, must be ≥ 6]*] and greater than the maximum PSK length defined in [FIA_PSK_EXT.3.1](#).

FIA_PSK_EXT.3.5

The T.SF shall generate all salts using an RBG that meets FCS_RBG.1 and with entropy of [**assignment:** *value equal to or greater than 256*] bits.

FIA_PSK_EXT.3.6

The T.SF shall require the PSK to be entered before every initiated connection.

FIA_PSK_EXT.3.7

The T.SF shall [**selection:** *provide a password strength meter, check the password against a denylist, perform no action to assist the user in choosing a strong password*].

Management: FIA_PSK_EXT.4

No specific management functions are identified.

Audit: FIA_PSK_EXT.4

No specific audit functions are identified.

FIA_PSK_EXT.4 HMAC-Based One-Time Password Pre-shared Keys Support

Hierarchical to: No other components.

Dependencies to: FIA_PSK_EXT.1 Pre-Shared Key Composition

FIA_PSK_EXT.4.1

The T.SF shall accept and send an HOTP while initiating a VPN connection.

Management: FIA_PSK_EXT.5

No specific management functions are identified.

Audit: FIA_PSK_EXT.5

No specific audit functions are identified.

FIA_PSK_EXT.5 Time-Based One-Time Password Pre-shared Keys Support

Hierarchical to: No other components.

Dependencies to: FIA_PSK_EXT.1 Pre-Shared Key Composition

FIA_PSK_EXT.5.1

The T.SF shall accept and send a TOTP while initiating a VPN connection.

C.2.3 Packet Filtering (FPF)

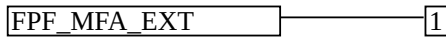
This class contains families that describe packet filtering behavior. Packet filtering refers to the notion that network traffic that is transmitted “through” the TOE (i.e. the source and destination of the traffic is not the TOE but the TOE is on the routing path between these two entities) can be treated differently by the T.SF based on attributes associated with the traffic. As this class is defined solely to contain an extended component defined for this PP-Module, it has one family, FPF_MFA_EXT.

C.2.3.1 FPF_MFA_EXT Multifactor Authentication Filtering

Family Behavior

Components in this family describe the requirements for multifactor authentication filtering when using the VPN client.

Component Leveling



[FPF_MFA_EXT.1](#), Multifactor Authentication Filtering, defines the use and composition of multifactor authentication filtering.

Management: FPF_MFA_EXT.1

No specific management functions are identified.

Audit: FPF_MFA_EXT.1

No specific audit functions are identified.

FPF_MFA_EXT.1 Multifactor Authentication Filtering

Hierarchical to: No other components.

Dependencies to: No dependencies.

FPF_MFA_EXT.1.1

The TSF shall not forward packets to the internal network until the IKE/IPsec tunnel has been established, except those necessary to ensure that the client is authenticated according to [FIA_PSK_EXT.1](#).

C.2.4 Protection of the TSF (FPT)

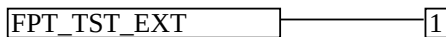
This PP-Module defines the following extended components as part of the FPT class originally defined by CC Part 2:

C.2.4.1 FPT_TST_EXT TSF Self-Test

Family Behavior

Components in this family describe requirements for self-test to verify functionality and integrity of the TOE.

Component Leveling



[FPT_TST_EXT.1](#), TSF Self-Test, requires the TOE to perform power on self-tests to verify its functionality and the integrity of its stored executable code.

Management: FPT_TST_EXT.1

No specific management functions are identified.

Audit: FPT_TST_EXT.1

There are no auditable events foreseen.

FPT_TST_EXT.1 TSF Self-Test

Hierarchical to: No other components.

Dependencies to: No dependencies.

FPT_TST_EXT.1.1

The [selection, choose one of: TOE, TOE platform] shall run a suite of self tests during initial start-up (on power on) to demonstrate the correct operation of the TSE.

FPT_TST_EXT.1.2

The [selection, choose one of: TOE, TOE platform] shall provide the capability to verify the integrity of stored TSE executable code when it is loaded for execution through the use of the [assignment: *cryptographic services provided either by the portion of the TOE described by the Base-PP or by the OE*].

C.2.5 User Data Protection (FDP)

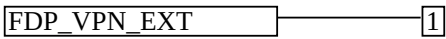
This PP-Module defines the following extended components as part of the FDP class originally defined by CC Part 2:

C.2.5.1 FDP_VPN_EXT Subset Information Flow Control

Family Behavior

Components in this family describe the requirements that pertain to IP traffic and information flow through the VPN client.

Component Leveling



[FDP_VPN_EXT.1](#), Split Tunnel Prevention, requires the TSE to process all IP traffic through its VPN client functionality.

Management: FDP_VPN_EXT.1

No specific management functions are identified.

Audit: FDP_VPN_EXT.1

There are no auditable events foreseen.

FDP_VPN_EXT.1 Split Tunnel Prevention

Hierarchical to: No other components.

Dependencies to: FCS_IPSEC_EXT.1 IPsec

FDP_VPN_EXT.1.1

The TSE shall ensure that all IP traffic (other than IP traffic required to establish the VPN connection) flow through the IPsec VPN client.

Appendix D - Implicitly Satisfied Requirements

This appendix lists requirements that should be considered satisfied by products successfully evaluated against this PP-Module. These requirements are not featured explicitly as SFRs and should not be included in the ST. They are not included as standalone SFRs because it would increase the time, cost, and complexity of evaluation. This approach is permitted by [CC] Part 1, 8.3 Dependencies between components.

This information benefits systems engineering activities which call for inclusion of particular security controls. Evaluation against the PP-Module provides evidence that these controls are present and have been evaluated.

Table 24: Implicitly Satisfied Requirements

Requirement	Rationale for Satisfaction
FCS_CKM.2 – Cryptographic Key Distribution, or FCS_COP.1 – Cryptographic Operation	FCS_CKM.1 (which is defined in this PP-Module as FCS_CKM.1/VPN) requires one of FCS_CKM.2 or FCS_COP.1 to be claimed so that the generated keys can serve some security-relevant purpose. Each of the Base-PPs for this PP-Module define an iteration of FCS_COP.1 for symmetric cryptography that is expected to use the IKE keys generated by FCS_CKM.1/VPN . Therefore, this dependency is satisfied through requirements defined in the Base-PPs.
FCS_COP.1 – Cryptographic Operation	FCS_IPSEC_EXT.1 has a dependency on FCS_COP.1 because of the cryptographic operations that are needed in support of implementing the IPsec protocol. FCS_COP.1 is not defined in this PP-Module because each of the supported Base-PPs define iterations of FCS_COP.1 that support the functions that are relevant to IPsec.
FMT_MTD.1 – Management of TSF Data	FAU_SEL.1/VPN has a dependency on FMT_MTD.1 to enforce appropriate access controls on the audit configuration, as this is TSF data. This SFR is not explicitly defined in any of the supported Base-PPs but the dependency is implicitly addressed by each Base-PP in the following manner: • GPOS PP: The GPOS PP implicitly defines the existence of ‘user’ and ‘administrator’ roles in the extended SFRs FMT_MOF_EXT.1 and FMT_SMF_EXT.1. A TOE that conforms to this Base-PP can associate the ability to perform the functionality defined by FAU_SEL.1/VPN to one or both of these roles. • MDF PP: The MDF PP implicitly defines the existence of ‘user,’ ‘administrator,’ and ‘MDM’ roles in the SFRs FMT_MOF_EXT.1 and FMT_SMF.1. A TOE that conforms to this Base-PP can associate the ability to perform the functionality defined by FAU_SEL.1/VPN to one or more of these roles. • App PP: The App PP does not define the existence of a separately authenticated management interface; instead, the App PP assumes that authentication to the underlying QS platform is sufficient authorization to access the application’s management functionality. • MDM PP: The MDM PP defines the existence of management roles in FMT_SMR.1/SECMAN_ROLES. A TOE that conforms to this Base-PP can associate the ability to perform the functionality defined by FAU_SEL.1/VPN to one or more of the roles defined here.
FPT_STM.1 – Reliable Time Stamps	FAU_GEN.1/VPN has a dependency on FPT_STM.1 because audit data is required to have timestamps that are based on reliable clock data. All of the supported Base-PPs either define this requirement explicitly or provide rationale for why the reader should expect that a reliable clock service should be present. Depending on the claimed Base-PP, the dependency is satisfied in the following manner: • GPOS PP: The GPOS PP states that FPT_STM.1 is implicitly satisfied by the requirements of FAU_GEN.1 since that requirement could not be satisfied if no clock

service was present. Additionally, a clock service is reasonably assumed to be provided by a general-purpose OS.

- MDF PP: The MDF PP explicitly defines FPT_STM.1.
- App PP: The App PP assumption A.PLATFORM assumes that the general-purpose computing platform on which the TOE is installed is ‘a trustworthy computing platform.’ System time data is not explicitly mentioned but a clock service is reasonably assumed to be provided by a general-purpose computer.
- MDM PP: The MDM PP assumption A.MDM_SERVER_PLATFORM assumes that the platform on which the TOE is installed will provide reliable time services.

FPT_STM.1 – Reliable Time Stamps

FAU_GEN.1 has a dependency on FPT_STM.1. While not explicitly stated in the PP, it is assumed that this will be provided by the underlying hardware platform on which the TOE is installed. This is because the TOE is installed as a software or firmware product that runs on general-purpose computing hardware so a hardware clock is assumed to be available.

Appendix E - Entropy Documentation and Assessment

The TOE does not require any additional supplementary information to describe its entropy sources beyond the requirements outlined in the Base-PPs. As with other Base-PP requirements, the only additional requirement is that the entropy documentation also applies to the specific VPN client capabilities of the TOE in addition to the functionality required by the claimed Base-PP.

Appendix F - Acronyms

Table 25: Acronyms

Acronym	Meaning
AES	Advanced Encryption Standard
Base-PP	Base Protection Profile
CC	Common Criteria
CEM	Common Evaluation Methodology
cPP	Collaborative Protection Profile
CRL	Certificate Revocation List
CSP	Critical Security Parameter
DH	Diffie-Hellman
DN	Distinguished Name
DSS	Digital Signature Standard
ECC	Elliptic Curve Cryptography
EP	Extended Package
ESP	Encapsulating Security Protocol
EUD	End-User Device
FEC	Finite Field Cryptography
FIPS	Federal Information Processing Standards
FP	Functional Package
FQDN	Fully Qualified Domain Name
IKE	Internet Key Exchange
IP	Internet Protocol
IT	Information Technology
MD	Mobile Device (Fundamentals)
NAT	Network Address Translation
NIST	National Institute of Standards and Technology
OCSP	Online Certificate Status Protocol
OE	Operational Environment

OS	(General Purpose) Operating System
OSP	Organizational Security Policy
PP	Protection Profile
PP-Configuration	Protection Profile Configuration
PP-Module	Protection Profile Module
PUB	Publication
RBG	Random Bit Generation
REC	Request For Comment
SA	Security Association
SAR	Security Assurance Requirement
SD	Supporting Document
SFR	Security Functional Requirement
SHA	Secure Hash Algorithm
SPD	Security Policy Database
ST	Security Target
TOE	Target of Evaluation
TSE	TOE Security Functionality
TSEI	TSE Interface
TSS	TOE Summary Specification
VPN	Virtual Private Network

Appendix G - Bibliography

Table 26: Bibliography

Identifier	Title
[CC]	Common Criteria for Information Technology Security Evaluation - - Part 1: Introduction and general model, CCMB-2022-11-001, CC:2022, Revision 1, November 2022. - Part 2: Security functional requirements, CCMB-2022-11-002, CC:2022, Revision 1, November 2022. - Part 3: Security assurance requirements, CCMB-2022-11-003, CC:2022, Revision 1, November 2022. - Part 4: Framework for the specification of evaluation methods and activities, CCMB-2022-11-004, CC:2022, Revision 1, November 2022. - Part 5: Pre-defined packages of security requirements, CCMB-2022-11-005, CC:2022, Revision 1, November 2022.
[CEM]	Common Methodology for Information Technology Security Evaluation - Evaluation methodology, CCMB-2022-11-006, CC:2022, Revision 1, November 2022.
[App PP]	Protection Profile for Application Software, Version 2.0, June 16, 2025
[GPOS PP]	Protection Profile for General Purpose Operating Systems, Version 5.0, September 27, 2022
[MDF PP]	Protection Profile for Mobile Device Fundamentals, Version 4.0, Version 4.0, September 12, 2022
[MDM PP]	Protection Profile for Mobile Device Management, Version 5.0, April 25, 2019